

ChronoFlow

Security Project Report

Certificate in Securing Ubiquitous Systems — Practice Module

Team Number	3
Members	Htet Aung Lu Shuwen Shirley Chow Thet Naung Soe Walfarid Hermawan Limbong
Date	24 May 2026

Table of Contents..... 2

1. Introduction..... 3

 1.1 Project Context..... 3

 1.2 Business Needs..... 3

 1.3 Stakeholders..... 4

 1.4 General Architecture..... 4

 1.5 Project Scope..... 5

 2.1 Project Plan..... 6

 2.2 Project Status..... 6

 2.3 Project Metrics..... 7

3. Security Requirements..... 8

4. Threat Modelling..... 11

 4.1 Trust boundaries and data flow diagram..... 11

 4.2 Trust Boundary Matrix..... 11

 4.3 Threat Register..... 13

 4.4 Risk Assessment..... 16

 4.5 Prioritised threat register..... 19

5. Security Architecture and Controls..... 22

 5.1 Controls Mapping..... 22

6. Verification of Security Controls..... 27

7. Other Things to be Highlighted..... 32

 Known Limitations..... 32

 Future Work..... 32

 Privacy and Ethical Notes..... 32

 Team Reflections / Lessons Learned..... 32

8. Appendix..... 33

1. Introduction

This report documents the security engineering work undertaken for ChronoFlow as part of the Certificate in Securing Ubiquitous Systems practice module. It covers the security requirements, threat model, security architecture and controls, and verification evidence for an integrated web, mobile, and cloud event-management platform. The goal is to demonstrate that reasonable confidentiality, integrity, and availability protections have been designed and implemented across the full system stack.

1.1 Project Context

ChronoFlow is an event management platform developed as a course/project deliverable. The solution spans a React web frontend, a Flutter mobile app (iOS and Android), and a cloud-hosted backend on Google Cloud Platform (GCP). Clients communicate with backend microservices through an API Gateway (Spring Cloud Gateway). Identity uses Firebase Authentication (e.g. Google Sign-In) with backend token validation and session handling (Sa-Token, refresh cookies).

Property	Details
Development Phase	Deployed application demo
Deployment Environments	Single environment - production URLs
Technology stack	Mobile (Flutter/Dart) — Riverpod for state, Firebase Auth + Google Sign-In, flutter_secure_storage for secrets, and freeRASP for runtime hardening. QR scanning via mobile_scanner. Web (React + TypeScript) — Vite-based build, Vitest + Playwright for testing, ESLint and Semgrep for linting/SCA, npm audit for dependency checks. Backend (Java 17 / Spring Boot ~3.3) — Spring Cloud Gateway as the API entry point, Sa-Token for auth/session, MyBatis-Plus + Druid for data access, Redisson/Lock4j on Redis, Dubbo RPC for inter-service calls, and Nacos for discovery and config. Cloud (GCP) — GKE for compute, Cloud SQL, Memorystore Redis, Pub/Sub, Firebase Auth for identity/OAuth tokens, FCM for push, and SES for email

1.2 Business Needs

Organisers need to create and manage events, coordinate staff tasks, and handle attendee flows (e.g. check-in) without exposing sensitive operations to unauthorised users. The organisation requires reasonable confidentiality and integrity of event and user data, availability of the service during scheduled use, and auditability of security-relevant actions where feasible.

Success criteria:

- All user data and API traffic protected in transit and at rest
- Only authenticated and authorised users can access protected features and data
- Mobile application meets baseline security standards for storage, signing, and runtime integrity
- Third-party dependencies and source code free of high-severity vulnerabilities at time of release
- Cloud infrastructure isolated and hardened against external exposure
- Security-relevant events are logged and monitorable

1.3 Stakeholders

Category	Role / Name	Interest
Business	Event Operations Manager	Efficient event creation, staff coordination, attendee check-in
Business	Compliance / Data Protection	Data privacy, regulatory compliance, audit trails
IT / Engineering	Platform Architect	Architecture decisions, security controls, scalability
IT / Engineering	DevSecOps / Security	CI/CD pipeline security, vulnerability management, operations
End Users	Event Organisers	Create/manage events via web and mobile
End Users	Staff (QR/Check-in)	Check-in attendees via mobile app (QR scanning)
End Users	Attendees	Registration, event browsing, QR ticket retrieval

1.4 General Architecture

ChronoFlow uses a layered, microservices-based architecture deployed on Google Cloud Platform. The diagram below illustrates the principal components and their interactions.

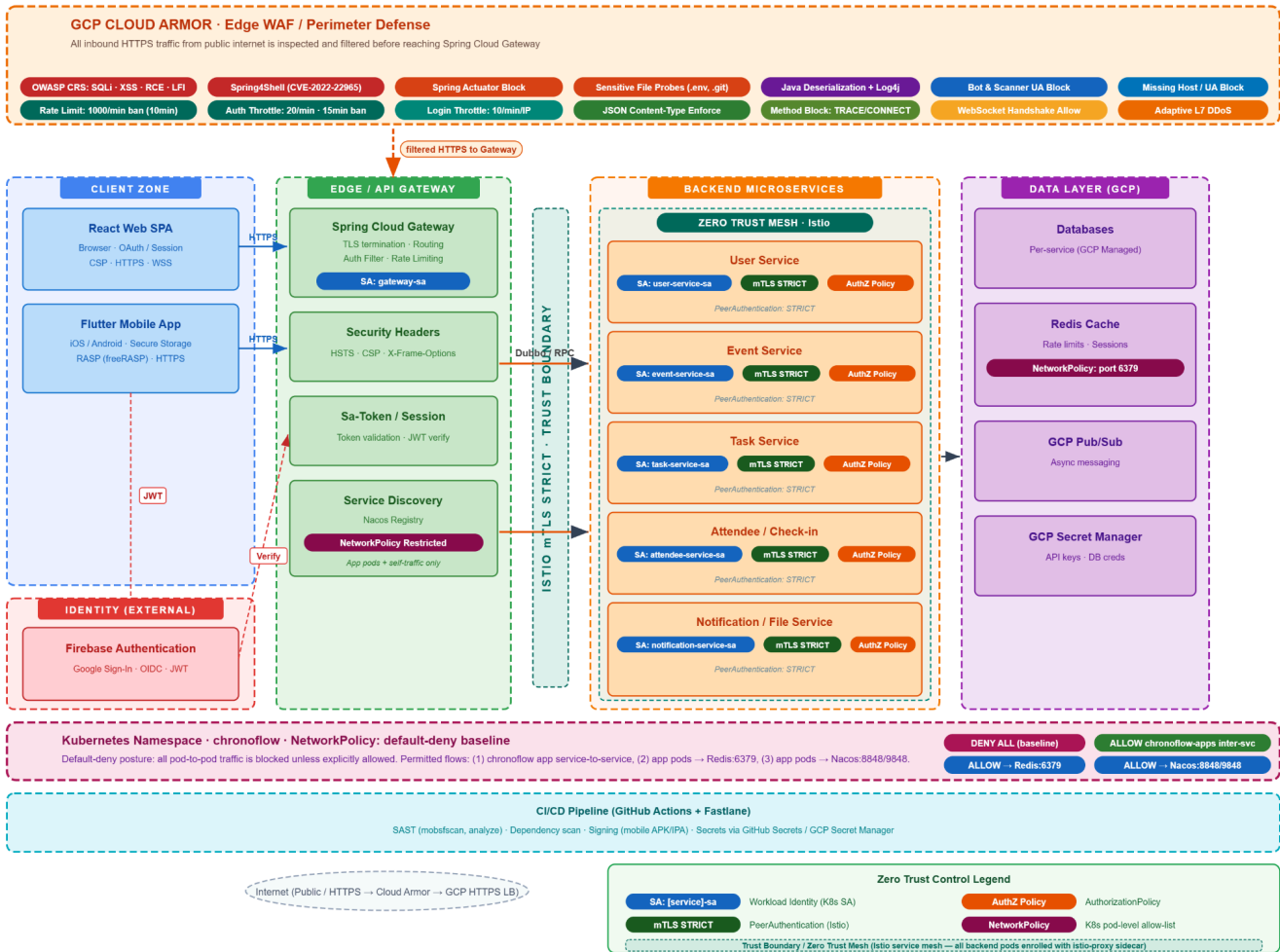


Figure 1.4.1 — ChronoFlow General Architecture

Component summary:

- Web Client: React SPA in the browser; communicates via HTTPS; OAuth / session patterns (Firebase, cookies).
- Mobile Client: Flutter app (iOS/Android); native UI with HTTPS API calls to api.chronoflow.site; secure token storage; optional RASP (freeRASP) at startup.
- Edge / API: Spring Cloud Gateway — TLS termination, routing, authentication filters, security headers (HSTS, CSP), rate limiting.
- Microservices: User, Event, Task, Notification, File, Attendee services with Nacos service discovery; internal Dubbo/gRPC.
- Data & Messaging: Per-service databases, Redis, GCP Pub/Sub, email/push channels.
- Identity: Firebase / OIDC for social login; backend validates tokens and issues internal session semantics (Sa-Token).

1.5 Project Scope

In scope (security perspective):

- Web frontend: transport security, auth flows, XSS mitigations (React, CSP from gateway), cookie usage, dependency posture.
- Mobile app: TLS to API, secure storage, session handling, CI signing, release pipeline secrets, static analysis (mobfsfscan) in CI.
- Backend / gateway: authentication/authorisation, headers, rate limits, multi-tenancy isolation, secrets management, logging.
- Threat modelling and security requirements documentation for the integrated system.

Out of scope (with justification):

- Formal penetration test by external third party — Out of course scope.
- Hardware security module (HSM) for keys — not required at this scale.
- Full WebView hardening — N/A; most key features in mobile app is native + API only.
- Inter-Process Communication & Intent Security - Application operates in a closed ecosystem with no external app interaction or integration suraces. However, baseline hardening (android:exported="false") remains mandatory.
- Deep Link & URL Scheme Security- Application does not handle external inbound navigation, custom URI schemes or universal linking.
- Step-Up Authentication - The business model and risk profile do not involve high-value transactional operations that mandate contextual step-up authentication.
- Active RASP Blocking Actions - Application strategy relies exclusively on passive notification rather than active runtime termination.

2. Project Conduct

The team organised work through weekly synchronisation meetings, a shared GitHub repository with branch-based feature development, and pull-request reviews requiring at least one approval before merge. Work was aligned to the module milestones. Security review checkpoints were included in each sprint cycle.

The project ran from 17 February 2026 to 24 May 2026 across five team members. The team held weekly synchronisation meetings each Saturday to review progress, blockers, and upcoming tasks. Development followed a GitHub Flow branching strategy — all work was carried out in feature branches with pull requests requiring at least one peer approval before merge. GitHub Actions CI ran automatically on every PR, executing linting, SAST, SCA, and mobile security scans. Work packages were aligned to the five module milestones defined below.

2.1 Project Plan

Work Package	Effort (person -days)	Owner(s)
1. Requirements & scope	5	All Members
2. Architecture & threat modelling	5	All Members
3. Security controls implementation	380	Backend/ Frontend: Htet Aung Lu, Shuwen, Thet Naung Soe Mobile: Shirley, Walfarid Websocket: Thet Naung CI/CD, Kubernetes: Thet Naung, Walfarid, Shirley Infrastructure: Walfarid, Thet Naung Soe
4. Verification (tests, scans, manual checks)	5	All Members
5. Documentation & report	5	All Members
TOTAL	400	

2.2 Project Status

Current status (as of 24 May 2026):

- On track — all milestones completed by 24 May 2026

Completed:

- TLS 1.2+ configured and enforced on all production endpoints (web and API)
- Firebase Auth integrated with Spring Cloud Gateway token validation and Sa-Token session management
- flutter_secure_storage implemented for token storage on iOS (Keychain) and Android (Keystore); plaintext SharedPreferences removed

Outstanding issues / risks:

- Redis TLS (in-transit encryption) not implemented — mitigated by Kubernetes NetworkPolicy restricting Redis access to approved pods only

Decision log:

- Sa-Token selected over custom JWT middleware for session management due to built-in RBAC annotation support and refresh token handling
- freeRASP selected for mobile runtime integrity checks due to open-source licence, Flutter support, and zero-cost for academic use

2.3 Project Metrics

Milestone	Target Date	Actual Date
M1 — Requirements & scope finalised	17 Feb 2026	17 Feb 2026
M2 — Threat model approved	14 Mar 2026	14 Mar 2026
M3 — Controls implemented	25 Apr 2026	25 Apr 2026
M4 — Verification complete	16 May 2026	16 May 2026
M5 — Report submitted	24 May 2026	24 May 2026

Team Member	Effort (hrs)	Roles
Shirley	80	IOS mobile development, CI/CD
Htet Aung Lu	80	Web frontend, threat modelling, security architecture
Shuwen	80	Backend microservices, API gateway configuration, documentation
Thet Naung Soe	80	Cloud infrastructure, backend services, CI/CD
Walfarid Hermawan Limbong	80	Cloud infrastructure, Android mobile development, CI/CD

CI/CD Metric	Value
PR checks pass rate	100%
Test coverage (area)	Backend: unit + integration tests; Frontend: Vitest + Playwright E2E; Mobile: CI scan
CI workflows	GitHub Actions (CI lint/SAST/SCA, CD build/sign/deploy)

3. Security Requirements

Requirements are organised by feature area. Mandatory (M) requirements must be satisfied for release; desirable (D) requirements are targeted but may be deferred with documented justification.

Req ID	M/D	Requirement	Status
Auth & Session			
REQ-SEC-001	M	Only authenticated users may access protected APIs and screens.	Pass
REQ-SEC-002	M	Credentials and tokens must not be stored in plaintext in app-local storage (e.g. SharedPreferences).	Pass
Authorisation			
REQ-SEC-003	M	Role/permission checks enforced server-side for each protected operation (not only in UI).	Pass
REQ-SEC-004	D	Tenant/user isolation for data (if multi-tenant).	Pass
Communication			
REQ-SEC-005	M	Production API and web traffic uses TLS (HTTPS only).	Pass
REQ-SEC-006	M	Security headers on gateway responses: HSTS, CSP, X-Frame-Options, X-Content-Type-Options.	Pass
REQ-SEC-007	M	Enforce modern connection encryption by requiring TLS 1.2 or higher on the load balancer. Block older, insecure connections (TLS 1.0 and 1.1).	Pass
REQ-SEC-008	M	Enable DNSSEC on the domain to prevent attackers from hijacking or spoofing the website address.	Pass
Data Protection			
REQ-SEC-009	M	Sensitive configuration (DB credentials, API keys) not committed to source control; managed via CI secrets / GCP Secret Manager.	Pass
REQ-SEC-010	D	Encryption at rest where provided by cloud (e.g. managed DB, GCP default encryption).	Pass
REQ-SEC-011	M	Cloud SQL must use private connectivity and must not expose a public database endpoint.	Pass
REQ-SEC-012	M	Cloud SQL client connections must enforce encrypted connections; plaintext database clients rejected.	Pass
REQ-SEC-013	M	Production database must have automated backup and point-in-time recovery enabled.	Pass
Mobile			
REQ-SEC-014	M	Release builds signed via CI (GitHub Actions + Fastlane) before uploading to TestFlight.	Pass
REQ-SEC-015	M	Credentials stored in OS-backed secure storage on iOS (Keychain) and Android (Keystore).	Pass
REQ-SEC-016	D	freeRASP runtime integrity checks active; configured to alert without blocking.	Pass
REQ-SEC-017	M	SAST scan (mobfsfscan) run in CI on each mobile pull request.	Pass
REQ-SEC-018	M	Mobile WebView navigation restricted to first-party ChronoFlow and required Google/Firebase domains.	Pass

REQ-SEC-019	M	Mobile WebView must reject unsafe or untrusted navigation, including attacker-controlled hosts, suffix-spoofed domains, and file://, javascript:, and data: schemes.	Pass
REQ-SEC-020	M	Mobile logout must clear WebView session state, including cookies, cache, localStorage, and native secure-storage auth material.	Pass
Cloud Infrastructure & Network			
REQ-SEC-021	M	All web traffic routed through the load balancer; direct access to backend services and databases blocked.	Pass
REQ-SEC-022	M	Principle of least privilege applied to all cloud console accounts; MFA enforced for all team members.	Pass
REQ-SEC-023	M	VPC perimeter controls applied to databases and cloud storage to prevent data exfiltration.	Pass
Edge Security & WAF			
REQ-SEC-024	M	API throttling enforced per IP address.	Pass
REQ-SEC-025	D	Requests from automated scanners or tools with missing/spoofed user-agent headers blocked at the edge.	Pass
REQ-SEC-026	M	Public access to internal configuration pages, actuator endpoints, and setup data blocked; API requests to api.chronoflow.site restricted to JSON content type.	Pass
REQ-SEC-027	D	HTTP methods restricted to standard verbs (GET, POST, PUT, DELETE, PATCH); dangerous methods and known exploit paths blocked.	Pass
REQ-SEC-028	M	GCP Cloud Armor pre-configured rulesets active to block SQLi, malicious file uploads, and XSS.	Pass
REQ-SEC-029	M	Rate limiting applied globally and with stricter thresholds on the login endpoint to mitigate brute-force and spam.	Pass
REQ-SEC-030	M	Default allow rule permits legitimate traffic that passes all preceding security checks.	Pass
WebSocket Security			
REQ-SEC-031	M	WebSocket traffic must use WSS; user identity must not be supplied or trusted from the WebSocket URL.	Pass
REQ-SEC-032	M	WebSocket-adjacent HTTP endpoints enforce authenticated user ownership and reject BOLA attempts.	Pass
REQ-SEC-033	M	WebSocket connections must authenticate with an AUTH message containing a short-lived token before subscribing to any user-specific channel.	Pass
REQ-SEC-034	M	Internal WebSocket push endpoints not callable by public clients; require an internal service token.	Pass
Push Notification Security			
REQ-SEC-035	D	Browser push notification payloads encrypted before FCM transport; FCM cannot read plaintext content.	Pass
REQ-SEC-036	D	Push device registration sends only public encryption material to the backend; private keys remain client-side.	Pass
REQ-SEC-037	D	Encrypted push payloads delivered as data-only FCM messages; no plaintext notification title or body in the FCM envelope.	Pass
Zero Trust Architecture			

REQ-SEC-038	D	Backend workloads use distinct Kubernetes ServiceAccounts for specific, auditable service identity.	Pass
REQ-SEC-039	D	Internal service-to-service traffic uses Istio mTLS in STRICT mode for selected backend services.	Pass
REQ-SEC-040	D	Internal service calls restricted by Istio AuthorizationPolicy allow-lists based on service identity.	Pass
REQ-SEC-041	D	Redis and Nacos restricted by Kubernetes NetworkPolicy; arbitrary pod traffic inside the cluster rejected.	Pass

4. Threat Modelling

Method: STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) applied to each trust boundary crossing.

Assumptions:

- Cloud provider (GCP) infrastructure is trusted; physical security is out of scope.
- TLS root certificates on client devices are trusted.
- Firebase / Google identity infrastructure is trusted as an external IdP.
- Internal service-to-service communication (Dubbo/RPC) operates within the GCP VPC.

4.1 Trust boundaries and data flow diagram

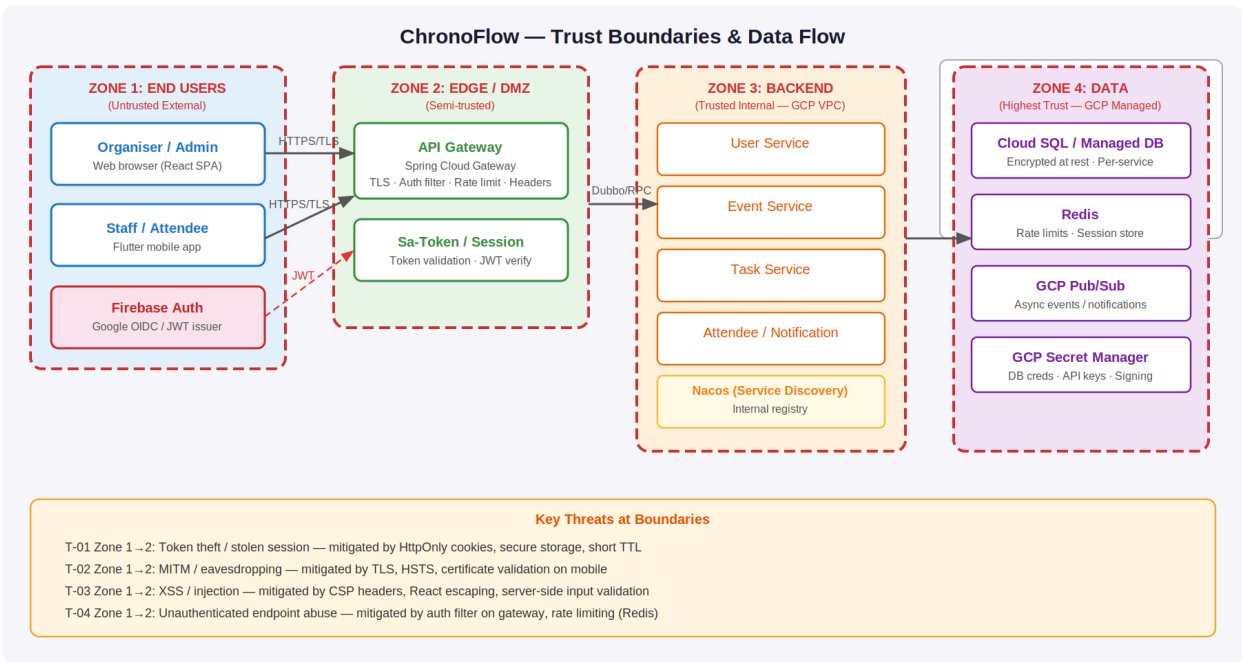


Figure 4.1.1 — Trust Boundaries and Data Flow Diagram

4.2 Trust Boundary Matrix

Boundary ID	Trust Boundary	Separates	Privilege / Trust Change	Primary Risk
TB-1	Public Client → Edge / DMZ	React Web SPA, Flutter Mobile App, browser traffic, mobile API traffic from API Gateway and WebSocket Gateway	Untrusted public clients enter the semi-trusted application edge	Brute-force login, credential stuffing, CORS abuse, MITM, CSWSH, WebSocket abuse, XSS input, unauthorised API access, public endpoint DoS

TB-2	External Identity Provider → Application Identity	Firebase Auth / external OIDC providers from User Service, Sa-Token session layer, user onboarding logic	External identity assertions become local application users, sessions, roles, and tenant context	Account-linking takeover, SSO auto-registration abuse, identity spoofing, weak onboarding control, token replay
TB-3	Edge / DMZ → Backend Services	API Gateway, WebSocket Gateway, and session validation layer from backend microservices	Semi-trusted edge services call trusted internal application services	Gateway bypass, broken authorisation propagation, missing service-to-service authentication, internal service impersonation
TB-4	Backend Services → Data / Control Plane	Backend services from Cloud SQL, Redis, MongoDB, Nacos, audit store, session store, and configuration plane	Internal services access high-value data, sessions, permissions, secrets, audit evidence, and configuration	Data exposure, Redis/session leakage, stale permissions, Nacos tampering, audit manipulation, lateral movement
TB-5	Backend Services → External Managed Services	File, notification, task, and attendee services from GCS, Pub/Sub, AWS SES, Firebase FCM, and provider APIs	Internal application data leaves direct application control and enters managed/external services	Signed URL leakage, rogue Pub/Sub messages, plaintext notification exposure, provider credential leakage, external message injection
TB-6	Mobile App → WebView / Device Runtime	Flutter Mobile App from embedded WebView, local storage, QR scanner input, mobile OS, external URL content	Trusted mobile app logic interacts with less trusted device runtime and external content	OTT replay, QR token injection, WebView navigation abuse, cookie/session leakage, repackaged mobile app abuse
TB-7	Build / Release → Runtime	Source repository, CI/CD, container registry, mobile build pipeline, deployment manifests from production runtime workloads and mobile clients	Build-time artefacts, secrets, images, and mobile packages become deployed runtime components	Secret leakage, image tampering, mutable tags, malicious mobile repackaging, supply-chain compromise

4.3 Threat Register

Threat ID	STRIDE-LM Category	Trust Boundary	Threat	Targeted Asset
T-01	Spoofing	TB-1	Brute-force login and credential stuffing; per-IP limit can be bypassed by distributed IPs or non-atomic rate-limit logic.	User accounts, login capacity
T-02	Information Disclosure	TB-1	Username enumeration through different backend error messages for missing user versus bad credentials.	Account existence data
T-03	Spoofing	TB-2	Firebase account-linking takeover through automatic email-based linking without confirmation.	User identity, active sessions
T-04	Spoofing	TB-2	SSO auto-registration allows account creation through supported providers without admin approval or business onboarding gate.	Identity namespace, tenant hygiene
T-05	Spoofing	TB-1, TB-4	Refresh token replay or race condition remains possible because rotation is not fully atomic and UA/IP can be replicated.	Refresh-token family, user session
T-06	Spoofing	TB-1, TB-4	TOTP brute-force due to absence of MFA-specific lockout and reliance on bypassable general IP rate limits.	MFA challenge, account session
T-07	Spoofing / Repudiation	TB-1, TB-4	TOTP code replay within the same time window due to missing per-code replay counter.	MFA assurance, auditability
T-08	Spoofing	TB-1	CORS downgrade through HTTP origins in production allow-list with credentials enabled.	Cookies, browser trust boundary
T-09	Information Disclosure	TB-1, TB-3	Event or task information disclosure through insufficient ownership filtering.	Event records, task records
T-10	Denial of Service	TB-1	WebSocket resource exhaustion before authentication deadline; WebSocket upgrade is reachable without prior login.	WebSocket gateway availability
T-11	Spoofing	TB-1	Cross-Site WebSocket Hijacking or malicious website WebSocket access if Origin checks and session authentication are misconfigured.	WebSocket session, notification feed
T-12	Tampering	TB-3	Gateway bypass to file service because file endpoints lack endpoint-level authentication and authorisation checks.	GCS objects, file metadata
T-13	Tampering	TB-1, TB-3, TB-5	Macro-capable Office files may pass upload validation because file validation relies on an incomplete blacklist.	User devices, file store, downstream consumers

T-14	Elevation of Privilege	TB-1, TB-3	Event or task permission checks validate action but not ownership or tenant scope.	Event data, task data
T-15	Elevation of Privilege	TB-1, TB-3	Attendee dashboard, list, update, or delete operations lack specific permission and ownership checks.	Attendee PII, check-in state
T-16	Spoofing	TB-3	No enforced mTLS or service-to-service authentication on Dubbo TRI; compromised service can impersonate internal callers.	Internal APIs, service identity
T-17	Tampering	TB-4	Nacos configuration tampering due to hardcoded/default credentials and internal network reachability.	Service configuration
T-18	Spoofing / Tampering	TB-5	Pub/Sub message spoofing if rogue publisher injects task-triggered notification messages without payload-level authentication.	Notification integrity
T-19	Information Disclosure	TB-4	Redis exposure allows sessions, MFA tokens, fingerprints, refresh metadata, audit keys, and rate-limit keys to be read if the internal network is reached.	Redis secrets, sessions
T-20	Information Disclosure	TB-4	Direct MySQL/MongoDB access from any pod due to missing workload-level network isolation.	User, role, event, attendee, notification data
T-21	Lateral Movement	TB-3, TB-4	Unrestricted pod-to-pod network permits compromised pod pivot to services, Redis, MySQL, MongoDB, and Nacos.	Cluster blast radius
T-22	Repudiation	TB-1, TB-4	Audit IP spoofing because forwarded headers are trusted without proxy validation.	Audit trail integrity
T-23	Tampering	TB-1, TB-4	Audit log injection through insufficient control-character escaping in manually constructed JSON.	Audit record integrity
T-24	Repudiation	TB-4	Audit logs retained only in Redis for short duration, reducing investigation window and evidence durability.	Forensic evidence
T-25	Information Disclosure	TB-7, TB-4, TB-5	Hardcoded or repository-leaked secrets such as DB passwords, Nacos credentials, Grafana credentials, JWT secrets, and API keys.	Credentials, dependent services
T-26	Spoofing	TB-1, TB-6	Basic mobile HTTP client lacks certificate pinning in a sensitive authentication path despite pinned clients existing elsewhere.	Firebase token, cookies, mobile session

T-27	Information Disclosure	TB-1, TB-6	Firestore API keys are exposed in client bundles; risk increases if console restrictions are weak.	Firestore project abuse surface
T-28	Spoofing	TB-1, TB-4, TB-6	OTT replay timing window due to non-atomic read-then-update token consumption.	WebView SSO session
T-29	Information Disclosure	TB-6	Cookie extraction via regex may mishandle malformed Set-Cookie headers.	Mobile token parsing correctness
T-30	Tampering	TB-6	Unrestricted WebView JavaScript can abuse injected cookies if hosted content has XSS.	Mobile WebView session
T-31	Spoofing	TB-6, TB-1	QR token injection because parser accepts token parameters from any URL.	Check-in token handling
T-32	Information Disclosure	TB-5, TB-1	GCS signed URL exposure grants file access for URL lifetime if leaked or shared.	Uploaded files
T-33	Spoofing / Information Disclosure	TB-5, TB-7	AWS SES credential exposure if notification pod or environment variables are compromised.	Email sending capability
T-34	Elevation of Privilege	TB-7, TB-3, TB-4	App pods lack restrictive pod security contexts; containers may run as root with writable filesystem and privilege escalation defaults.	Node and cluster runtime
T-35	Denial of Service	TB-1, TB-4	Non-atomic Redis rate limiter permits concurrent limit bypass and permanent-key edge cases.	Auth and notification availability
T-36	Elevation of Privilege	TB-1, TB-4	Stale Sa-Token permissions persist after role revocation because sessions are not invalidated.	Role and permission enforcement
T-37	Denial of Service	TB-5, TB-4	Notification rate limits are global, not per-user or per-tenant; one user can exhaust the shared notification budget.	Email, push, WebSocket capacity
T-38	Tampering	TB-7	Container image tags are not pinned by digest, allowing tag mutation or registry compromise to change deployed artefacts.	Runtime image integrity
T-39	Information Disclosure	TB-1	CSP allows style-src 'unsafe-inline', enabling CSS-injection data exfiltration paths where injection exists.	Browser-side data confidentiality
T-40	Spoofing	TB-1, TB-4	Stolen refresh token or JWT is reused by an attacker to continue a valid user session.	User session

T-41	Information Disclosure	TB-1	MITM attack on API traffic allows credentials, JWTs, or cookies to be eavesdropped in transit.	Data in transit
T-42	Tampering	TB-1	XSS or injection in the web UI leads to data exfiltration or session theft.	Users, application data
T-43	Denial of Service	TB-1	Unauthenticated endpoint flooding or brute-force login reduces application availability.	Public API availability
T-44	Elevation of Privilege	TB-1, TB-3	Attendee accesses organiser-only API operations by manipulating client-side requests.	Event data, organiser operations
T-46	Tampering	TB-6, TB-7	Repackaged or tampered mobile apps are distributed outside official stores.	End users, brand trust
T-47	Tampering	TB-1, TB-3, TB-5	File service accepts manipulated event assets, such as SVGs containing XSS that can execute in a victim browser.	Users, uploaded data
T-48	Spoofing	TB-1, TB-3	Attacker opens a WebSocket connection using another user's identifier in the URL to impersonate that user.	WebSocket session, notification feed
T-50	Information Disclosure	TB-5	Push providers can read plaintext notification title/body if sensitive content is sent directly through FCM.	Notification content
T-51	Tampering	TB-6	Mobile WebView navigates to attacker-controlled pages or dangerous javascript: / data: URLs that alter the displayed experience.	Mobile WebView session, user trust
T-52	Information Disclosure	TB-6	Mobile WebView loads untrusted file:// or attacker-controlled URLs that may expose local or session-adjacent data.	Mobile WebView session, local data
T-53	Information Disclosure	TB-4	Database endpoint exposure or plaintext database client connections leak sensitive application data.	Application data, database records
T-54	Elevation of Privilege / Lateral Movement	TB-3, TB-4	Compromised internal workload calls other backend services or internal infrastructure because it is already inside the cluster.	Internal services, infrastructure components

4.4 Risk Assessment

Rank	Threat ID	Threat	DI	R	E	A	D	Risk Score
1	T-08	CORS downgrade through HTTP origins in production allow-list with credentials enabled.	3	3	2	3	3	48

2	T-25	Hardcoded or repository-leaked secrets such as DB passwords, Nacos/Grafana credentials, JWT secrets, and API keys.	3	3	2	3	3	48
3	T-42	XSS or injection in the web UI leads to data exfiltration or session theft.	3	3	2	3	3	48
4	T-10	WebSocket resource exhaustion before authentication deadline; WebSocket upgrade is reachable without prior login.	3	3	3	3	2	45
5	T-43	Unauthenticated endpoint flooding or brute-force login reduces application availability.	3	3	3	3	2	45
6	T-54	Compromised internal workload calls other backend services or internal infrastructure because it is already inside the cluster.	2	3	2	3	3	42
7	T-37	Notification rate limits are global, not per-user/tenant; one user can exhaust the budget for all users.	2	3	3	3	2	40
8	T-44	Attendee accesses organiser-only API operations by manipulating client-side requests.	3	3	2	2	3	40
9	T-47	File service accepts manipulated event assets, such as SVGs containing XSS that can run in a victim's browser.	3	3	2	2	3	40
10	T-48	Attacker opens a WebSocket connection using another user's identifier in the URL to impersonate that user.	3	3	2	2	3	40
11	T-50	Push providers can read plaintext notification title/body if sensitive content is sent directly through FCM.	3	3	2	3	2	40
12	T-04	SSO auto-registration allows account creation through supported providers without admin approval or business onboarding gate.	3	3	3	2	2	36
13	T-16	No mTLS or service-to-service authentication on Dubbo TRI; compromised service can impersonate internal callers.	2	2	2	3	3	36
14	T-17	Nacos configuration tampering due to hardcoded/default credentials and network reachability.	2	2	2	3	3	36
15	T-19	Redis exposure: sessions, MFA tokens, fingerprints, refresh metadata, audit/rate-limit keys readable if internal network is reached.	2	2	2	3	3	36
16	T-20	Direct MySQL/MongoDB access from any pod due to missing NetworkPolicy isolation.	2	2	2	3	3	36
17	T-21	Unrestricted pod-to-pod network permits compromised pod pivot to services, Redis, MySQL, MongoDB, and Nacos.	2	2	2	3	3	36
18	T-22	Audit IP spoofing because forwarded headers are trusted without proxy validation.	3	3	3	2	2	36
19	T-34	App pods lack restrictive pod security contexts; containers may run as root with writable filesystem and privilege escalation defaults.	2	2	2	3	3	36
20	T-53	Database endpoint exposure or plaintext database client connections leak sensitive application data.	2	2	2	3	3	36

21	T-06	TOTP brute-force due to absence of MFA-specific lockout and reliance on bypassable general IP rate limits.	3	2	2	2	3	35
22	T-35	Non-atomic Redis rate limiter permits concurrent limit bypass and permanent-key edge cases.	2	2	3	3	2	35
23	T-01	Brute-force login and credential stuffing; per-IP limit can be bypassed by distributed IPs or non-atomic increment/expire race.	3	3	2	2	2	32
24	T-51	Mobile WebView navigates to attacker-controlled pages or dangerous javascript: / data: URLs.	3	3	2	2	2	32
25	T-03	Firebase account linking takeover through automatic email-based linking without confirmation.	2	2	2	2	3	30
26	T-05	Refresh token replay/race remains possible because rotation is not fully atomic and UA/IP can be replicated.	2	2	2	2	3	30
27	T-09	Event/task information disclosure through insufficient ownership filtering.	2	2	2	2	3	30
28	T-12	Gateway bypass to file service because file endpoints lack endpoint-level authentication.	2	2	2	2	3	30
29	T-14	Event/task permission checks validate action but not ownership or tenant scope.	2	2	2	2	3	30
30	T-15	Attendee dashboard/list/update/delete lack specific permission annotations and ownership checks.	2	2	2	2	3	30
31	T-26	Basic mobile HTTP client lacks certificate pinning in a sensitive auth path.	2	2	2	2	3	30
32	T-36	Stale Sa-Token permissions persist after role revocation because sessions are not invalidated.	2	2	2	2	3	30
33	T-38	Container image tags are not pinned by digest, allowing tag mutation or registry compromise.	2	2	2	3	2	30
34	T-40	Stolen refresh token or JWT is reused by an attacker to continue a valid user session.	2	2	2	2	3	30
35	T-02	Username enumeration through different backend error codes for missing user versus bad credentials.	3	3	3	2	1	27
36	T-27	Firebase API keys are exposed in client bundles; risk increases if console restrictions are weak.	3	3	3	2	1	27
37	T-31	QR token injection because the parser accepts token parameters from any URL.	3	3	3	2	1	27
38	T-41	MITM attack on API traffic allows credentials, JWTs, or cookies to be eavesdropped in transit.	2	2	1	2	3	25
39	T-52	Mobile WebView loads untrusted file:// or attacker-controlled URLs that may expose local or session-adjacent data.	2	2	1	2	3	25

40	T-07	TOTP code replay within the same time window due to missing per-code replay counter.	2	2	2	2	2	24
41	T-11	Cross-Site WebSocket Hijacking or malicious website WebSocket access if Origin and session authentication are misconfigured.	2	2	2	2	2	24
42	T-13	Macro-capable Office files may pass upload validation because extension blocklist is incomplete.	2	2	2	2	2	24
43	T-18	Pub/Sub message spoofing if rogue publisher injects task-triggered notification messages without payload-level authentication.	2	2	2	2	2	24
44	T-23	Audit log injection through insufficient control-character escaping in manually constructed JSON.	2	2	2	2	2	24
45	T-24	Audit logs retained only in Redis for short duration, reducing investigation window and evidence durability.	2	2	2	2	2	24
46	T-28	OTT replay timing window due to non-atomic read-then-update consumption.	2	2	2	2	2	24
47	T-32	GCS signed URL exposure grants file access for URL lifetime if leaked/shared.	2	2	2	2	2	24
48	T-46	Repackaged or tampered mobile apps are distributed outside official stores.	1	3	3	2	1	21
49	T-30	Unrestricted WebView JavaScript can abuse injected cookies if hosted content has XSS.	3	1	1	2	2	20
50	T-33	AWS SES credential exposure if notification pod or environment variables are compromised.	2	1	1	2	2	16
51	T-39	CSP allows style-src 'unsafe-inline', enabling CSS-injection data exfiltration paths where injection exists.	2	1	1	2	2	16
52	T-29	Cookie extraction via regex may mishandle malformed Set-Cookie headers.	2	1	1	2	1	12

4.5 Prioritised threat register:

Threat ID	STRIDE Cat.	Threat	Asset	Controls (summary)	Risk Score
T-42	Tampering	XSS or injection in web UI leading to data exfiltration or session theft	Users, data	CSP from gateway; React automatic escaping; server-side input validation on API	48
T-25	Information Disclosure	Secrets such as DB passwords and API keys leaked via source repository	Data stores, third-party services	No secrets in repo; pre-commit hooks; GitHub secret scanning; GCP Secret Manager	48

T-43	DoS	Unauthenticated endpoint flooding / brute-force login	Availability	Rate limiting at gateway using Redis; auth filter on protected routes; Firebase login throttling	45
T-54	Elevation of Privilege / Lateral Movement	Compromised internal workload attempts to call other backend services or internal infrastructure because it is already inside the cluster	Internal application services and infrastructure components	App workloads use distinct Kubernetes ServiceAccounts; Istio mTLS identifies service callers; AuthorizationPolicy restricts service-to-service calls; Kubernetes NetworkPolicy restricts access to Redis and Nacos	42
T-44	Elevation of Privilege	Attendee accessing organiser-only API operations by manipulating requests	Event data, operations	Server-side RBAC enforced by Sa-Token; role validated per request at microservice level	40
T-47	Tampering	File service handles uploaded event assets that may disguise malicious content, such as SVGs containing XSS	Users, data	Check magic number / file signature; validate real file type regardless of extension or client-declared MIME type	40
T-48	Spoofing	Attacker opens a WebSocket connection using another user's identifier in the URL to impersonate that user	WebSocket session, notification feed	WebSocket URL identity is not trusted; backend mints short-lived WS JWT through authenticated HTTPS; first WebSocket message must be AUTH; user identity is derived from validated token subject	40
T-50	Information Disclosure	Push provider can read plaintext notification title/body if sensitive content is sent directly through FCM	Notification content	Browser registers public encryption key; backend sends encrypted data-only FCM envelope; service worker decrypts locally before display	40
T-53	Information Disclosure	Database endpoint exposure or plaintext database client connections leak sensitive application data	Application data and database records	Cloud SQL uses private connectivity; public access disabled; encrypted client connections; automated backups; point-in-time recovery	36
T-51	Tampering	Mobile WebView navigates to attacker-controlled pages or dangerous javascript: / data: URLs that can alter the displayed experience	Mobile WebView session, user trust	WebView domain allow-list restricts navigation to ChronoFlow and required Google/Firebase domains; unsafe schemes and suffix-spoofed hosts are blocked	32
T-40	Spoofing	Stolen refresh token / JWT reused by attacker	User session	HttpOnly cookies; flutter_secure_storage; server-side token validation; short TTL	30

T-41	Information Disclosure	MITM attack on API traffic; eavesdropping on credentials	Data in transit	TLS enforced; HSTS for browsers; HTTPS-only base URL on mobile; no HTTP fallback	25
T-52	Information Disclosure	Mobile WebView loads untrusted file:// or attacker-controlled URLs that may expose local or session-adjacent data	Mobile WebView session, user data	WebView policy blocks file:// and untrusted hosts; logout clears WebView cookies, cache, localStorage, and native secure-storage auth material	25
T-11	Spoofing	Malicious website attempts cross-site WebSocket access by relying on browser cookies or trusted session state	WebSocket session, user notifications	Production WebSocket uses WSS, trusted Origin, and explicit AUTH-first WS JWT; cookies alone are not sufficient to subscribe to a user channel	24
T-46	Tampering	Repackaged / tampered mobile app distributed outside official stores	End users, brand trust	CI-signed release builds using Fastlane; freeRASP integrity check at runtime	21

5. Security Architecture and Controls

The security architecture centres on a single, hardened entry point (the API Gateway) with defence-in-depth controls at each layer. The key design decisions are:

- Single entry via API Gateway with central authentication and authorisation filter — no microservice is directly reachable from the internet.
- Firebase for identity; backend validates every JWT before issuing an internal session — no implicit trust of client-supplied user identity.
- Mobile tokens stored in Keychain/Keystore via flutter_secure_storage — no plaintext storage.
- All secrets managed via GCP Secret Manager or GitHub Secrets — never committed to source control.

5.3 Controls Mapping

ID	Layer	Control	Description	Implementation Reference
C-01	Transport	TLS 1.2+	All client-to-gateway traffic encrypted in transit	HTTPS endpoints; gateway TLS config
C-02	Transport	HSTS	HTTP Strict-Transport-Security forces HTTPS in browsers	SecurityHeadersFilter (gateway)
C-03	Edge	Rate Limiting	Limits requests per IP / user to prevent brute force and DoS	Redis / gateway rate limit config + GCP Cloud Armor Policies
C-04	Edge	Security Headers	CSP, X-Frame-Options, X-Content-Type-Options on all responses	SecurityHeadersFilter (gateway)
C-05	Edge	Auth Filter	Gateway rejects unauthenticated requests before forwarding	GlobalFilter / RouteLocator
C-06	Edge	Metrics & Logs Monitoring	Security-relevant events (auth failures, 401s, access patterns) logged and monitored for anomalies	GCP Cloud Logging + GCP Cloud Monitoring
C-07	Edge	File Magic Number Validation	Validates true file type by inspecting file header bytes on upload; rejects files where magic number does not match declared type	File service — server-side upload handler
C-08	AuthN/Z	Token Validation	Firebase JWT verified on each request; invalid tokens rejected	Firebase Admin SDK / Sa-Token StpUtil
C-09	AuthN/Z	RBAC	Role-based access control enforced server-side per endpoint	Sa-Token annotations; per-service checks
C-10	Data	Encryption at Rest	GCP managed encryption for databases and storage	GCP default encryption (AES-256)
C-11	Data	Database Backup and Recovery	Cloud SQL automated backups and point-in-time recovery support data availability and recovery after accidental deletion, corruption, or operational failure.	GCP Cloud SQL backup/PITR settings
C-12	Data	Private Database Connectivity	Cloud SQL uses private connectivity and encrypted client	GCP Cloud SQL connection/security settings

			connections to reduce database exposure	
C-13	Mobile	Secure Storage	Tokens stored in OS-backed secure enclave (Keychain/Keystore)	flutter_secure_storage
C-14	Mobile	CI Release Signing	APK/IPA signed via Fastlane in CI; keys stored in GitHub Secrets	GitHub Actions + Fastlane
C-15	Mobile	freeRASP	Provides runtime in-app protection for mobile applications by detecting and responding to threats such as rooted/jailbroken devices, tampering, reverse engineering, and malicious hooks	Mobile UI
C-16	Build	CI checks	Static analysis of source code to detect injection flaws, hardcoded secrets, weak cryptography, insecure deserialization, and memory safety issues before deployment. SCAs scans third-party and open source dependencies for known CVEs and outdated libraries. Mobile specific: MobSF to detect hardcoded secrets, insecure data storage, weak cryptography, overly broad permissions, exposed app components, and cleartext network configurations in APK/ IPA	CI workflow artifacts
C-17	Mobile	Code Obfuscation	Code obfuscation of compiled binary to prevent reverse engineering	GitHub Actions + Fastlane
C-18	Secrets	No Secrets in Repo	Environment variables and CI/cloud secrets; GitHub secret scanning enabled	GCP Secret Manager + External Secret Operator + GitHub Secrets
C-19	WebSocket	WSS + AUTH-first WebSocket	Browser connects using <code>wss://</code> ; backend requires the first message <code>{type:"AUTH", token}</code> and derives user identity from validated WS JWT.	WS Gateway / frontend WS client
C-20	Push	Provider-blind web push encryption	Browser registers public key; backend encrypts push display payload before sending FCM data-only message.	Notification service + frontend service worker
C-21	Mobile WebView	WebView navigation allow-list	Flutter WebView allows only ChronoFlow and required Google/Firebase domains; blocks untrusted and dangerous schemes.	Chronoflow-mobile WebView security helper

C-22	Mobile WebView	WebView logout/session cleanup	Logout clears auth state, secure storage, WebView cookies/cache/localStorage.	Mobile auth service
C-23	Zero Trust	Service identities and Istio mTLS	App services use distinct Kubernetes ServiceAccounts and Istio mTLS in STRICT mode.	GKE / Istio
C-24	Zero Trust	Istio AuthorizationP olicy	Selected services allow only required caller identities by ServiceAccount principal.	Istio AuthorizationPolicy
C-25	Zero Trust	Redis/Nacos NetworkPolicy	Redis and Nacos accept ingress only from approved app pods and required ports.	Kubernetes NetworkPolicy
C-26	Transport	DNS Cryptographic Domain Signing	The system enforces cryptographic origin authentication and data integrity for domain resolution by fully signing the authoritative DNS zone to mitigate tampering.	Cloud DNS
C-27	Edge	SQL Injection Mitigation	The system protects web applications from SQL injection attacks by analyzing incoming HTTP request payloads and blocking malicious database queries at the network edge.	Cloud Armor policy
C-28	Edge	Cross-Site Scripting (XSS) Prevention	The system protects web applications from XSS attacks by filtering and blocking malicious scripts embedded in incoming user inputs before they reach the backend services.	Cloud Armor policy
C-29	Edge	Path Traversal Protection	The system prevents unauthorized access to the underlying server file system by blocking HTTP requests containing malicious directory traversal sequences.	Cloud Armor policy
C-30	Edge	Path Traversal Protection	The system prevents unauthorized access to the underlying server file system by blocking HTTP requests containing malicious directory traversal sequences.	Cloud Armor policy

C-31	Edge	Remote Code Execution Mitigation	The system blocks exploit attempts targeting the Spring4Shell vulnerability (CVE-2022-22965) by filtering out malicious payload variations in HTTP request headers, URLs, and bodies at the edge layer.	Cloud Armor policy
C-32	Edge	Application Actuator Endpoint Protection	The system prevents the unauthorized exposure of Spring Boot Actuator environment endpoints (<code>/actuator/env</code>) to stop attackers from harvesting sensitive configuration data or environment variables.	Cloud Armor policy
C-33	Edge	Configuration File Access Restriction	The system blocks external requests aiming to download sensitive configuration files (such as <code>.env</code> , <code>config.json</code> , or <code>application.properties</code>) from the application's directory structure.	Cloud Armor policy
C-34	Edge	Sensitive System File Protection	The system prevents information disclosure by blocking requests for known sensitive development, backup, or runtime files (such as <code>.git</code> directories, core dumps, or application log files).	Cloud Armor policy
C-35	Edge	Java Deserialization Exploit Mitigation	The system blocks Remote Code Execution (RCE) attempts that pass serialized Java object payloads inside HTTP request streams or parameters to exploit vulnerable application components.	Cloud Armor policy
C-36	Edge	JNDI Injection Mitigation	The system mitigates Log4Shell (CVE-2021-44228) risks by filtering out inbound string patterns that match JNDI lookups (such as <code>\${jndi:ldap://}</code>) across headers, user-agents, and input payloads.	Cloud Armor policy
C-37	Edge	Shell Command Injection Mitigation	The system blocks arbitrary OS command injection patterns—such as shell metacharacters, pipes, and execution chains (e.g., <code> ; cat /etc, && id, mknod</code>)—used to	Cloud Armor policy

			execute unauthorized commands directly on the host system.	
C-38	Infrastructure	Cloud Log Aggregation and Streaming	The system exports cloud infrastructure and application security logs into a centralized messaging topic, allowing down-stream security tools to subscribe and ingest events asynchronously for security monitoring.	Wazuh, Pub/Sub
C-39	Auth	TOTP MFA	After successful password verification, if the user has TOTP enabled, login pauses and the user must present a 6-digit time-based code from their authenticator app. Secret is generated server-side (32-byte), provisioned via QR code (otpauth://), and stored per-user.	TotpService
C-40	Auth	Password Policy Enforcement	Strong-password validator enforced at every password sink (registration, password reset, profile update): length 12–128, must contain upper + lower + digit + symbol, rejects common-breach list, rejects passwords equal to or containing username / email local-part	PasswordPolicy
C-41	Auth	Self-Service Password Reset	Email-delivered, single-use, time-limited reset token (30 min TTL). Generic response prevents account enumeration ("If an account exists...").	PasswordReset

6. Verification of Security Controls

Verification uses a combination of automated checks in CI, SAST/dependency scanning, manual checklist review, and targeted API testing. Evidence (CI run links, screenshots, log excerpts) should be attached as appendices in the final submission.

ID	Control Ref	Control / Test	Method	Result	Evidence / Notes
V-01	C-01	HTTPS-only to production API (no HTTP fallback)	Curl request	Pass	Figure 6.1.1
V-02	C-02	Gateway returns security headers on API responses, specifically: • Strict-Transport-Security — Forces HTTPS for 1 year (<code>max-age=31536000</code>), including subdomains. Prevents downgrade attacks. • X-Frame-Options: DENY — Blocks the page from being embedded in iframes. Prevents clickjacking. • X-XSS-Protection: 1; mode=block — Tells older browsers to block detected XSS attacks. • X-Content-Type-Options: nosniff — Prevents browsers from MIME-sniffing responses. Stops certain content injection attacks.	browser DevTools	Pass	Figure 6.2.1
V-03	C-05	Unauthenticated API returns 401 (not 403 or 200)	API test (Postman / curl)	Pass	Figure 6.3.1
V-04	C-08	Role-based access: attendee cannot access organiser endpoints	API test with two accounts	Pass	Figure 6.3.1
V-05	C-16	PR pipeline: linting, SAST and SCA quality gates pass before merge for chronoflow frontend and backend.	CI log review	Pass	Figure 6.5.1
V-06	C-16	mobsfscan on mobile repo — no high-severity findings	CI artifact / SARIF	Pass	Figure 6.6.1
V-07	C-07, C-13	Logout clears client-side session tokens	Logging + Manual test	Pass	Figure 6.7.1
V-08	C-13	flutter_secure_storage used (no SharedPreferences for tokens)	Introspection of keychain DB dump	Pass	Figure 6.8.1

V-09	C-18	No secrets committed to repository (GitHub secret scanning)	GitHub Security tab	Pass	Figure 6.9.1, Figure 6.9.2, Figure 6.9.3
V-10	C-04	CSP header present on gateway responses	curl / browser DevTools	Pass	Figure 6.2.1
V-11	C-03	API throttling/ rate limiting triggers on excessive API requests	Load testing	Pass	Figure 6.11.1, Figure 6.11.2
V-12	C-13	Mobile release build signed by CI (not dev key)	Github CD logs	Pass	Figure 6.12.1, Figure 6.12.2
V-13	C-17	Code obfuscation of mobile app binary	Github CD logs	Pass	Figure 6.13.1
V-14	C-06	Security-relevant events appear in GCP Cloud Logging (auth failures, 401s)	GCP Cloud Logging console	Pass	Figure 6.14.1
V-15	C-07	Magic number validation for file uploads to detect malicious content disguised as legitimate files	Enhance file validator to check for magic number	Pass	Figure 6.15.1 (See appendix)
V-16	C-19	WebSocket uses WSS and browser Origin. The WebSocket URL does not carry user identity or credentials.	Browser DevTools	Pass	Figure 6.16.1(See appendix)
V-17	C-19	WebSocket requires an AUTH-first message with a short-lived WS JWT before normal traffic.	Browser DevTools	Pass	Figure 6.16.2(See appendix)
V-18	C-19	WS JWT is minted over authenticated HTTPS before WebSocket authentication.	Browser DevTools	Pass	Figure 6.16.3, Figure 6.16.4(See appendix)
V-19	C-20	Push device registration contains public encryption material and no private key.	Browser DevTools	Pass	Figure 6.17.1(See appendix)
V-20	C-20	FCM outbound payload contains an encrypted data envelope, not plaintext notification title/body and browser displays Decrypted Push Notification.	Cloud Logging	Pass	Figure 6.17.2, Figure 6.17.3, Figure 6.17.4(See appendix)
V-21	C-21	WebView only allows trusted hosts and blocks navigation to an untrusted host.	Android/iOS simulator	Pass	Figure 6.18.1, Figure 6.18.2, Figure 6.18.3

					(See appendix)
V-22	C-12	Cloud SQL uses private connectivity with public access disabled.	GCP Console	Pass	Figure 6.19.1(See appendix)
V-23	C-11	Cloud SQL backup and point-in-time recovery are enabled.	GCP Console	Pass	Figure 6.19.2 (See appendix)
V-24	C-12	Cloud SQL enforces encrypted client connections.	GCP Console	Pass	Figure 6.19.3 (See appendix)
V-25	C-23	Application pods use distinct Kubernetes ServiceAccounts.	GCP Console / Kubernetes evidence	Pass	Figure 6.20.1, Figure 6.20.2 (See appendix)
V-26	C-23	Istio sidecar injection and STRICT mTLS are active for backend services.	GCP Console / Kubernetes evidence	Pass	Figure 6.20.3, Figure 6.20.4 (See appendix)
V-27	C-24	Istio AuthorizationPolicies allow only required service identities.	GCP Console Object Browser	Pass	Figure 6.20.5 , Figure 6.20.6, Figure 6.20.7(See appendix)
V-28	C-24	Unauthorized internal service-to-service call is rejected.	Kubernetes runtime test	Pass	Figure 6.20.8 (See appendix)
V-29	C-25	Redis and Nacos ingress are restricted by Kubernetes NetworkPolicy.	GCP Console Object Browser	Pass	Figure 6.20.9 (See appendix)
V-30	C-15	freeRASP detects client-side security risks without enforcing compliance.	Android/iOS simulator	Pass	Figure 6.21.1

V-31	C-01	Edge Perimeter TLS Enforcement.	CDN77	Pass	Figure 6.22.1, Figure 6.22.2
V-32	C-26	DNS Cryptographic Domain Signing	PowerDMARC DNSSEC Checker	Pass	Figure 6.23.1
V-33	C-27	SQL Injection Mitigation	API Test (Bruno)	Pass	Figure 6.24.1, Figure 6.24.2, Figure 6.24.3, Figure 6.24.4, Figure 6.24.5
V-34	C-28	Cross-Site Scripting (XSS) Prevention	API Test (Bruno)	Pass	Figure 6.25.1, Figure 6.25.2, Figure 6.25.3, Figure 6.25.4
V-35	C-29	Path Traversal Protection	API Test (Bruno)	Pass	Figure 6.26.1, Figure 6.26.2
V-36	C-30	Path Traversal Protection	API Test (Bruno)	Pass	Figure 6.27.1, Figure 6.27.2, Figure 6.27.3, Figure 6.27.4
V-37	C-31	Remote Code Execution Mitigation	API Test (Bruno)	Pass	Figure 6.28.1, Figure 6.28.2, Figure 6.28.3
V-38	C-32	Application Actuator Endpoint Protection	API Test (Bruno)	Pass	Figure 6.29.1, Figure 6.29.2, Figure 6.29.3, Figure 6.29.4
V-39	C-33	Configuration File Access Restriction	API Test (Bruno)	Pass	Figure 6.30.1, Figure 6.30.2, Figure 6.30.3
V-40	C-34	Sensitive System File Protection	API Test (Bruno)	Pass	Figure 6.31.1, Figure 6.31.2

V-41	C-35	Java Deserialization Exploit Mitigation	API Test (Bruno)	Pass	Figure 6.32.1, Figure 6.32.2
V-42	C-36	JNDI Injection Mitigation	API Test (Bruno)	Pass	Figure 6.33.1, Figure 6.33.2, Figure 6.33.3
V-43	C-37	Shell Command Injection Mitigation	API Test (Bruno)	Pass	Figure 6.34.1, Figure 6.34.2
V-44	C-38	SIEM Log Pipeline	kubectrl port-forward	Pass	Figure 6.35.1
V-45	C-39	TOTP verify rejects wrong/expired code	UI/ API	Pass	Figure 6.36.1
V-46	C-40	Password policy rejects: <12 chars, missing class, breached password, password equal to or containing username/email local-part (≥5 chars). Enforced at register-member, register-organizer, password-reset, profile-update	UI/API	Pass	Figure 6.36.2
V-47	C-41	Reset token is single-use (second consume → already-consumed warning); expires after 30 min; generic response on unknown email (no enumeration); reset audit logged	UI/API	Pass	Figure 6.36.3

Issues found:

Issue ID	Description	Severity	Corrective Action	Status
I-01	Google Cloud MemoryStore (Redis-compatible) is not compatible with some libraries.	Medium	Self-host redis at kubernetes will introduce problems at scale.	Closed

7. Other Things to be Highlighted

Known Limitations

- Web push encryption hides notification content from FCM, but not from the ChronoFlow backend because the backend creates and encrypts the notification.
- Redis is restricted using Kubernetes NetworkPolicy, but Redis protocol TLS is not implemented.
- Cloud SQL and GCS use managed encryption at rest, but application-level Cloud KMS column encryption for selected PII fields is not implemented.
- JavaScript remains enabled inside the mobile WebView because the embedded React SPA requires it. This is mitigated by WebView domain allow-listing, CSP, React escaping, and no exposed native JavaScript bridge.
- The application detects client-side security risks, such as the integrity compromises and insecure device states but issues a warning notification rather than enforcing a hard lockout to maintain user convenience for non-critical application functions.

Future Work

- Google Play Integrity API / Apple DeviceCheck for stronger mobile device attestation.
- Hardware Security Module (HSM) or GCP Cloud KMS for key management at scale.
- Add Redis TLS/in-transit encryption if replacing or reconfiguring Redis infrastructure.
- Add mobile public-key pinning or certificate pinning where feasible, with backup pins and a tested certificate-rotation plan.
- Add Cloud KMS envelope encryption for selected Restricted fields such as invitation secrets, phone numbers, or high-risk audit details.

Privacy and Ethical Notes

- Data minimisation: attendee registration collects only name and email; no unnecessary PII retained.
- Audit log: security-relevant events (login, logout, role changes) logged with user ID and timestamp.
- Device identifiers, FCM tokens, token hashes, and push public keys are treated as user/device metadata. They should not be exposed in public screenshots or logs unless clearly needed for assessment evidence.
- Authentication and session material is treated as Restricted data. It is stored in server-side session stores, HttpOnly cookies, Secret Manager, Kubernetes secrets, or platform secure storage rather than plaintext local app storage.

Team Reflections / Lessons Learned

- The primary engineering takeaway is that security is structurally cheaper, cleaner, and more efficient when designed at the baseline of each sprint rather than retrofitted onto deployed features. While proactive security implementations require a visible upfront investment in engineering hours, a production security breach is exponentially more expensive in capital, operational recovery, and brand devastation.
- Earlier security planning for TLS, RBAC, WebView allow-listing, push encryption, Cloud SQL private access, and service-to-service mTLS would reduce late migration, late mitigation, and repeated regression testing.
- Threat modelling should be a recurring sprint practice, not a one-time documentation task near submission. For each new user story, the team should identify the trust boundary, the STRIDE risk, the required control, the negative test, and the evidence that will prove the control. This is closer to the DSMA and SSDLA approach of embedding security into design, implementation, testing, and release activities.
- Securing only the infrastructure layer is not enough. Cloud Armor, TLS, DNSSEC, private networking, and Kubernetes controls protect important boundaries, but they cannot by themselves prove object ownership or business authorization. Application-layer controls are still required for BOLA prevention, RBAC, WebSocket AUTH-first identity handling, safe WebView navigation, file content validation, and provider-blind push payload encryption.
- The project became more robust when controls were layered across the full stack. Edge controls reduced public attack traffic, backend authentication and authorization protected business operations, data controls protected Cloud SQL and recovery, mobile controls protected local tokens and app integrity, and Zero Trust controls reduced internal lateral movement.
- Evidence planning should happen together with implementation. Browser DevTools, GCP Console, Cloud Logging, CI logs, mobile simulators, and Kubernetes runtime tests were easier to capture when the team already knew what each control needed to prove. This avoided weak code-only screenshots and produced evidence that matched the verification table.
- The team also learned the value of honest residual-risk handling. Some controls, such as Redis protocol TLS, native mobile push encryption, Cloud KMS field-level encryption, complete SIEM operations, and external penetration testing, need more design and regression testing before being claimed as complete.

8. Appendix

Figure 6.1.1 Http calls to chronoflow.site results in 301 redirection response to https://chronoflow.site

```
((base) shchow@Shirleys-Air ~ % curl -sv http://chronoflow.site
* Host chronoflow.site:80 was resolved.
* IPv6: (none)
* IPv4: 199.36.158.100
* Trying 199.36.158.100:80...
* Established connection to chronoflow.site (199.36.158.100 port 80) from 192.168.1.247 port 52838
* using HTTP/1.x
> GET / HTTP/1.1
> Host: chronoflow.site
> User-Agent: curl/8.16.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 301 Moved Permanently
< Connection: close
< Content-Length: 0
< Server: Varnish
< Retry-After: 0
< Location: https://chronoflow.site/
< Accept-Ranges: bytes
< Date: Sun, 24 May 2026 01:41:02 GMT
< X-Served-By: cache-qpg1274-QPG
< X-Cache: HIT
< X-Cache-Hits: 0
< X-Timer: S1779586863.518102,VS0,VE0
< alt-svc: h3=":443";ma=86400,h3-29=":443";ma=86400,h3-27=":443";ma=86400
<
* shutting down connection #0
```

Figure 6.2.1 Screenshot of security headers in http response

Name	Headers	Preview	Response	Initiator	Timing	Cookies
refresh	Access-Control-Max-Age		3000			
feed?userId=2058066642494775298&li...	Content-Security-Policy		default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https;; font-src 'self' https://fonts.gstatic.com; connect-src 'self' https://*.googleapis.com https://*.firebaseapp.com https://identitytoolkit.googleapis.com https://securetoken.googleapis.com; frame-src https://*.firebaseapp.com https://accounts.google.com; base-uri 'self'; form-action 'self'			
2058066642494775298						
users						
roles						
roles						
2058066642494775298						
2058066642494775298	Content-Type		application/json			
refresh	Date		Sat, 23 May 2026 06:26:19 GMT			
2058066642494775298	Permissions-Policy		camera=(), microphone=(), geolocation=(), payment=()			
	Referrer-Policy		strict-origin-when-cross-origin			
	Strict-Transport-Security		max-age=31536000; includeSubDomains; preload			
	Transfer-Encoding		chunked			
	Vary		Origin			
	Vary		Access-Control-Request-Method			
	Vary		Access-Control-Request-Headers			
	X-Content-Type-Options		nosniff			
	X-Frame-Options		DENY			
	X-Xss-Protection		1; mode=block			

Figure 6.3.1 Unauthenticated API returns 401 (not 403 or 200)

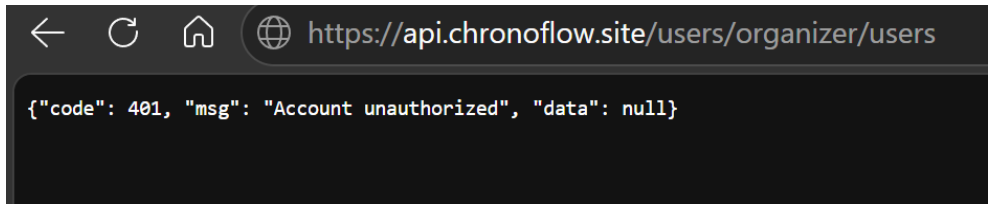


Figure 6.5.1 CI checks for chronoflow backend

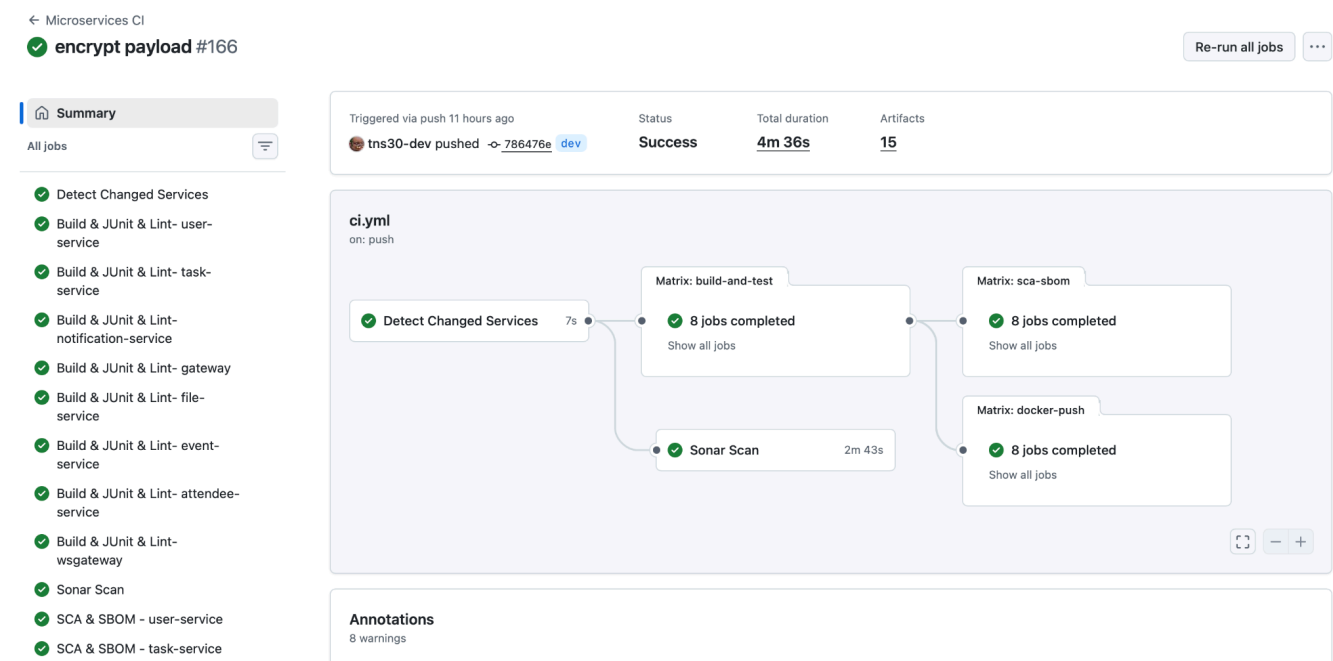


Figure 6.5.1 CI checks for chronoflow frontend

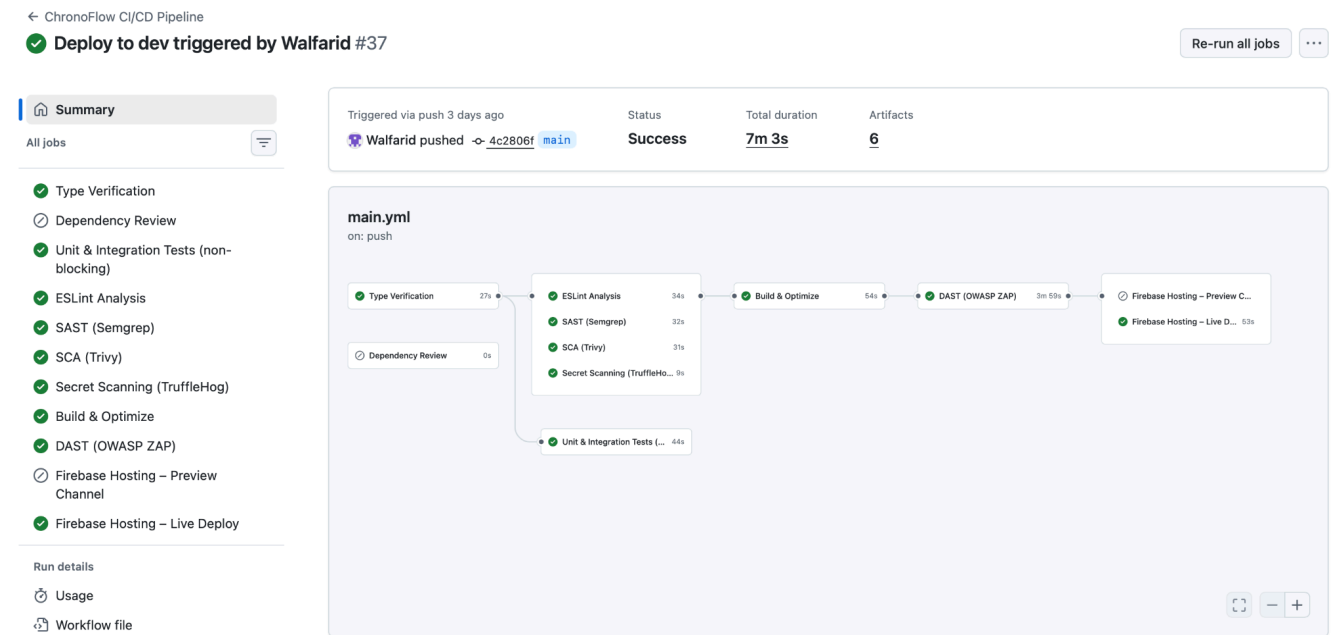




Figure 6.9.1 Results of secret scan configured on chronoflow mobile git repository

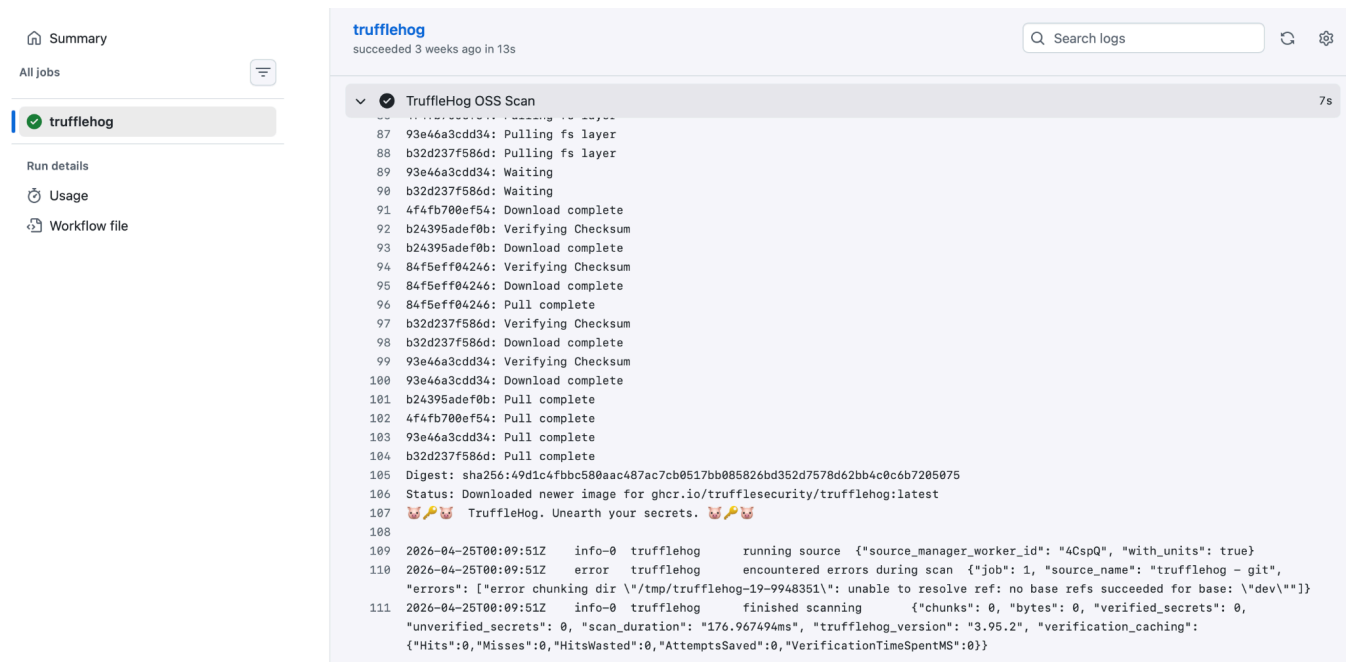


Figure 6.9.2 - Hardware Backed encryption Storing Sensitive Information

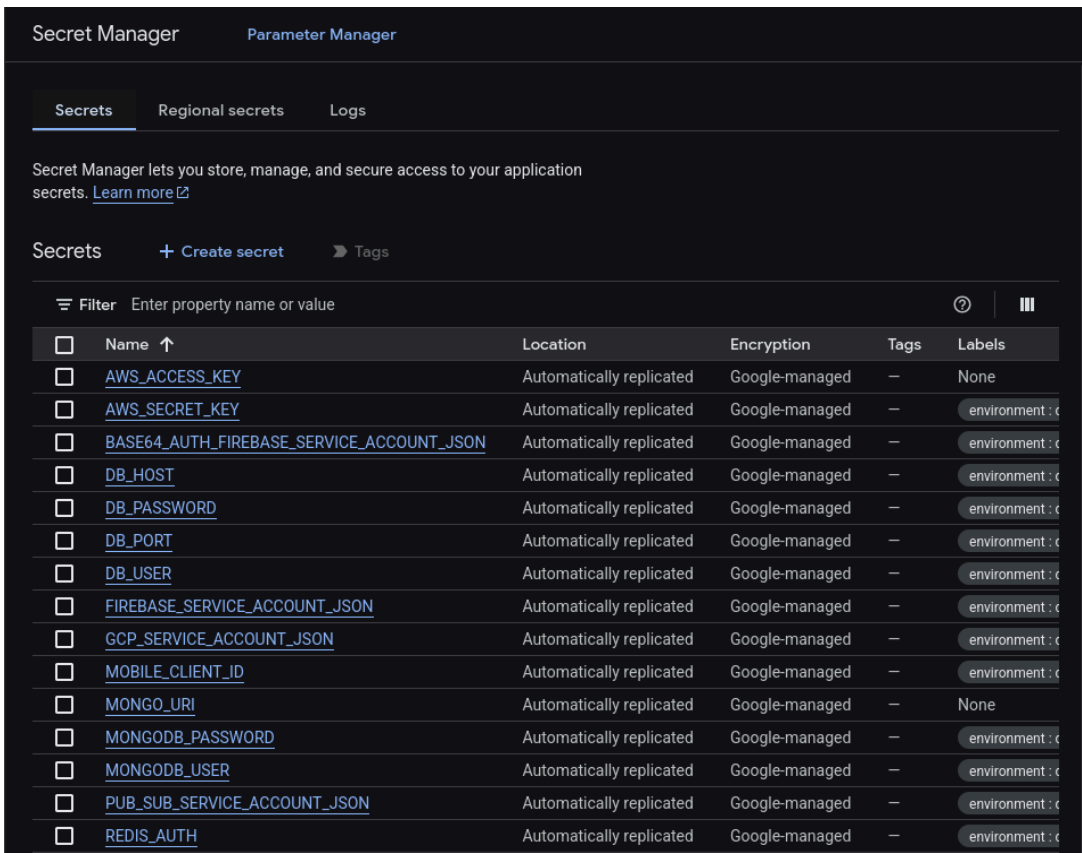


Figure 6.9.3 - Audit Logs for Secret Manager

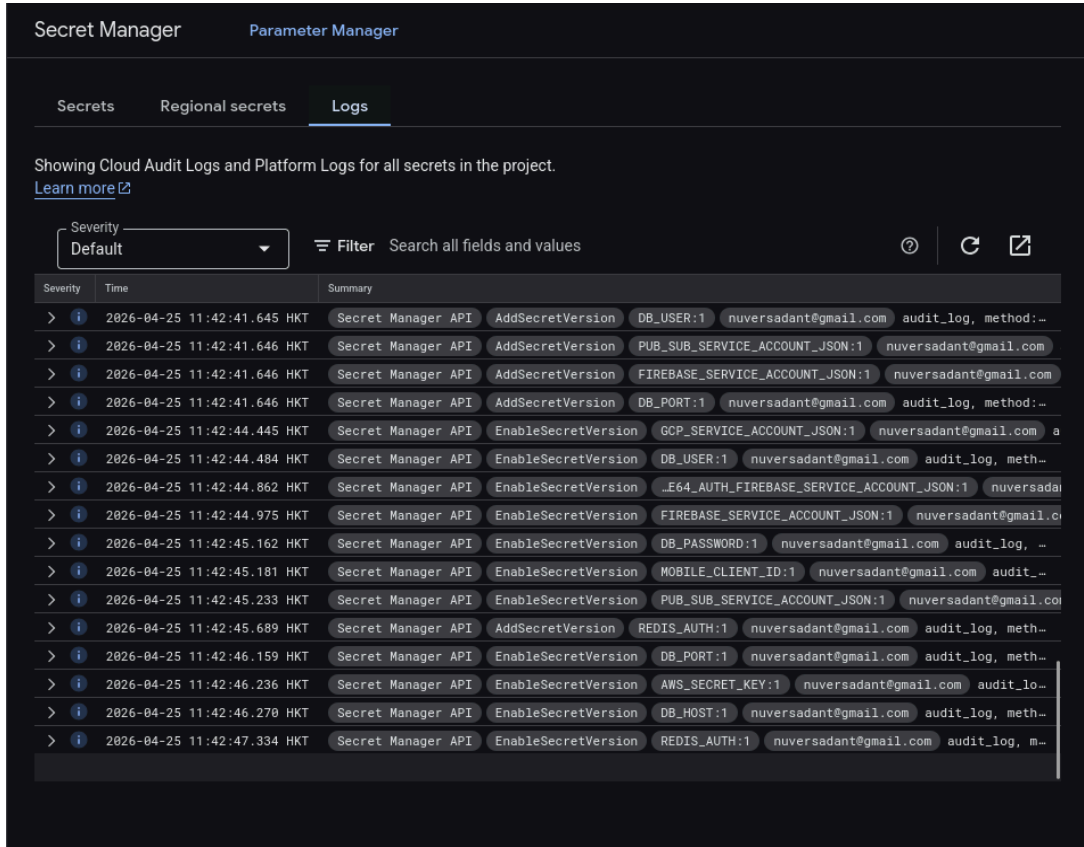


Figure 6.11.1 Results of load testing on login endpoint - 200 requests made in 3 seconds. API throttling results in 429 errors for 172 responses.

```
(base) shchov@Shirleys-Air ~ % hey -n 200 -c 10 -m POST \
-H 'Content-Type: application/json' \
-d '{"username":"loadtest-dummy@example.com","password":"NotARealPassword123"}' \
https://api.chronoflow.site/users/auth/login
```

Summary:

```
Total:      2.9175  secs
Slowest:    0.5673  secs
Fastest:    0.0292  secs
Average:    0.1370  secs
Requests/sec: 68.5516
```

```
Total data: 24424 bytes
Size/request: 122 bytes
```

Response time histogram:

Value	Count
0.029	1
0.083	8
0.137	159
0.191	20
0.244	2
0.298	0
0.352	4
0.406	0
0.460	0
0.513	2
0.567	4

Latency distribution:

```
10% in 0.1128 secs
25% in 0.1162 secs
50% in 0.1204 secs
75% in 0.1286 secs
90% in 0.1437 secs
95% in 0.3365 secs
99% in 0.5673 secs
```

Details (average, fastest, slowest):

```
DNS+dialup:      0.0122 secs, 0.0000 secs, 0.3000 secs
DNS-lookup:      0.0072 secs, 0.0000 secs, 0.1457 secs
req write:        0.0000 secs, 0.0000 secs, 0.0004 secs
resp wait:        0.1238 secs, 0.0254 secs, 0.3161 secs
resp read:        0.0008 secs, 0.0000 secs, 0.0594 secs
```

Status code distribution:

```
[200] 28 responses
[429] 172 responses
```

Figure 6.11.2 WAF Rule to rate limit 20 req/min on certain endpoint

Match condition builder

Preview

Match condition editor

AND

OR

Condition type 1

Request path

Condition type 2

Request path

Condition type 3

Request path

Condition type 4

Request path

Condition type 5

Request path

Add another condition

Modifiers

Applied

Edit

Operator

Contains

Value *

/login

X

Operator

Contains

Value *

/oauth2

X

Operator

Contains

Value *

/signin

X

Operator

Contains

Value *

/logout

X

Operator

Contains

Value *

/api/auth

X

Generated match condition

request.path.lower().contains('/login') || request.path.lower().contains('/oauth2') || request.path.lower().contains('/signin') || request.path.lower().contains('/logout') || request.path.lower().contains('/api/auth')

Advanced rule tuning

Fine tune

reCAPTCHA site key configuration

Configure

Remove

Action

Rate based ban

Threshold setting

Request count *

20

Interval *

1 minute

Figure. 6.12.1 Screenshot of certificate used to codesign ios build artefact, successful code sign

Summary

All jobs

build-and-deploy

Run details

Usage

Workflow file

build-and-deploy

succeeded 2 minutes ago in 4m 0s

Search logs

Install Certificates

5s

121 | Certificate Name | sigh_edu.nus.u.chronoflow_appstore_certificate-name | Apple Distribution: Jia Shiuan Shirley Chow
122 | (2U93L9FLAY) |
123 |-----|
124 [02:42:00]: All required keys, certificates and provisioning profiles are installed 🎉
125 [02:42:00]: Setting Provisioning Profile type to 'app-store'
126 |-----|
127 | fastlane summary |
128 |-----|
129 | Step | Action | Time (in s) |
130 |-----|
131 | 1 | default_platform | 0 |
132 | 2 | match | 2 |
133 |-----|
134 |
135 [02:42:00]: fastlane.tools finished successfully 🎉
136 |-----|
137 |
138 #####
139 # fastlane 2.234.0 is available. You are on 2.233.0.
140 # You should use the latest version.
141 # Please update using 'bundle update fastlane'.
142 #####
143 |-----|

Sign and Export IPA

0s

1 ▶ Run security set-key-partition-list -S apple-tool:,apple:,codesign: -s -k "" build.keychain
26 keychain: "/Users/runner/Library/Keychains/build.keychain-db"
27 version: 512
28 class: 0x00000010
29 attributes:
30 0x00000000 <uint32>=0x00000010
31 0x00000001 <blob>="Imported Private Key"

1691 [03:10:43]: Successfully exported and compressed dSYM file
1692 [03:10:43]: Successfully exported and signed the ipa file:
1693 [03:10:43]: /Users/runner/work/chronoflow-mobile/chronoflow-mobile/ios/Runner.ipa
1694 [03:10:43]: -----

Team 3 | ISS5005 Final Report — Page 41

Figure 6.12.2 - Release build using keystore

```

✓ build-and-deploy
Run details
Usage
Workflow file

run fastlane
90 | release_status      | draft |
91 | json_key_data       | ***** |
92 | aab                 | ../build/app/outputs/bundle/release/app-release.aab |
93 | package_name        | edu.nus.u.chronoflowapp |
94 | metadata_path       | ../fastlane/metadata/android |
95 | skip_***_apk        | false |
96 | skip_***_aab        | false |
97 | skip_***_metadata   | false |
98 | skip_***_changelogs | false |
99 | skip_***_images     | false |
100 | skip_***_screenshots | false |
101 | sync_image_***      | false |
102 | track_promote_release_status | completed |
103 | validate_only       | false |
104 | check_superseded_tracks | false |
105 | timeout             | 300 |
106 | deactivate_on_promote | true |
107 | changes_not_sent_for_review | false |
108 | rescue_changes_not_sent_for_review | true |
109 | ack_bundle_installation_warning | false |
110 +-----+-----+-----+
111
112 [14:56:19]: Preparing aab at path '../build/app/outputs/bundle/release/app-release.aab' for **
113 [14:57:09]: Updating track 'internal'...
114 [14:57:10]: Preparing ***s for language 'en-US'...
115 [14:57:10]: Could not find changelog for '3' and language 'en-US' at path ../fastlane/metadata,
116 [14:57:10]: Uploaded all items for language 'en-US'... (0.447193824 secs)
117 [14:57:10]: Uploading all changes to Google Play...
118 [14:57:12]: Successfully finished the *** to Google Play
119
120 +-----+-----+-----+
121 |                                     | fastlane summary |
122 +-----+-----+-----+
123 | Step | Action | Time (in s) |
124 +-----+-----+-----+
125 | 1 | default_platform | 0 |
126 | 2 | flutter build appbundle --release --obfuscate --split-debug-i | 431 |
127 | 3 | ***_to_play_store | 53 |
128 +-----+-----+-----+
129
130 [14:57:12]: fastlane.tools just saved you 8 minutes! 🚀

```

```

chronoflow-mobile / android / app / build.gradle.kts
Code Blame 66 lines (56 loc) · 1.98 KB
18     targetCompatibility = JavaVersion.VERSION_17
19 }
20
21 defaultConfig {
22     applicationId = "edu.nus.u.chronoflowapp"
23     minSdk = flutter.minSdkVersion
24     targetSdk = flutter.targetSdkVersion
25     versionCode = flutter.versionCode
26     versionName = flutter.versionName
27 }
28
29 signingConfigs {
30     create("release") {
31         val keystoreProperties = Properties()
32         val keystorePropertiesFile = rootProject.file("key.properties")
33         if (keystorePropertiesFile.exists()) {
34             keystoreProperties.load(FileInputStream(keystorePropertiesFile))
35         }
36
37         keyAlias = System.getenv("KEY_ALIAS") ?: keystoreProperties["keyAlias"] as String? ?: ""
38         keyPassword = System.getenv("KEY_PASSWORD") ?: keystoreProperties["keyPassword"] as String? ?: ""
39         storePassword = System.getenv("STORE_PASSWORD") ?: keystoreProperties["storePassword"] as String? ?: ""
40
41         val storeFilePath = System.getenv("STORE_FILE") ?: keystoreProperties["storeFile"] as String?

```

Figure 6.13.1 - Code obfuscation performed during build process

Summary

All jobs

✓ build-and-deploy

Run details

Usage

Workflow file

✓ Sign and Export IPA

```

1723 [03:14:55]: ▶ Copying file:///Users/runner/work/chronoflow-mobile/chronoflow-mobile/debu
Type=application/octet-stream]...
1724 [03:14:56]: ▶ - [1 files][ 3.0 MiB/ 3.0 MiB]
1725 [03:14:56]: ▶ Operation completed over 1 objects/3.0 MiB.
1726
1727 +-----+
1728 |                                     fastlane summary                                     |
1729 +-----+
1730 | Step | Action                                                                 | Time (in s) |
1731 +-----+
1732 | 1     | default_platform                                                       | 0            |
1733 | 2     | app_store_connect_api_key                                             | 0            |
1734 | 3     | latest_testflight_build_number                                        | 0            |
1735 | 4     | increment_build_number                                                | 2            |
1736 | 5     | flutter build ios --release --obfuscate --split-debug-info=/U       | 122          |
1737 | 6     | build_app                                                             | 111          |
1738 | 7     | upload_to_testflight                                                  | 249          |
1739 | 8     | gsutil cp /Users/runner/work/chronoflow-mobile/chronoflow-mob       | 3            |
1740 +-----+

```

build-and-deploy

Run details

Usage

Workflow file

✓ Run Fastlane

```

90 | release_status | draft
91 | json_key_data  | *****
92 | aab            | ../build/app/outputs/bundle/release/app-release.aab
93 | package_name   | edu.nus.u.chronoflowapp
94 | metadata_path  | ./fastlane/metadata/android
95 | skip_***_apk   | false
96 | skip_***_aab   | false
97 | skip_***_metadata | false
98 | skip_***_changelogs | false
99 | skip_***_images | false
100 | skip_***_screenshots | false
101 | sync_image_*** | false
102 | track_promote_release_status | completed
103 | validate_only   | false
104 | check_superseded_tracks | false
105 | timeout         | 300
106 | deactivate_on_promote | true
107 | changes_not_sent_for_review | false
108 | rescue_changes_not_sent_for_review | true
109 | ack_bundle_installation_warning | false
110 +-----+
111
112 [14:56:19]: Preparing aab at path '../build/app/outputs/bundle/release/app-release.aab' for **
113 [14:57:09]: Updating track 'internal'...
114 [14:57:10]: Preparing ***s for language 'en-US'...
115 [14:57:10]: Could not find changelog for '3' and language 'en-US' at path ./fastlane/metadata/
116 [14:57:10]: Uploaded all items for language 'en-US'... (0.447193824 secs)
117 [14:57:10]: Uploading all changes to Google Play...
118 [14:57:12]: Successfully finished the *** to Google Play
119
120 +-----+
121 |                                     fastlane summary                                     |
122 +-----+
123 | Step | Action                                                                 | Time (in s) |
124 +-----+
125 | 1     | default_platform                                                       | 0            |
126 | 2     | flutter build appbundle --release --obfuscate --split-debug-i       | 431          |
127 | 3     | ***_to_play_store                                                      | 53           |
128 +-----+
129
130 [14:57:12]: fastlane.tools just saved you 8 minutes! 🎉

```


Figure 6.14.1 - Metrics and Logs monitoring

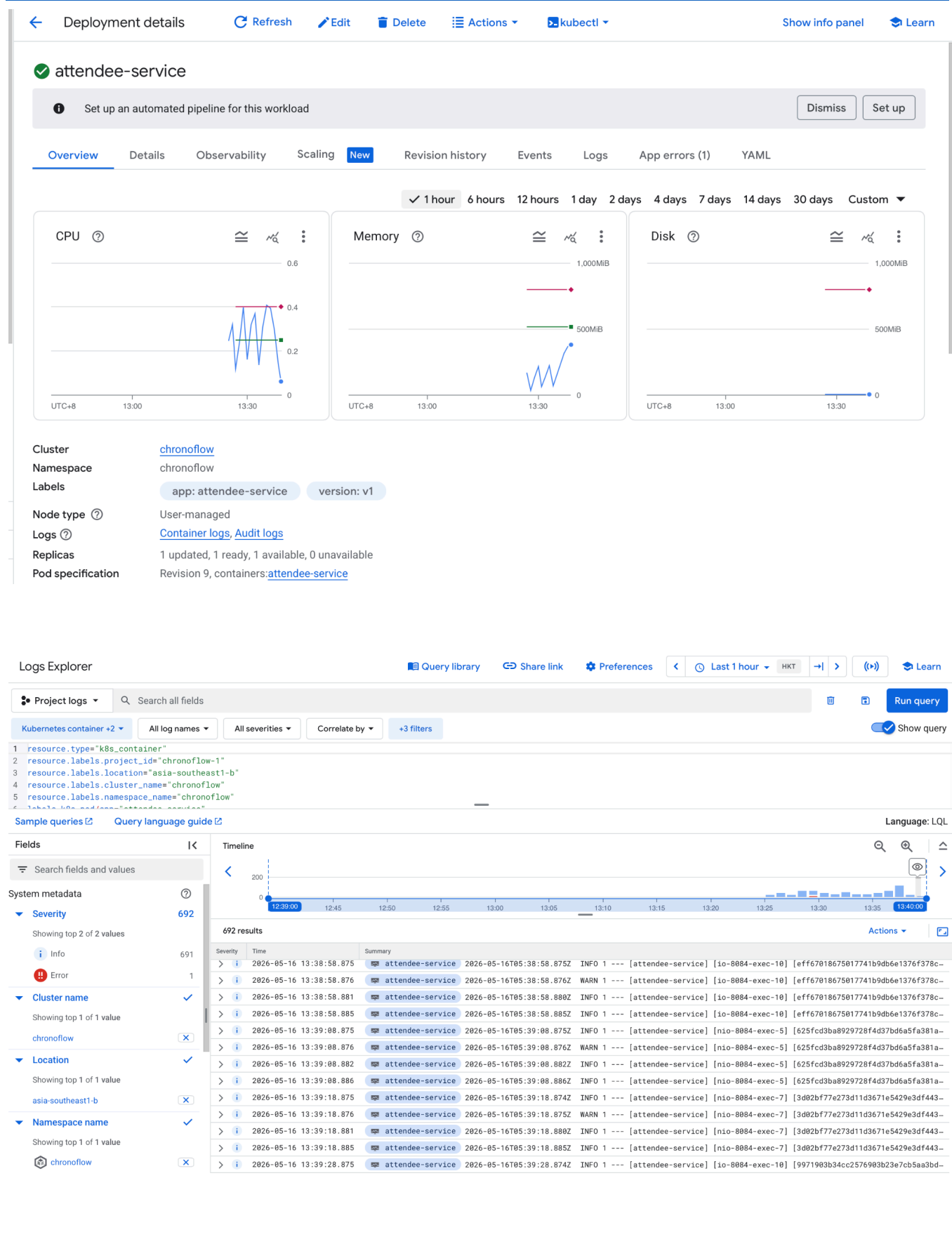
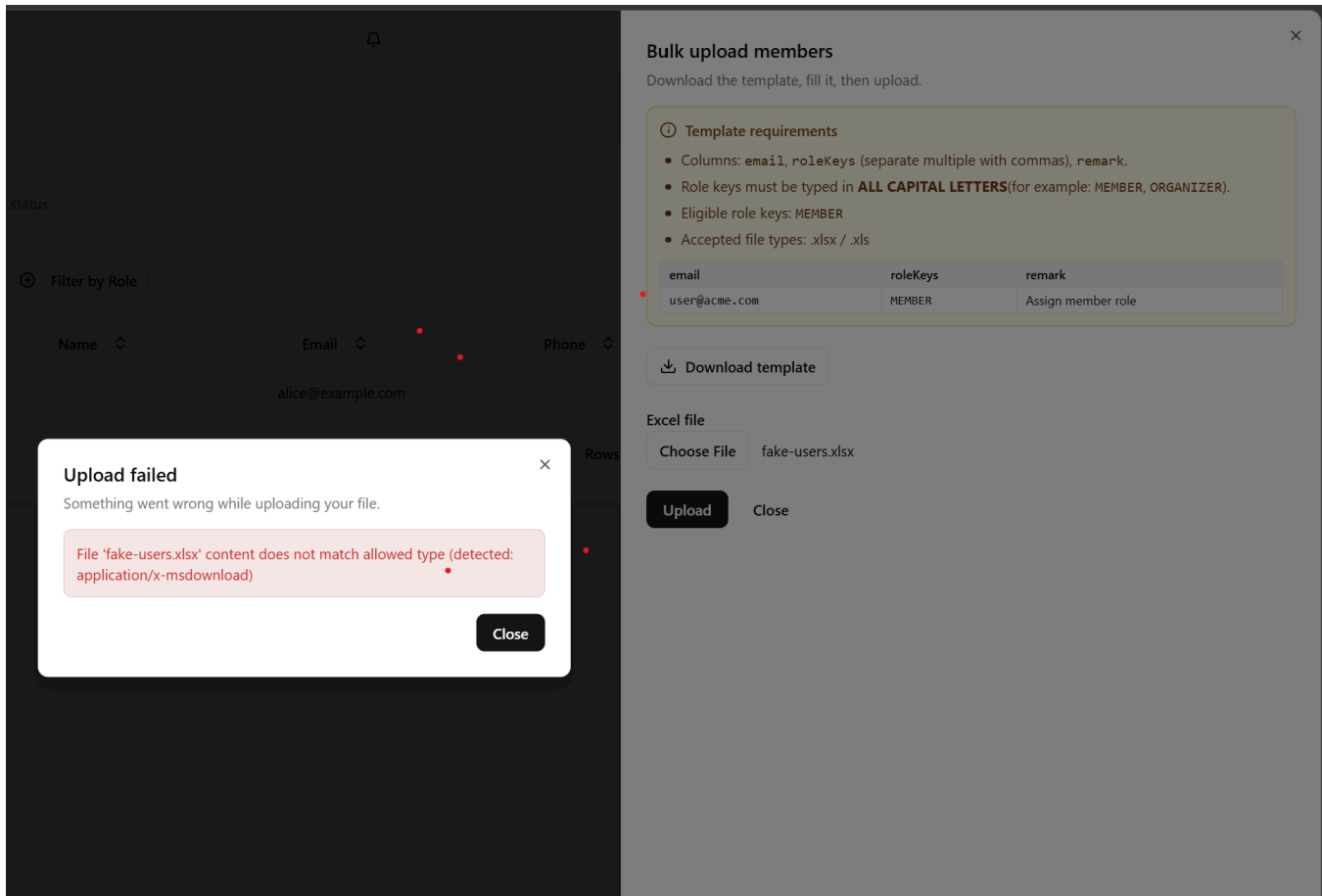


Figure 6.15.1 - File validation for magic number to prevent file upload attacks



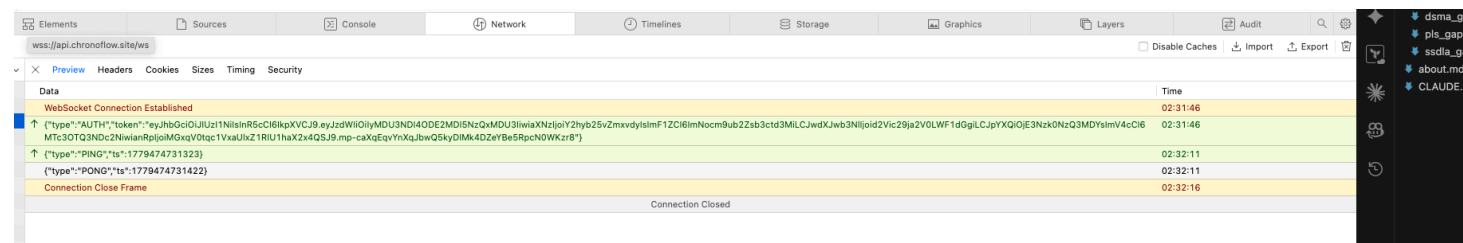
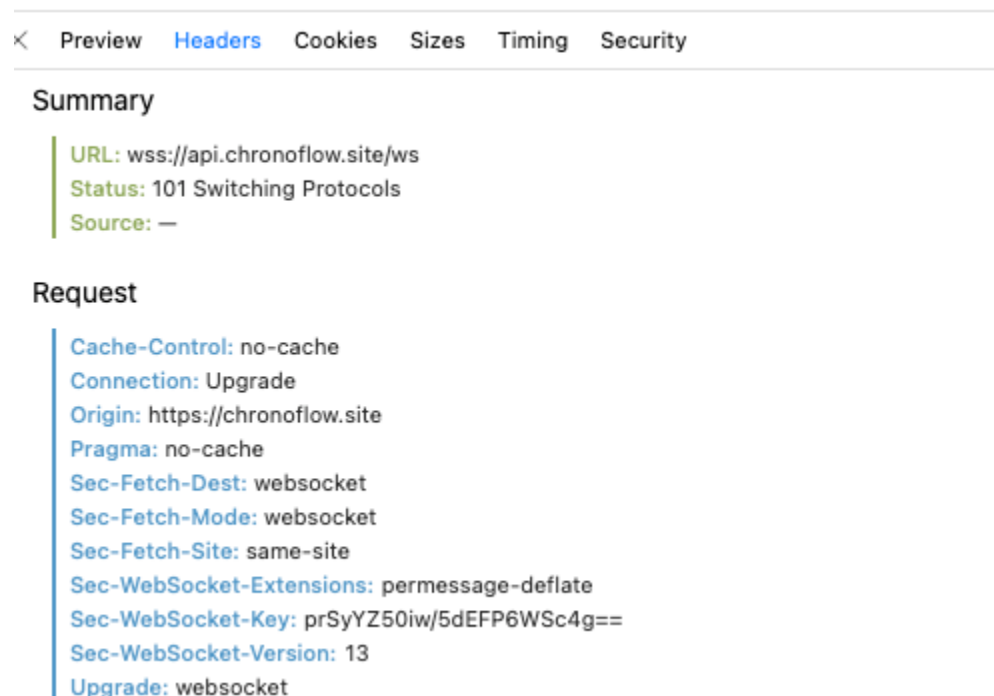


Figure 6.16.3 - Authenticated HTTPS Headers for WS JWT Minting

Request

```
Accept: application/json, text/plain, */*
Accept-Encoding: gzip, deflate, br
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
Content-Length: 0
Cookie: Authorization=34fec894-ab09-d486-ba08-dffe6280831; refreshToken=a03819e-d73-4c16-b1b0-e7e20c5c4e7
Origin: https://chronoflow.site
Priority: u=3, i
Referer: https://chronoflow.site/
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-site
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.6 Safari/605.1.15
```

Response

```
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: Content-Type, Authorization, Accept, Origin, X-Requested-With, Cache-Control, Pragma
Access-Control-Allow-Methods: GET,POST,DELETE,PATCH,PUT,OPTIONS
Access-Control-Allow-Origin: https://ichronoflow.site
Access-Control-Max-Age: 3600
Alt-Svc: h3="443"; ma=2592000,h3-29="443"; ma=2592000
Content-Length: 326
Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:// fonts.gstatic.com; connect-src 'self' https://*.googleapis.com https://*.firebaseapp.com https://identitytoolkit.googleapis.com https://securetoken.googleapis.com wss://*.firebaseapp.com; frame-src 'self'; firebaseapp https://accounts.google.com; base-uri 'self'; form-action 'self'
Content-Type: application/json
```

Figure 6.16.4 - WS JWT Token and Expiry Response

[illegible]

Figure 6.17.1 - Push Device Registration Sends Public Encryption Material Only

The screenshot shows the Burp Suite interface. The top section displays a timeline of requests with a red bar indicating the selected request. The bottom section shows the 'Request Payload' tab, which contains a JSON object with fields like deviceId, platform, pushKeyAlg, pushKeyVersion, pushPublicKey, and token. The token field is highlighted in red.



Figure 6.17.4 - Browser Displays Decrypted Push Notification

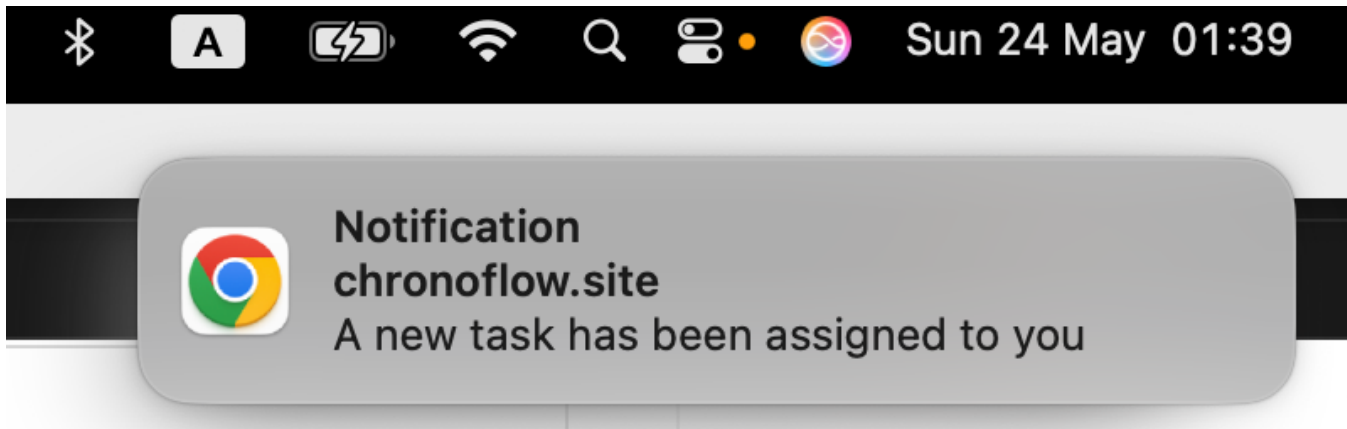


Figure 6.18.1 - WebView Loads Allowed ChronoFlow Domain

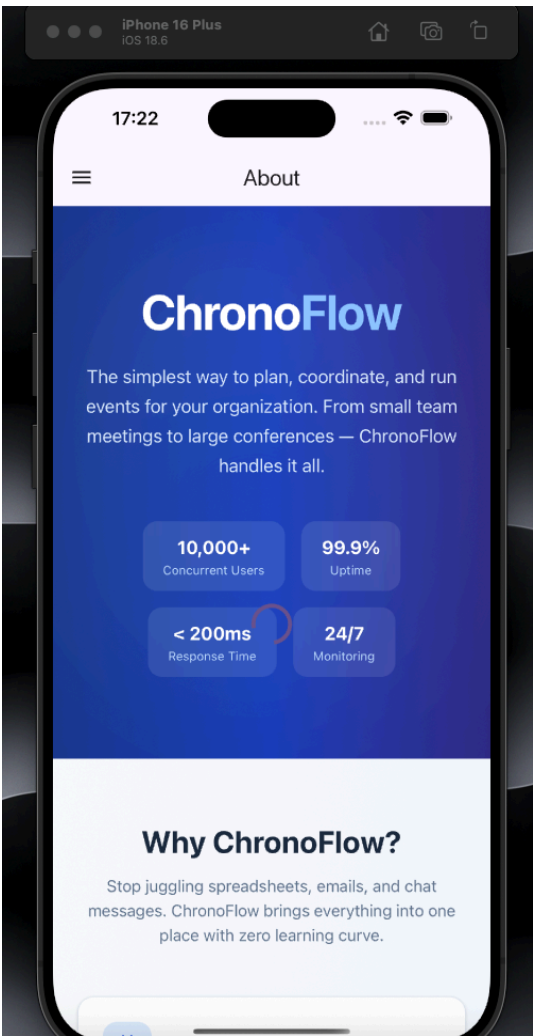


Figure 6.18.2 - WebView Blocks Suffix-Spoofed Domain Test

```
void _initializeWebView() {  
    final targetUrl = Uri.parse('https://chronoflow.site.evil.com');  
  
    if (!WebViewSecurity.isUrlAllowed(targetUrl.toString())) {  
        setState(() {  
            _errorMessage = 'Blocked: URL is not in the allowed domains list.';  
            _isLoading = false;  
        });  
        return;  
    }  
}
```

Figure 6.18.3 - WebView Shows Blocked Navigation Error

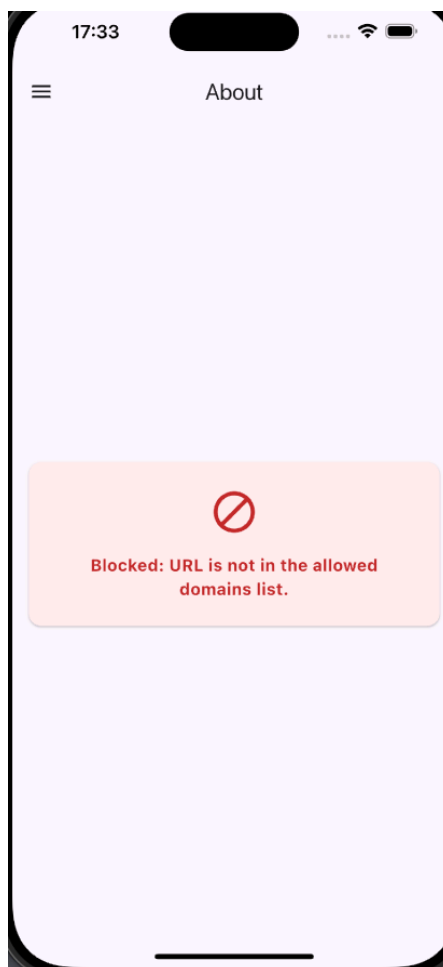


Figure 6.19.1 - Cloud SQL instance uses private IP connectivity and public IP connectivity is disabled.

➔

Connect to this instance

Connection name

chronoflow-1:asia-southeast1:chronoflow-mysql

Private IP connectivity

Enabled

Private Service Access (PSA)

Enabled

Associated networking

projects/chronoflow-1/global/networks/chronoflow-vpc-dev

VPC network

chronoflow-vpc-dev

Allocated IP range

Automatically assigned IP range

Internal IP address

10.122.1.3

Write endpoint

-

Public IP connectivity

Disabled

Default TCP database port number

3306

Figure 6.19.2 - Cloud SQL Backup and Point-in-Time Recovery Are Enabled

All instances > chronoflow-mysql

chronoflow-mysql

MySQL 8.4

Settings

Edit

Backup tier

Standard backup tier

Automated backups

Enabled

Backups window

12:00 AM – 4:00 AM (GMT+8)

Automated backups retained

7

Point-in-time recovery

Enabled

Days of logs retained

7

Location

Multi-region: default

Create backup

Restore to a point in time

Backup Tier

Standard Tier (currently active)

Filter

Filter backups

Created	Type	Location	Description	
May 24, 2026, 1:31:04 AM	Automated	Multi-region: asia	-	Restore
May 23, 2026, 1:08:38 AM	Automated	Multi-region: asia	-	Restore
May 22, 2026, 1:05:14 AM	Automated	Multi-region: asia	-	Restore
May 21, 2026, 12:50:52 AM	Automated	Multi-region: asia	-	Restore
May 20, 2026, 2:18:36 AM	Automated	Multi-region: asia	-	Restore
May 19, 2026, 12:58:30 AM	Automated	Multi-region: asia	-	Restore
May 18, 2026, 12:58:27 AM	Automated	Multi-region: asia	-	Restore

Figure 6.19.3 - Cloud SQL Enforces SSL Connections and prevents plaintext database client connection

Security

SSL mode

Secure data transmission between client and this instance by enforcing SSL encryption and certificates. SSL encryption is recommended for all connections using public IP networks. [Learn more](#) 

- ☐ Allow unencrypted network traffic (not recommended)
- ☒ Allow only SSL connections
Only allows connections using SSL/TLS encryption. Client certificates will not be verified.
- ☐ Require trusted client certificates
Only allows connections from clients that use a valid client certificate and SSL encryption

Server certificate authority mode

Choose the type of certificate authority that signs the server certificate for this Cloud SQL instance. [Learn more](#) 

Server certificate authority mode can't be changed once chosen for the instance.

- ☒ Google managed internal certificate authority
An internal per-instance certificate authority is the trust anchor for the instance.
- ☐ Google managed CAS certificate authority
A root certificate authority and subordinate certificate authorities stored in Certificate Authority Service (CAS) are the trust anchors for all instances in a region.
- ☐ Customer managed CAS certificate authority
Certificate authorities that you create and manage in the Certificate Authority Service (CAS) are the trust anchors for the instance.
- ☐ Rotate server certificates automatically
Auto-rotates certificates during maintenance within 6 months of expiration. [Learn more](#) 

Figure 6.20.1 - Application pods use distinct Kubernetes ServiceAccounts

```
(base) thetนาungsoe@MacBook-Pro-105 security_project % kubectl get pods -n chronoflow \
-l version=v1 \
-o 'custom-columns=NAME:.metadata.name,APP:.metadata.labels.app,SA:.spec.serviceAccountName,READY:.status.containerStatuses[*].ready'
NAME                                APP                                SA                                READY
attende-service-5b8654dff5-9t9ht    attendee-service                  attendee-service-sa             true
event-service-57d9f5669-fvzd2       event-service                    event-service-sa                true
event-service-57d9f5669-nv67h       event-service                    event-service-sa                true
file-service-85db7d547c-cmtdx       file-service                    file-service-sa                 true
gateway-66cbf7b655-fdz62            gateway                         gateway-sa                     true
notification-service-54cd87d987-4lm24 notification-service             notification-service-sa         true
task-service-85968b489c-5lkpn        task-service                    task-service-sa                 true
user-service-76fd7bf7b4-ffsqc       user-service                    user-service-sa                 true
wsgateway-588d6576db-xvjgk          wsgateway                      wsgateway-sa                   true
(base) thetนาungsoe@MacBook-Pro-105 security_project %
```

Figure 6.20.2 - Task Service Workload Uses Dedicated ServiceAccount

task-service

Set up an automated pipeline for this workload

DismissSet up

OverviewDetailsObservabilityScalingNewRevision historyEventsLogsApp Errors (0)YAML

Try out the new "Explain code" feature! Enable Gemini APIs to start using this feature.

Enable APIsDismiss

CopyDownload

165requests:

166cpu: 250m

167memory: 512Mi

168terminationMessagePath: /dev/termination-log

169terminationMessagePolicy: File

170dnsPolicy: ClusterFirst

171restartPolicy: Always

172schedulerName: default-scheduler

173securityContext: {}

174serviceAccount: task-service-sa

175serviceAccountName: task-service-sa

176terminationGracePeriodSeconds: 30

177status:

178availableReplicas: 1

179conditions:

180- lastTransitionTime: '2026-05-23T15:09:24Z'

181lastUpdateTime: '2026-05-23T15:09:24Z'

182message: Deployment has minimum availability.

183reason: MinimumReplicasAvailable

184status: 'True'

185type: Available

186- lastTransitionTime: '2026-04-21T08:29:25Z'

187lastUpdateTime: '2026-05-23T22:59:42Z'

188message: ReplicaSet "task-service-85968b489c" has successfully progressed.

189reason: NewReplicaSetAvailable

190status: 'True'

191type: Progressing

192observedGeneration: 28

193readyReplicas: 1

194replicas: 1

195terminatingReplicas: 0

196updatedReplicas: 1

197

Team 3 | ISS5005 Final Report — Page 53

Figure 6.20.3 - Backend Services Enforce STRICT Istio mTLS

```
(base) thetนาungsoe@MacBook-Pro-105 security_project % kubectl get peerauthentication -n chronoflow
NAME                                MODE    AGE
attendee-service-strict-mtls        STRICT  165m
event-service-strict-mtls           STRICT  165m
file-service-strict-mtls            STRICT  165m
notification-service-strict-mtls     STRICT  165m
task-service-strict-mtls            STRICT  165m
user-service-strict-mtls            STRICT  165m
wsgateway-strict-mtls              STRICT  22m
(base) thetนาungsoe@MacBook-Pro-105 security_project %
```

Figure 6.20.4 - Workload Details Show Istio Sidecar Injection Enabled

attendee-service

Set up an automated pipeline for this workload

Overview

Details

Observability

Scaling

New

Revision history

Events

Logs

App Errors (1)

YAML

Cluster

chronoflow

Namespace

chronoflow

Created

Apr 21, 2026, 4:29:30 PM

Labels

app: attendee-service

version: v1

Annotations

deployment.kubernetes.io/revision: 19

Show all annotations

Node type

User-managed

Replicas

1 updated, 1 ready, 1 available, 0 unavailable

Label selector

app = attendee-service

Classification

istio-injection

Update strategy

Rolling update, Max unavailable: 1, Max surge: 0

Min time ready before available

0 s

Progress deadline

600 s

Revision history limit

10

Pod specification

Revision

19

Labels

app: attendee-service

sidecar.istio.io/inject: true

version: v1

Termination grace period

30

Restart policy

Always

Containers

attendee-service

Figure 6.20.5 - Istio AuthorizationPolicy Inventory Across Backend Services

▼ security.istio.io		API Group				
▼ AuthorizationPolicy		Kind				
attendee-service-allow-required-callers	● Unknown	Authorization Policy	chronoflow	chronoflow	asia-southeast1-b	
event-service-allow-required-callers	● Unknown	Authorization Policy	chronoflow	chronoflow	asia-southeast1-b	
file-service-allow-required-callers	● Unknown	Authorization Policy	chronoflow	chronoflow	asia-southeast1-b	
notification-service-allow-required-callers	● Unknown	Authorization Policy	chronoflow	chronoflow	asia-southeast1-b	
task-service-allow-required-callers	● Unknown	Authorization Policy	chronoflow	chronoflow	asia-southeast1-b	
user-service-allow-required-callers	● Unknown	Authorization Policy	chronoflow	chronoflow	asia-southeast1-b	
wsgateway-allow-required-callers	● Unknown	Authorization Policy	chronoflow	chronoflow	asia-southeast1-b	
▼ PeerAuthentication		Kind				
attendee-service-strict-mtls	● Unknown	Peer Authentication	chronoflow	chronoflow	asia-southeast1-b	
event-service-strict-mtls	● Unknown	Peer Authentication	chronoflow	chronoflow	asia-southeast1-b	
file-service-strict-mtls	● Unknown	Peer Authentication	chronoflow	chronoflow	asia-southeast1-b	
notification-service-strict-mtls	● Unknown	Peer Authentication	chronoflow	chronoflow	asia-southeast1-b	
task-service-strict-mtls	● Unknown	Peer Authentication	chronoflow	chronoflow	asia-southeast1-b	
user-service-strict-mtls	● Unknown	Peer Authentication	chronoflow	chronoflow	asia-southeast1-b	
wsgateway-strict-mtls	● Unknown	Peer Authentication	chronoflow	chronoflow	asia-southeast1-b	

Figure 6.20.6 - Websocket gateway AuthorizationPolicy Allows Only Required Service Identities

```
apiVersion: security.istio.io/v1
kind: AuthorizationPolicy
metadata:
  annotations:
    kubectl.kubernetes.io/last-applied-configuration: |
      {"apiVersion":"security.istio.io/v1","kind":"AuthorizationPolicy","metadata":{"annotations":{},"labels":{"app":"wsgateway","security-control":"zero-trust"},"name":"wsgateway-allow-required-callers","namespace":"chronoflow"},"spec":{"action":"ALLOW","rules":[{"from":[{"source":{"principals":["cluster.local/ns/chronoflow/sa/gateway-sa","cluster.local/ns/chronoflow/sa/notification-service-sa"]},"to":{"operation":{"paths":["/actuator/health","/actuator/health/*","/actuator/prometheus"]}}}]}}}}
  creationTimestamp: '2026-05-23T23:32:41Z'
  generation: 1
  labels:
    app: wsgateway
    security-control: zero-trust
    name: wsgateway-allow-required-callers
    namespace: chronoflow
    resourceVersion: '1779579161928879023'
    uid: de7a9363-fc76-4d4b-8198-710c1a8d9965
spec:
  action: ALLOW
  rules:
    - from:
        - source:
            principals:
              - cluster.local/ns/chronoflow/sa/gateway-sa
              - cluster.local/ns/chronoflow/sa/notification-service-sa
        - to:
            operation:
              paths:
                - /actuator/health
                - /actuator/health/*
                - /actuator/prometheus
  selector:
    matchLabels:
      app: wsgateway
```

Figure 6.20.7 - event-service AuthorizationPolicy Allows Only Required Service Identities

```

1  apiVersion: security.istio.io/v1
2  kind: AuthorizationPolicy
3  metadata:
4    annotations:
5      kubectl.kubernetes.io/last-applied-configuration: |
6        {"apiVersion":"security.istio.io/v1","kind":"AuthorizationPolicy","metadata":{"annotations":{},"labels":{"app":"event-service","security-co
7      creationTimestamp: '2026-05-23T23:32:41Z'
8      generation: 1
9      labels:
10       app: event-service
11       security-control: zero-trust
12       name: event-service-allow-required-callers
13       namespace: chronoflow
14       resourceVersion: '1779579161610383013'
15       uid: dc35293f-a162-4ac1-898d-5ac97c7ad10e
16 spec:
17   action: ALLOW
18   rules:
19   - from:
20     - source:
21       principals:
22       - cluster.local/ns/chronoflow/sa/gateway-sa
23       - cluster.local/ns/chronoflow/sa/task-service-sa
24       - cluster.local/ns/chronoflow/sa/attendee-service-sa
25       - cluster.local/ns/chronoflow/sa/notification-service-sa
26   - to:
27     - operation:
28       paths:
29       - /actuator/health
30       - /actuator/health/*
31       - /actuator/prometheus
32   selector:
33     matchLabels:
34       app: event-service
35

```

Figure 6.20.8 - Unauthorized Internal Service-to-Service Call Is Rejected

```

(base) thetนาungsoe@MacBook-Pro-105 security_project % kubectl exec -n chronoflow deploy/user-service -c user-service -- sh -c 'wget -S -O - -T 8 http://wsgateway:8087/ws/token 2>&1'
| head -40'
Connecting to wsgateway:8087 (10.2.127.174:8087)
HTTP/1.1 403 Forbidden
wget: server returned error: HTTP/1.1 403 Forbidden
(base) thetนาungsoe@MacBook-Pro-105 security_project %

```

Figure 6.20.9 - Redis and Service Discovery (Nacos) Are Restricted by Kubernetes NetworkPolicy

```

1  apiVersion: networking.k8s.io/v1
2  kind: NetworkPolicy
3  metadata:
4    annotations:
5      kubectl.kubernetes.io/last-applied-configuration: |
6        {"apiVersion":"networking.k8s.io/v1","kind":"NetworkPolicy","metadata":{"annotations":{},"labels":{"app":"nacos"},"name":"nacos-allow-chronoflow-apps","namespace":"cf"}
7      creationTimestamp: '2026-05-23T20:12:23Z'
8      generation: 1
9      labels:
10       app: nacos
11       name: nacos-allow-chronoflow-apps
12       namespace: chronoflow
13       resourceVersion: '1779567143575631023'
14       uid: 86275fb5-714b-4567-9c39-2ff142084f1d
15 spec:
16   ingress:
17     - from:
18       - podSelector:
19         matchExpressions:
20           - key: app
21             operator: In
22             values:
23               - gateway
24               - user-service
25               - event-service
26               - task-service
27               - attendee-service
28               - file-service
29               - notification-service
30               - wsgateway
31         ports:
32           - port: 8848
33             protocol: TCP
34           - port: 9848
35             protocol: TCP
36     - from:
37       - podSelector:
38         matchLabels:
39           app: nacos
40         ports:
41           - port: 7848
42             protocol: TCP
43           - port: 8848
44             protocol: TCP
45           - port: 9848
46             protocol: TCP
47           - port: 9849
48             protocol: TCP

```

```

apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  annotations:
    kubectl.kubernetes.io/last-applied-configuration: |
      {"apiVersion":"networking.k8s.io/v1","kind":"NetworkPolicy","metadata":{"annotations":{},"labels":{"app":"redis"},"name":"redis-allow-chronoflow-apps","namespace":"cf"}
    creationTimestamp: '2026-05-23T19:24:20Z'
    generation: 3
    labels:
      app: redis
      name: redis-allow-chronoflow-apps
      namespace: chronoflow
      resourceVersion: '1779566399209647010'
      uid: 22933d52-b9c7-47e0-971f-1836942ffdd3d
spec:
  ingress:
    - from:
      - podSelector:
        matchExpressions:
          - key: app
            operator: In
            values:
              - gateway
              - user-service
              - event-service
              - task-service
              - attendee-service
              - file-service
              - notification-service
              - wsgateway
        ports:
          - port: 6379
            protocol: TCP
      podSelector:
        matchLabels:
          app: redis
      policyTypes:
        - Ingress

```

Figure 6.21.1 - Allow user to acknowledge client side security issues (First time setup only)

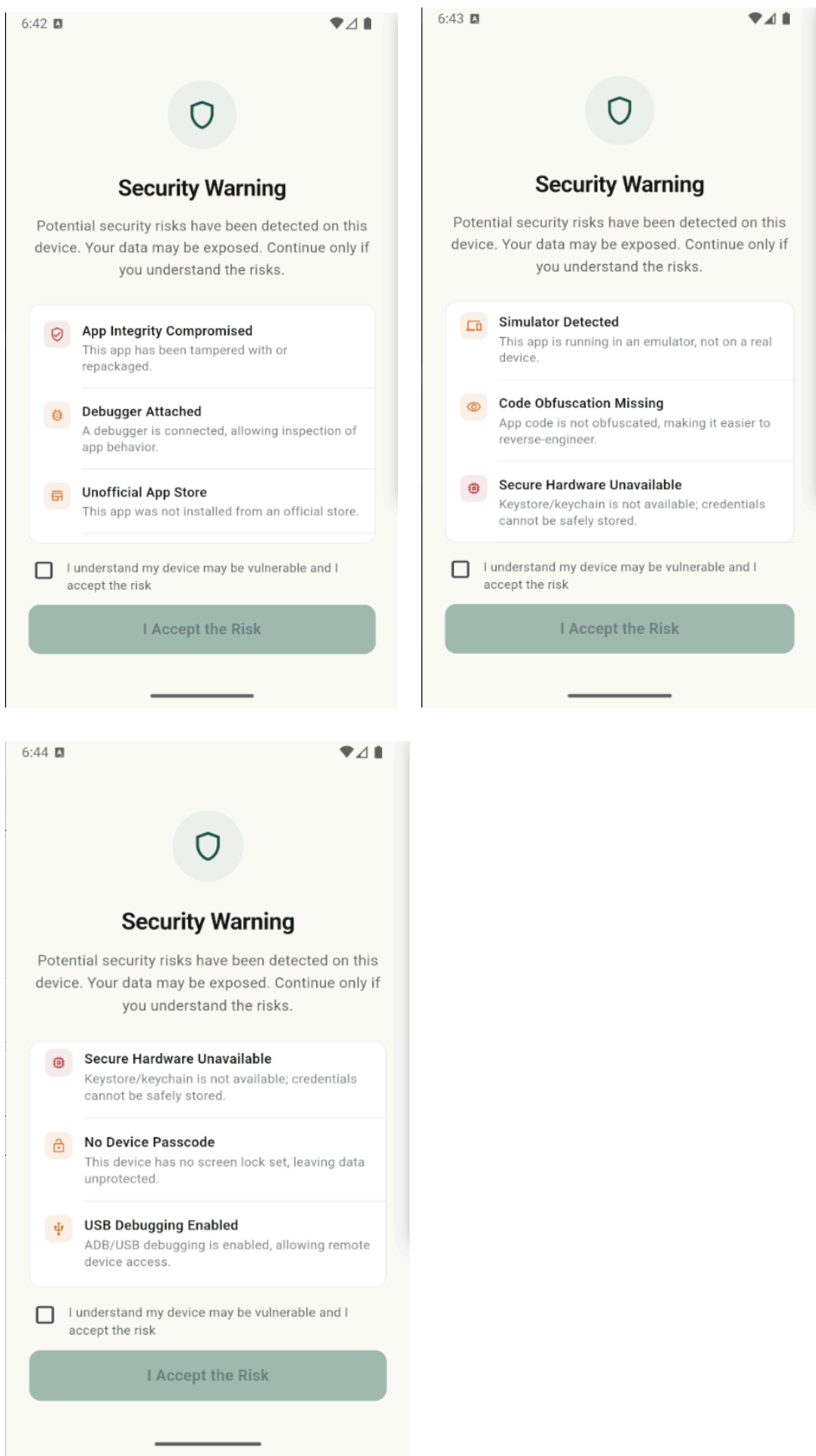


Figure 6.22.1 - TLS 1.2+ supported on frontend site

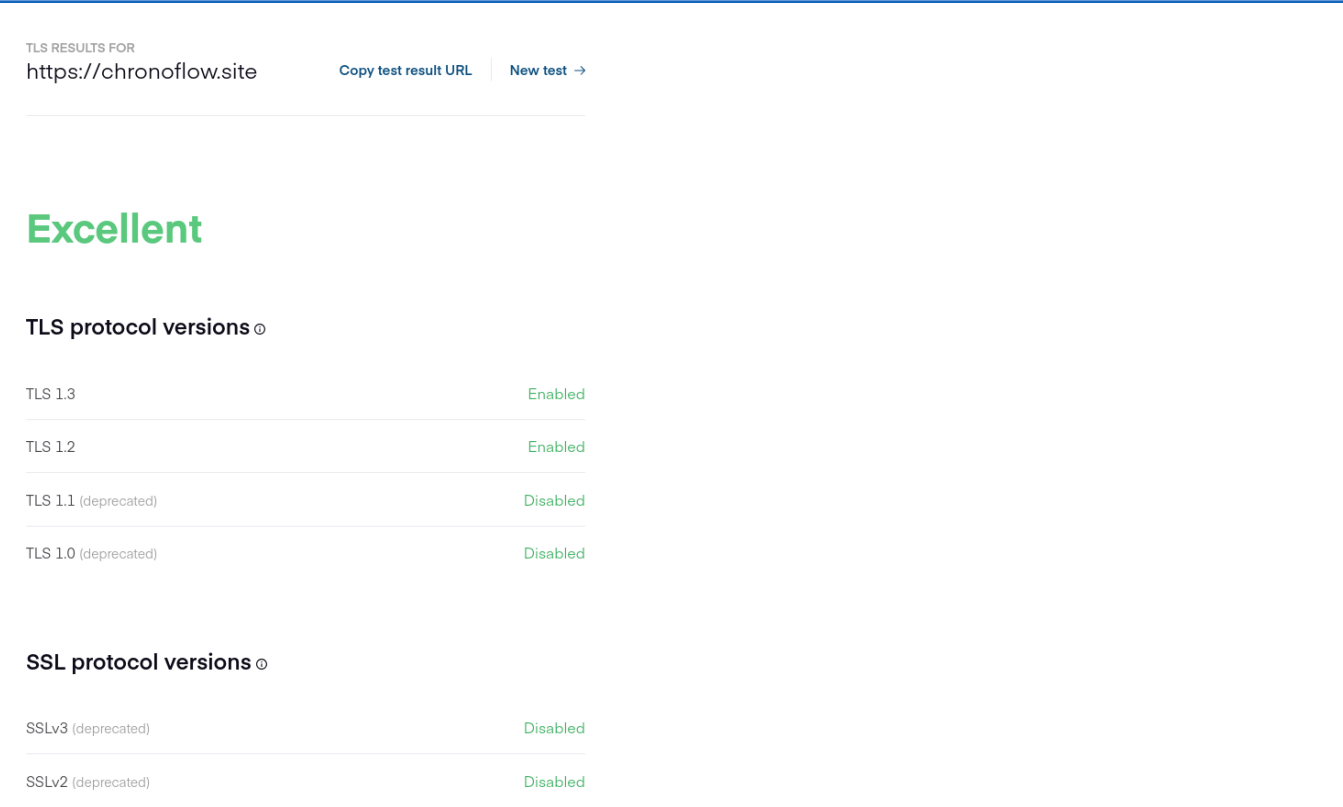


Figure 6.22.2 - TLS 1.2+ supported on backend API

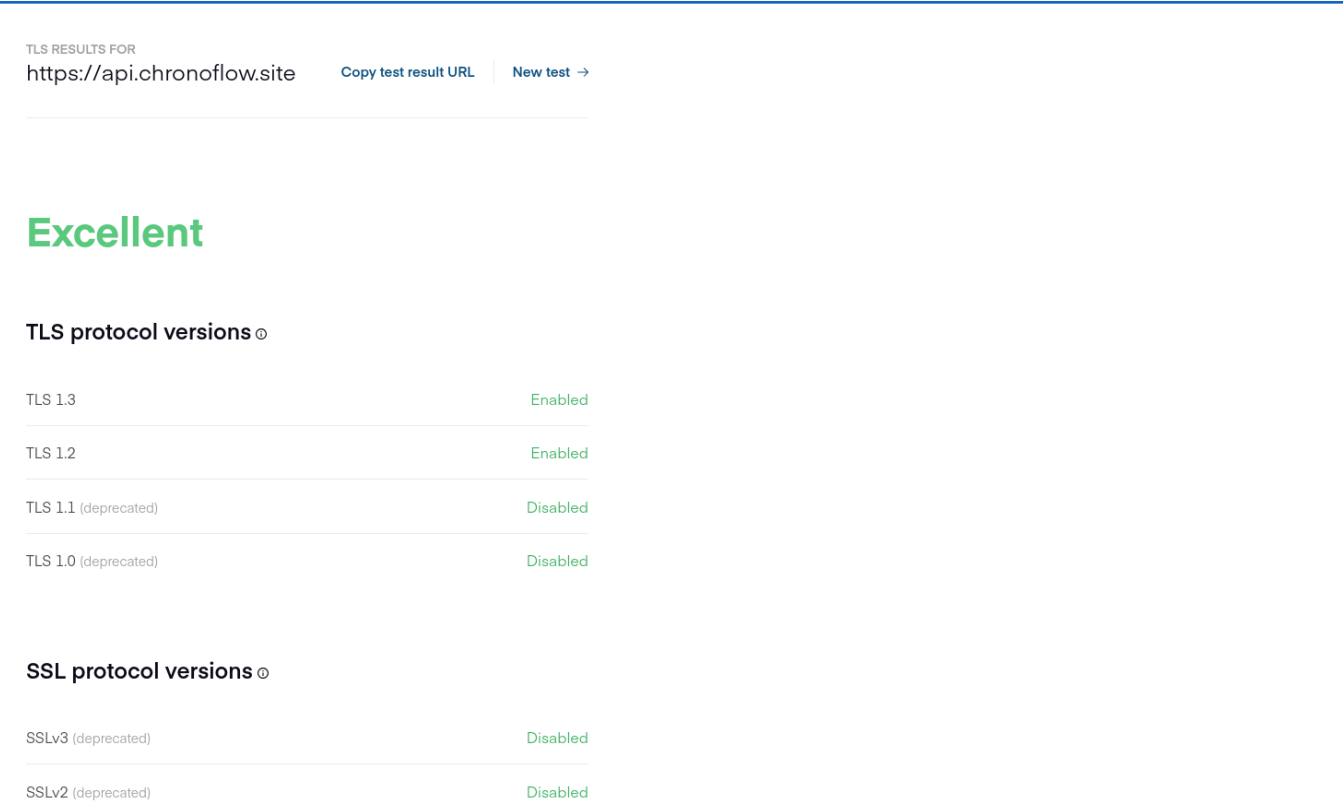


Figure 6.23.1 - DNSSEC fully Signed

 DNSSEC Record Checker

Use this tool to lookup and validate your DNSSEC record.

chronoflow.site

Please enter a valid domain name, without http:// prefix

Lookup

DNSSEC Status

✓ Enabled

DNSSEC at Registrar

✓ Enabled

DNSSEC at Nameservers

✓ Enabled

Result Details

✓ Registrar Status: FullySigned

✓ DS

RecordsRRSIG

Name	Ttl	Class	Type	Raw
chronoflow.site.	900	IN	DS	chronoflow.site. 900 IN DS 55766 8 2 EF6AA506C315B732A334828716F6C958C6 200E113FD2FC4055CC69B3 09642BCE

Figure 6.24.1 - SQL Injection Payload

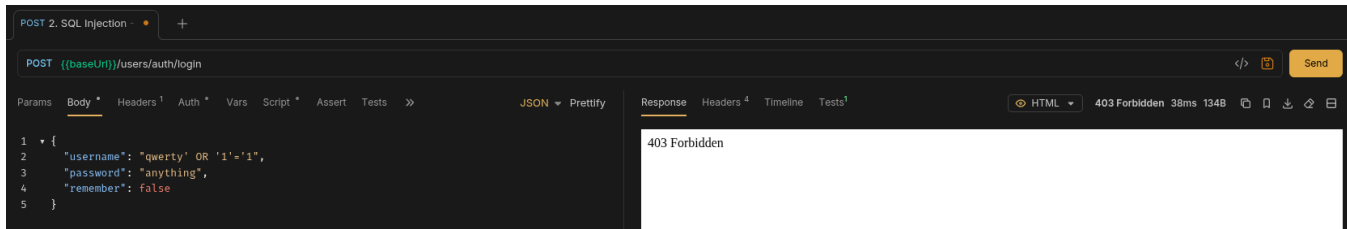


Figure 6.24.2 - Cloud Logging on Deny

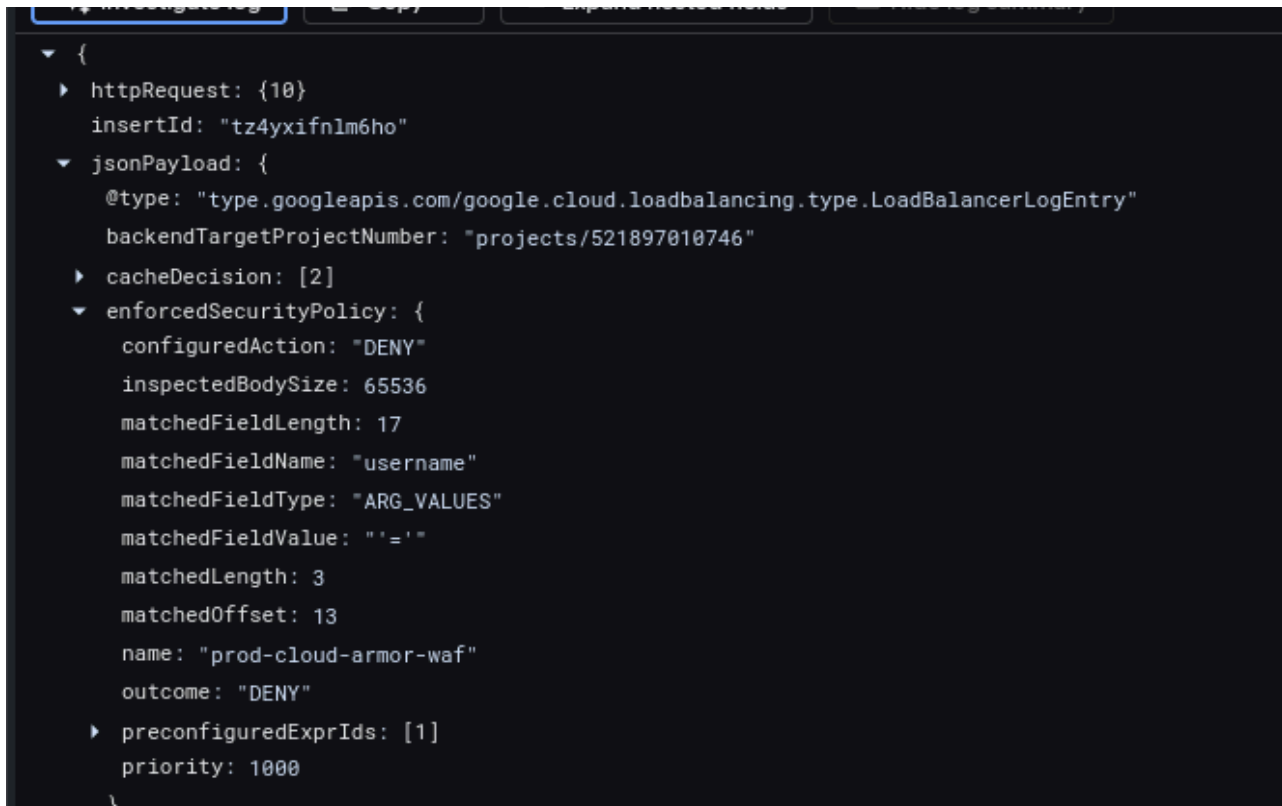


Figure 6.24.3 - SQL Injection Payload

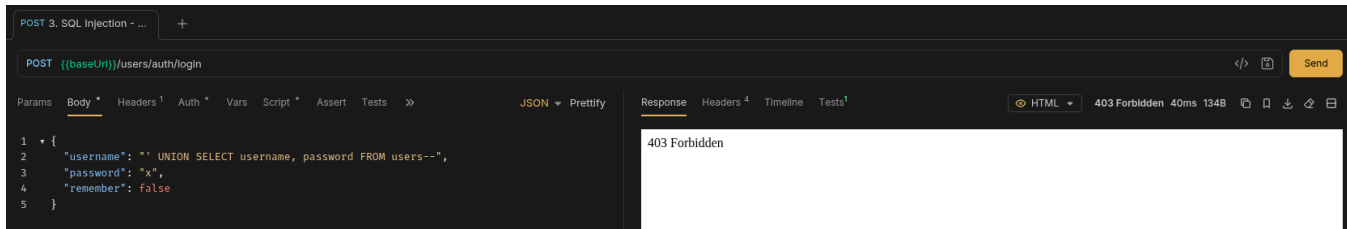


Figure 6.24.4 - Cloud Logging on Deny

Severity	Time	Summary
▼ jsonPayload: { @type: "type.googleapis.com/google.cloud.loadbalancing.type.LoadBalancerLogEntry" backendTargetProjectNumber: "projects/521897010746" ▶ cacheDecision: [2] ▼ enforcedSecurityPolicy: { configuredAction: "DENY" inspectedBodySize: 65536 matchedFieldLength: 46 matchedFieldName: "username" matchedFieldType: "ARG_VALUES" matchedFieldValue: " SELECT username" matchedLength: 31 matchedOffset: 7 name: "prod-cloud-armor-waf" outcome: "DENY" ▶ preconfiguredExprIds: [1] priority: 1000 } remoteIp: "103.6.150.99" ▶ securityPolicyRequestData: {3} statusDetails: "body_denied_by_security_policy" } logName: "projects/chronoflow-1/logs/requests"		

Figure 6.24.5 - SQL Injection test using SQLMap (Blocked by WAF)

[illegible]

Figure 6.25.1 - XSS Payload

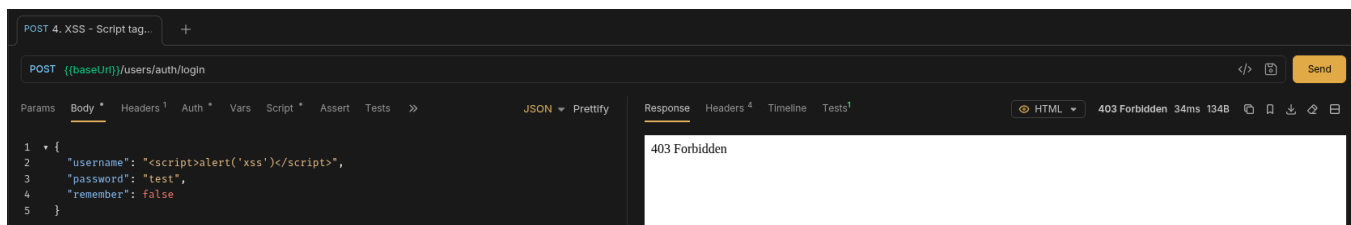


Figure 6.25.2 - Cloud Logging on Deny



Figure 6.25.3 - XSS Payload

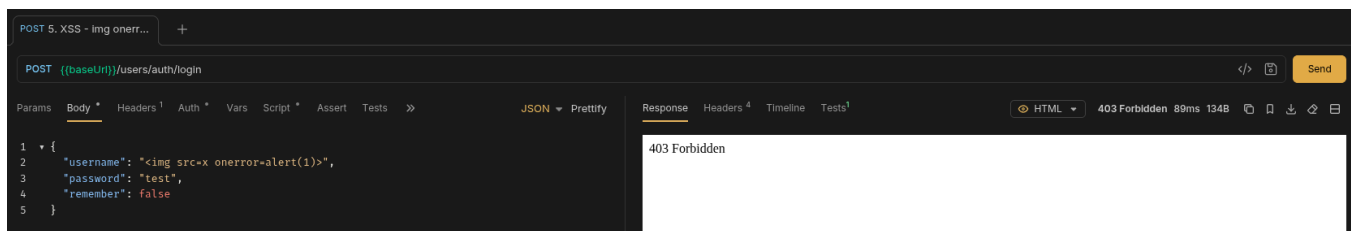


Figure 6.25.4 - Cloud Logging on Deny

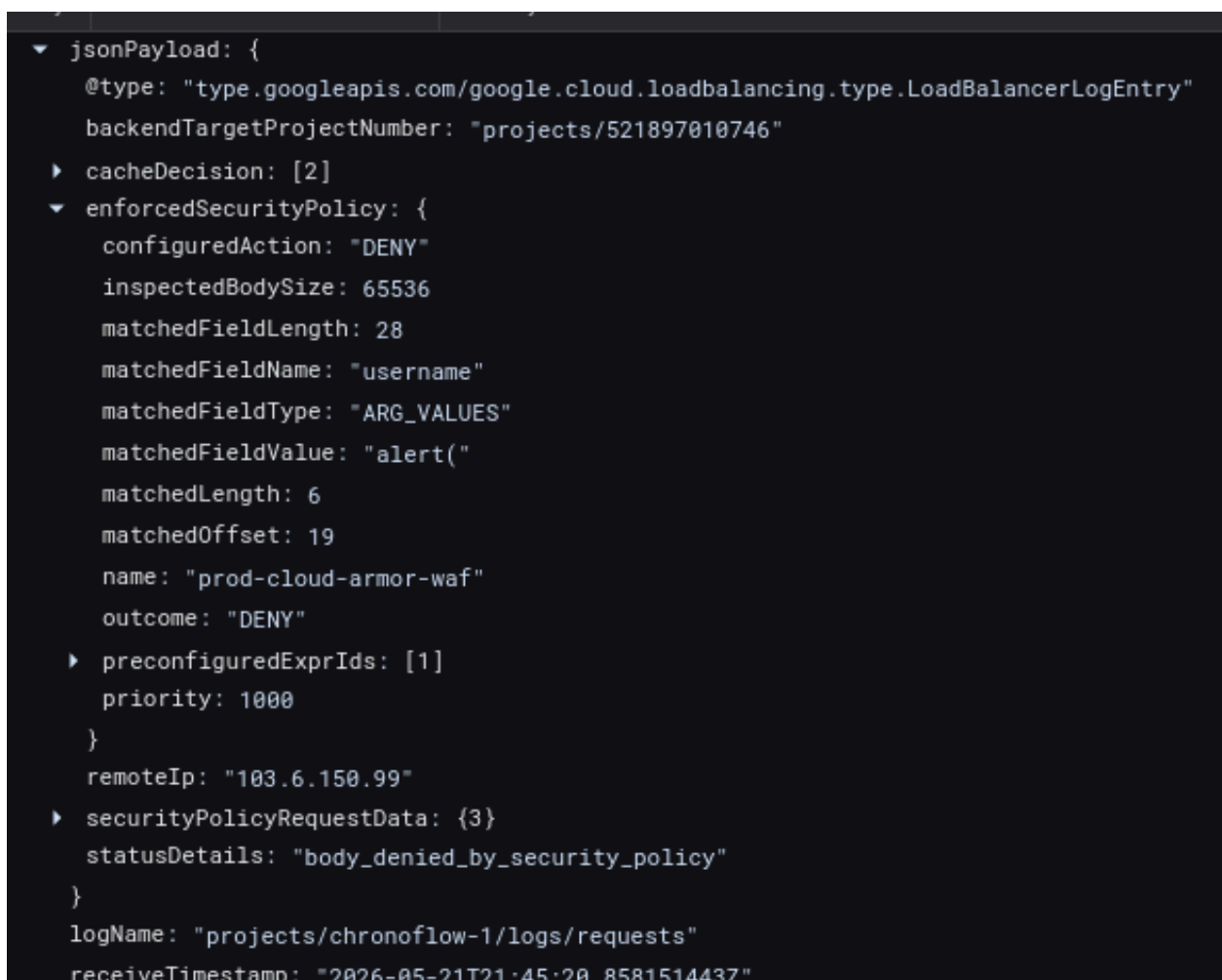


Figure 6.26.1 - Path Traversal Payload

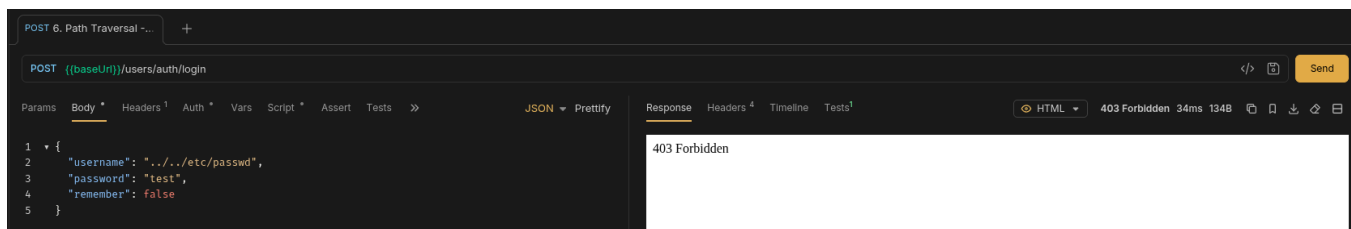


Figure 6.26.2 - Cloud Logging on Deny

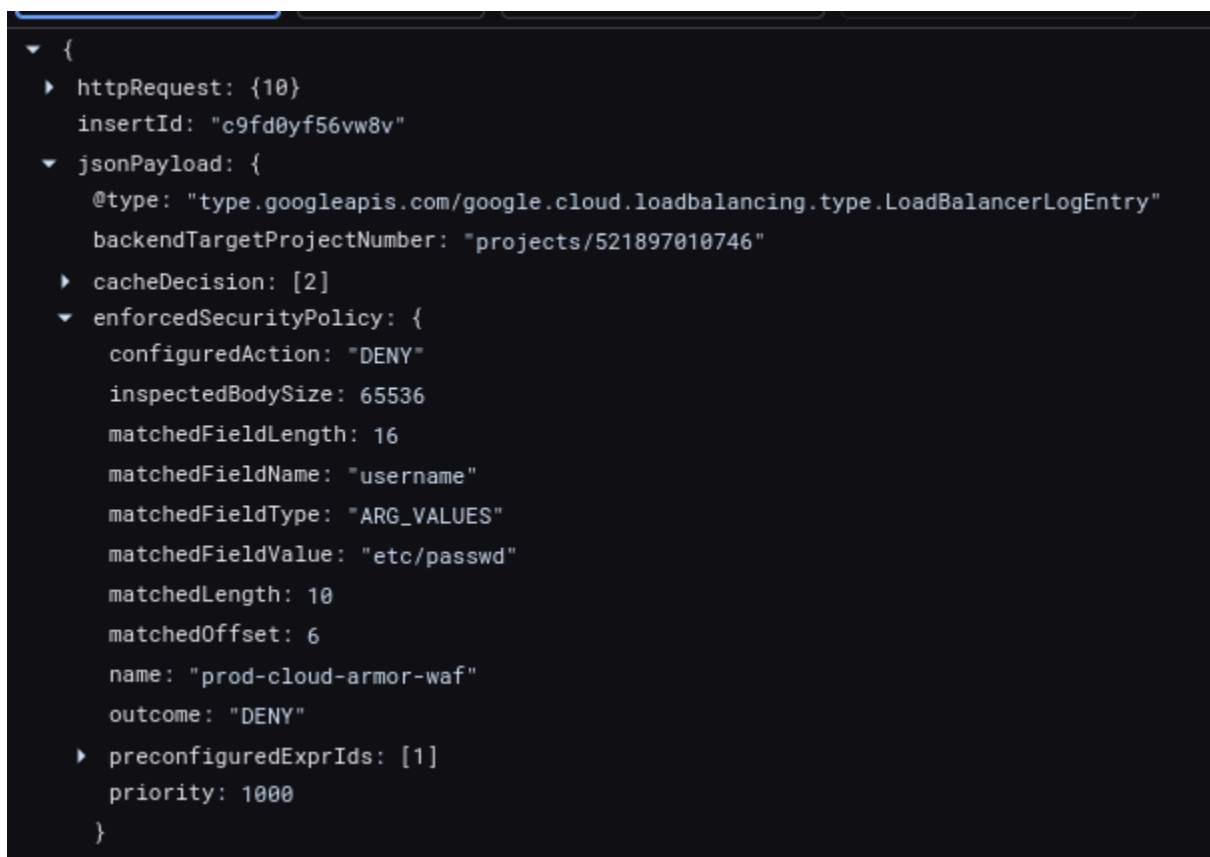


Figure 6.27.1 - Information gathering tools User-Agent

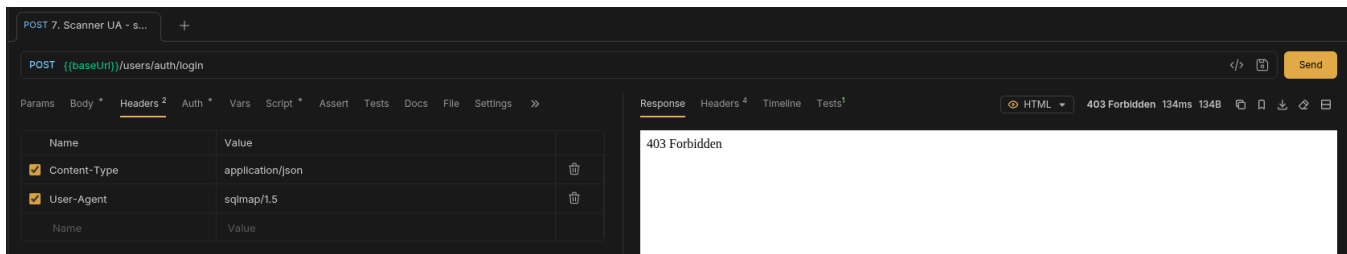


Figure 6.27.2 - Cloud Logging on Deny

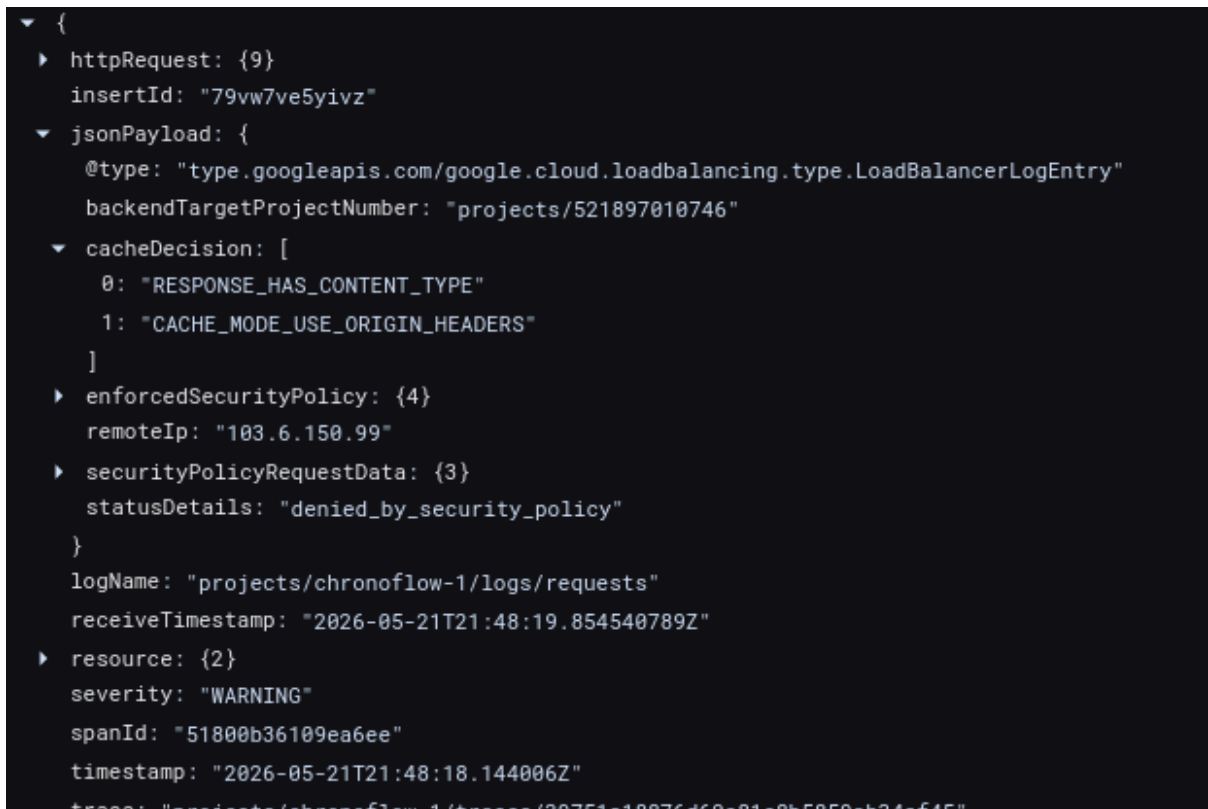


Figure 6.27.3 - Information gathering tools User-Agent

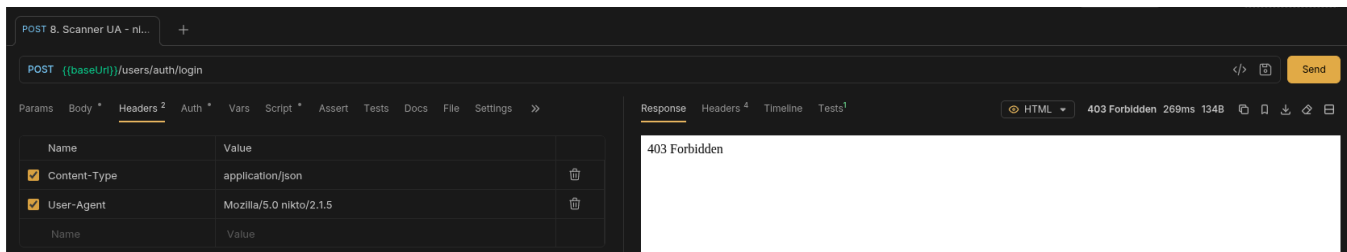


Figure 6.27.4 - Cloud Logging on Deny

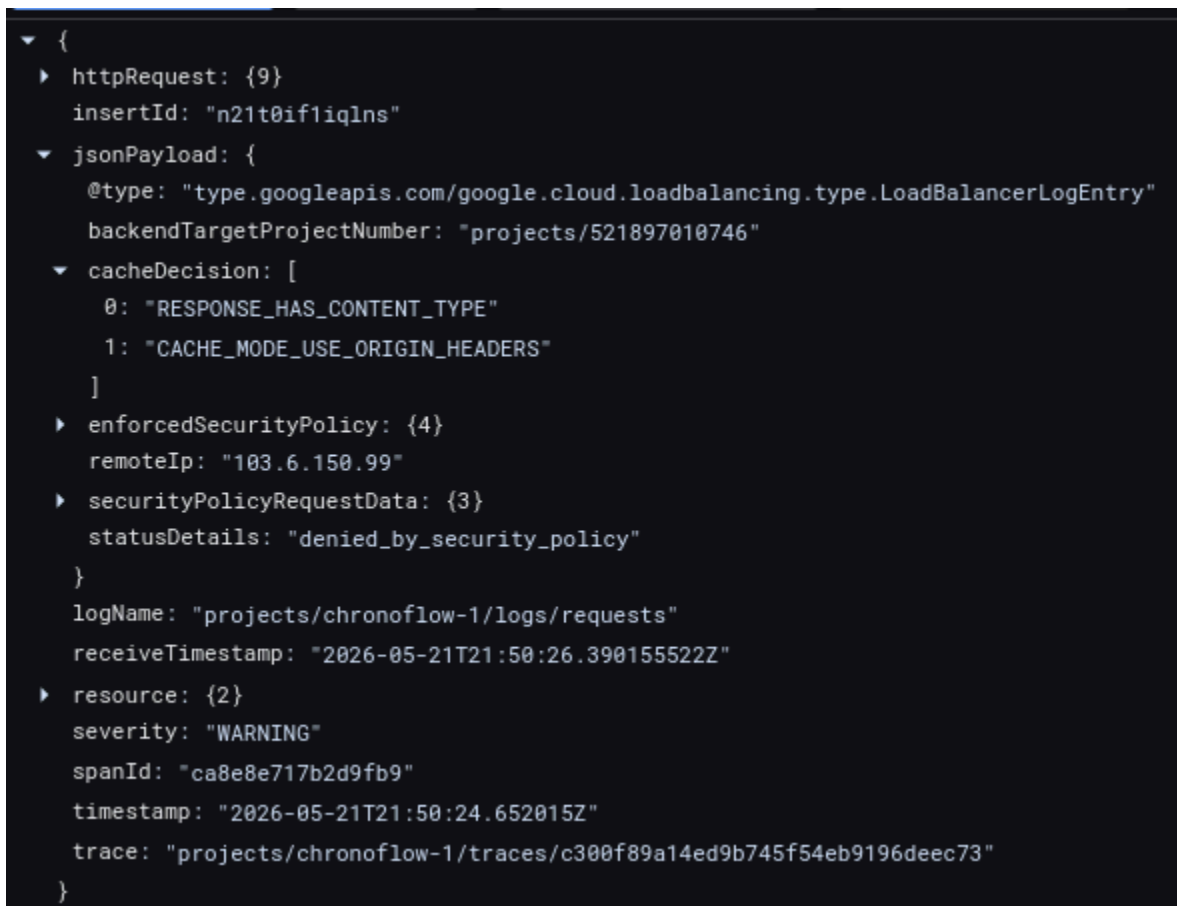


Figure 6.28.1 - Spring4shell Payload

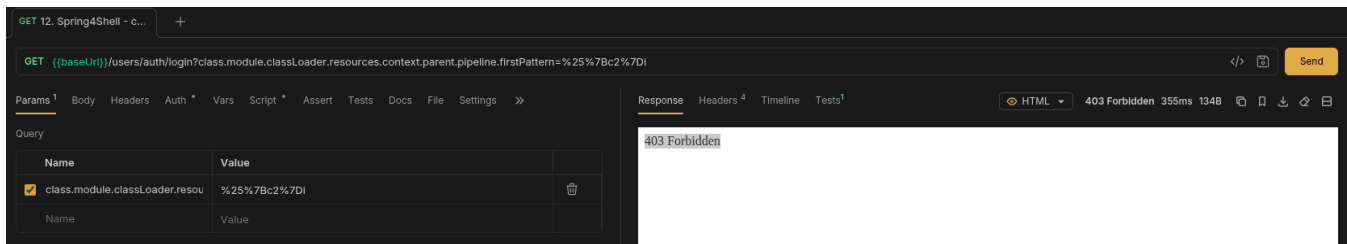


Figure 6.28.2 - Spring4shell Payload

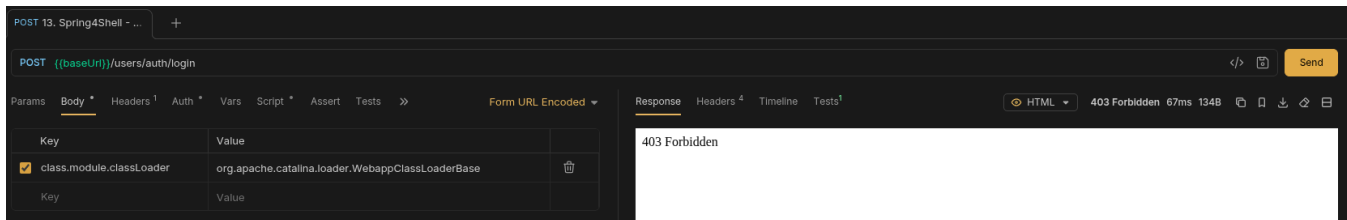


Figure 6.28.3 - Cloud Logging on Deny

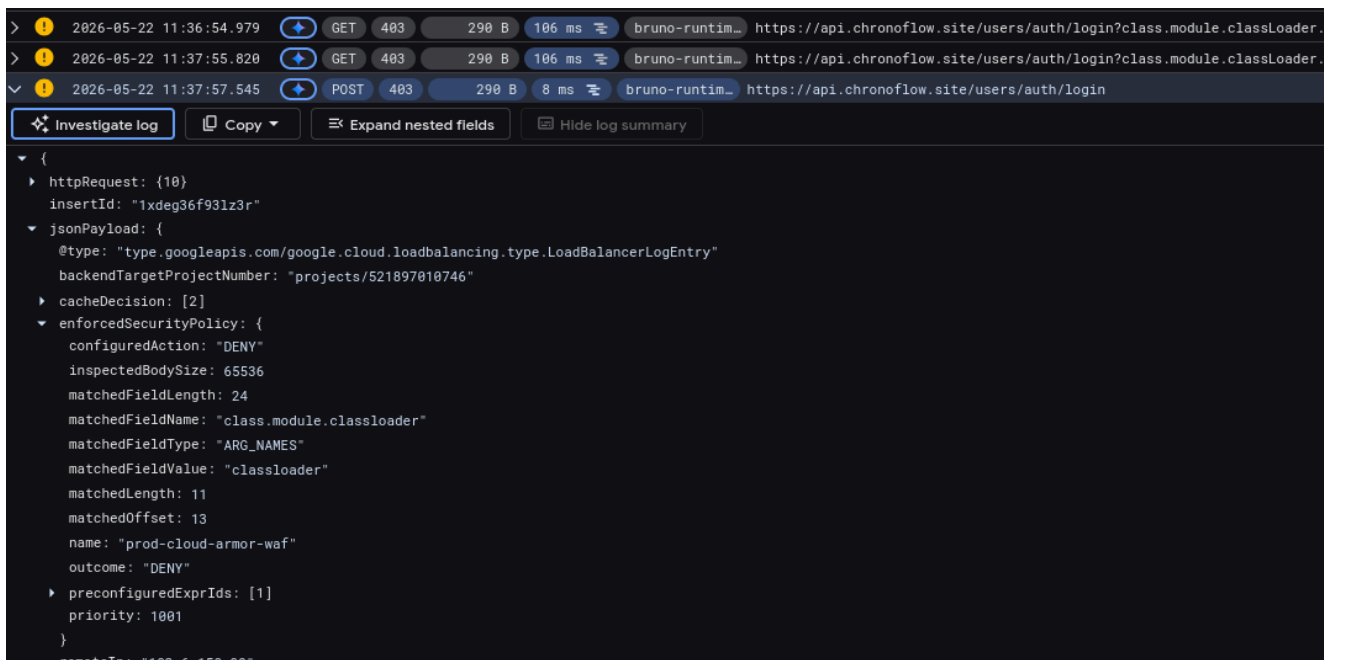


Figure 6.29.1 - Actuator information calls

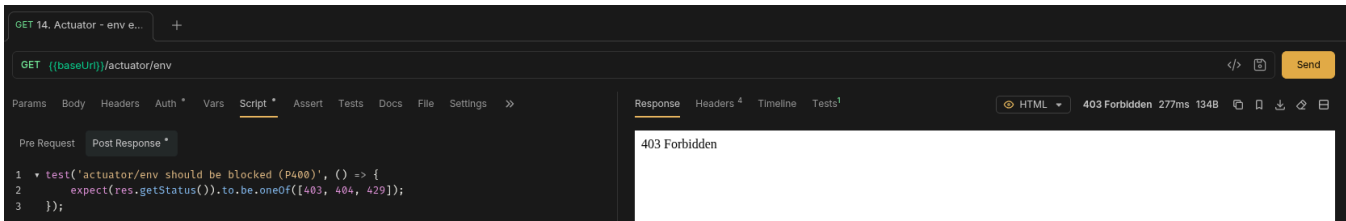


Figure 6.29.2 - Actuator information calls

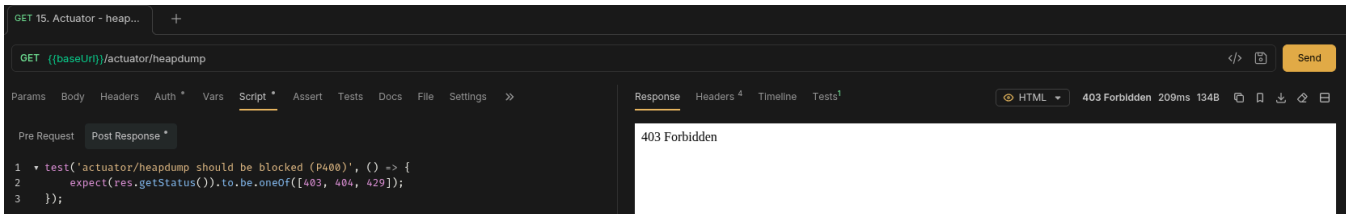


Figure 6.29.3 - Actuator information calls

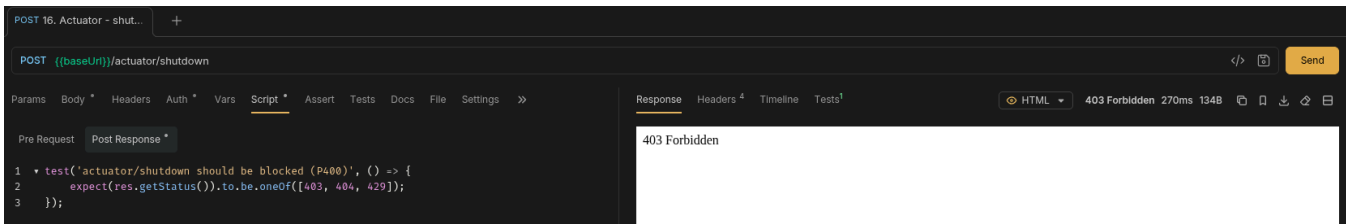


Figure 6.29.4 - Cloud Logging on Deny

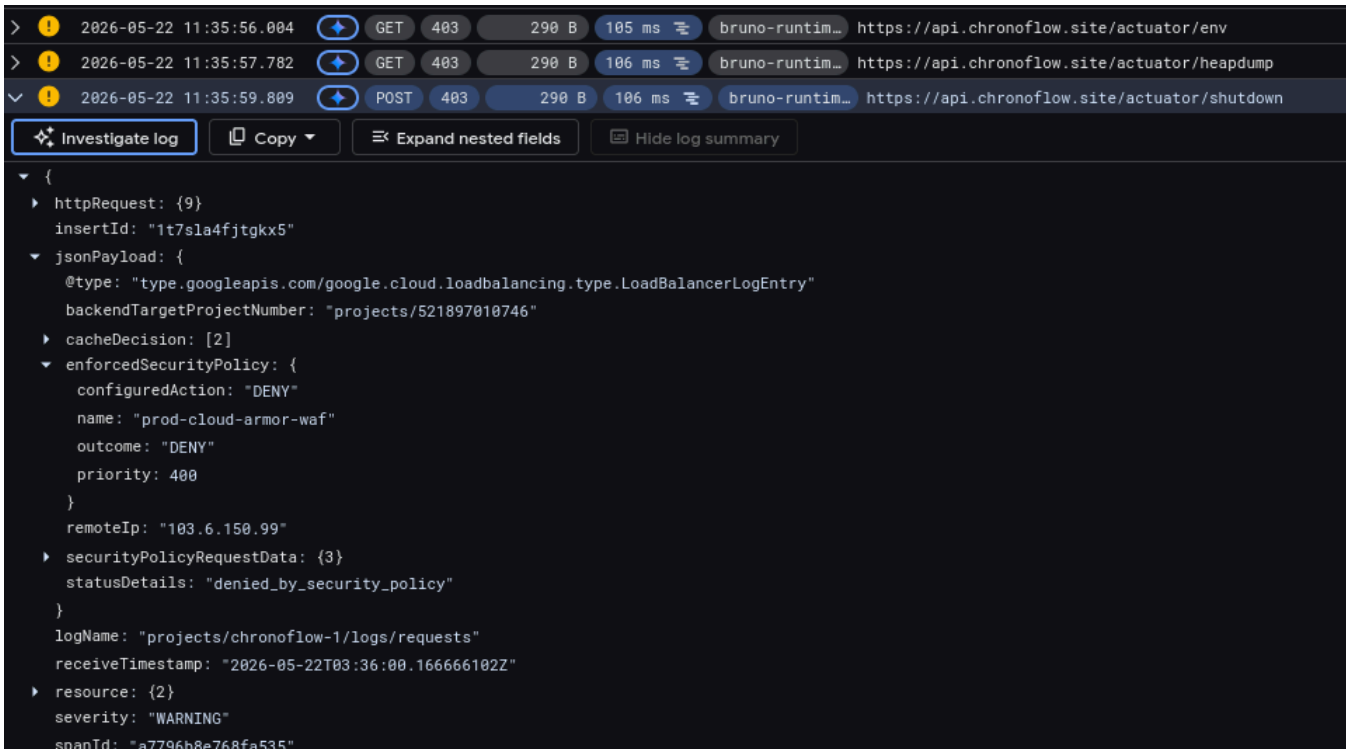


Figure 6.30.1 - Configuration file calls

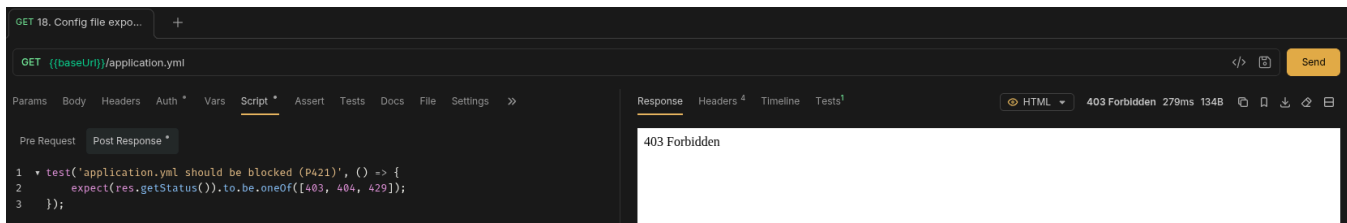


Figure 6.30.2 - Configuration file calls

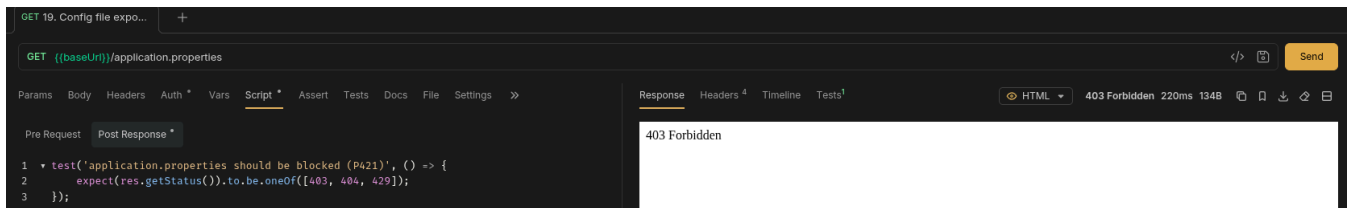


Figure 6.30.3 - Cloud Logging on Deny

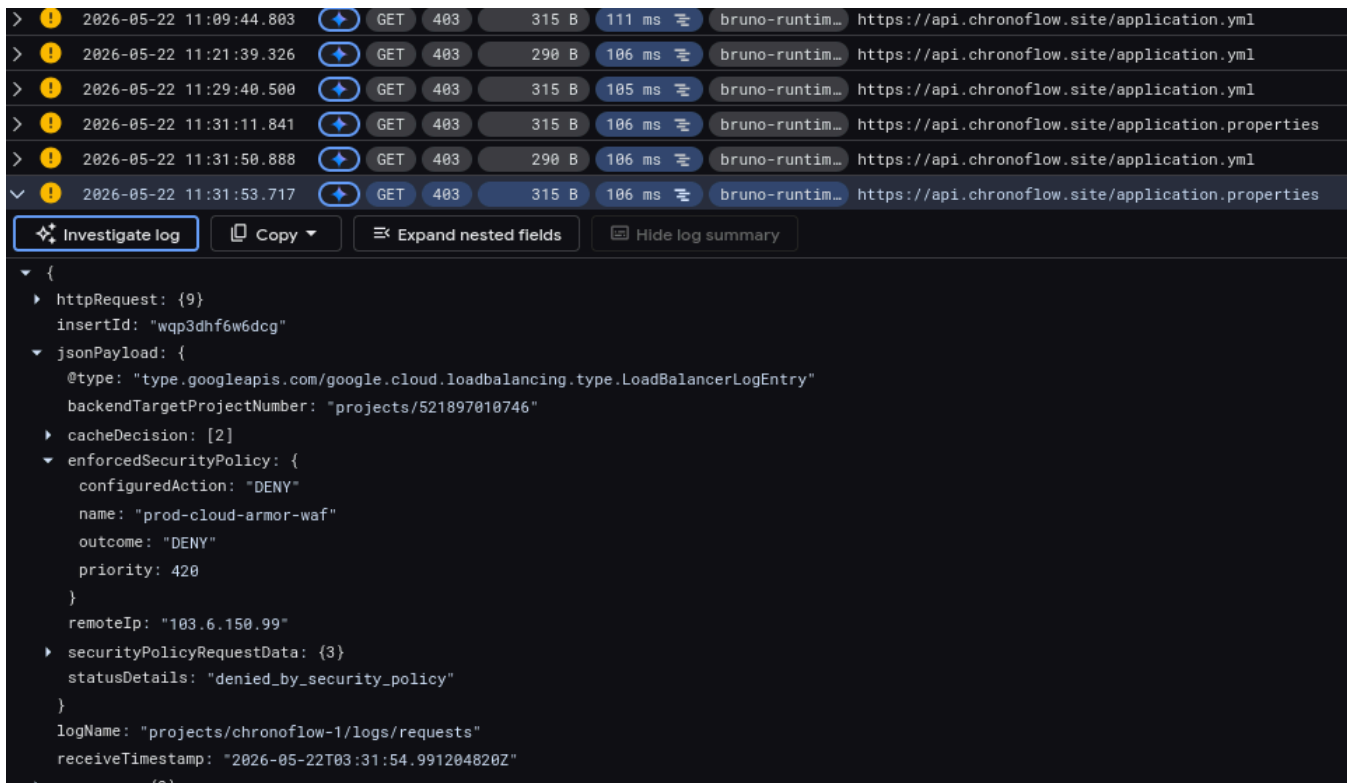


Figure 6.31.1 - Sensitive file calls

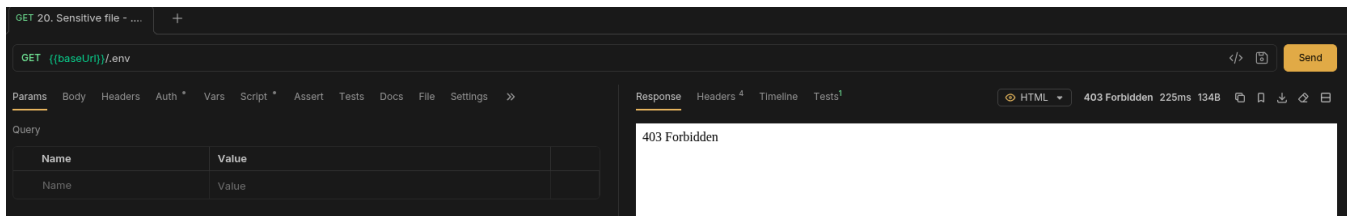


Figure 6.31.2 - Cloud Logging on Deny

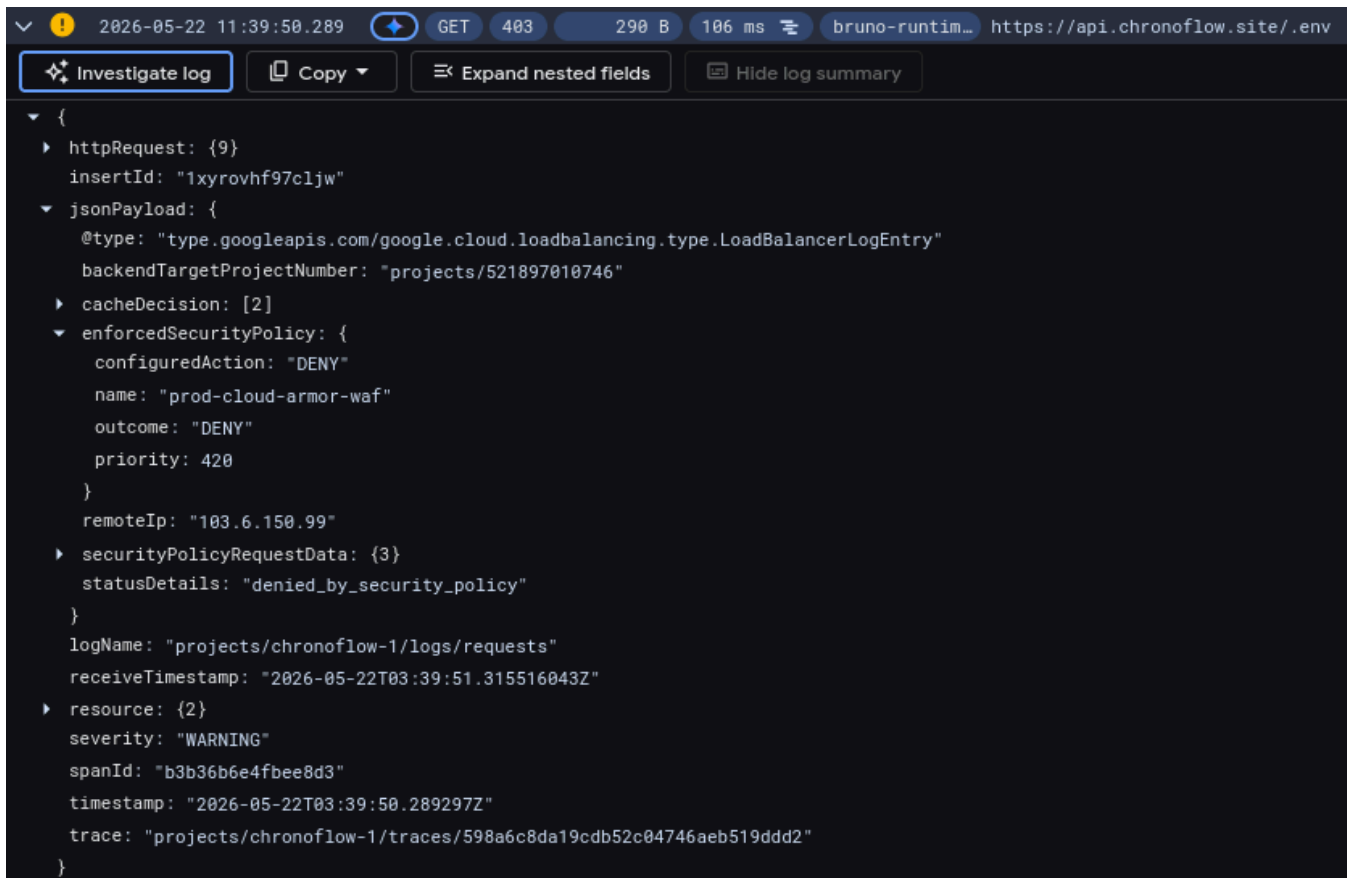


Figure 6.32.1 - Java deserialization Payload

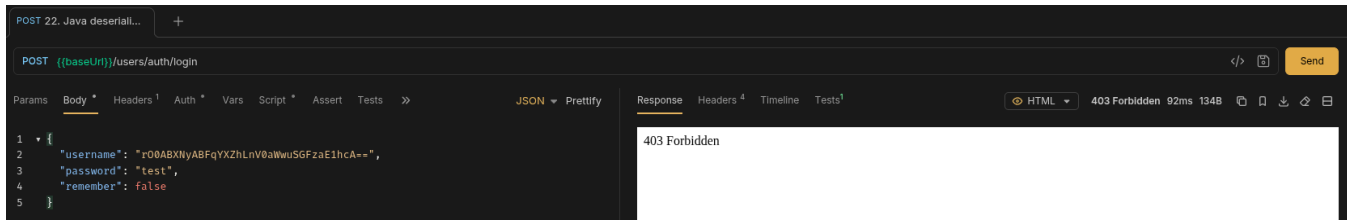


Figure 6.32.2 - Java deserialization Payload

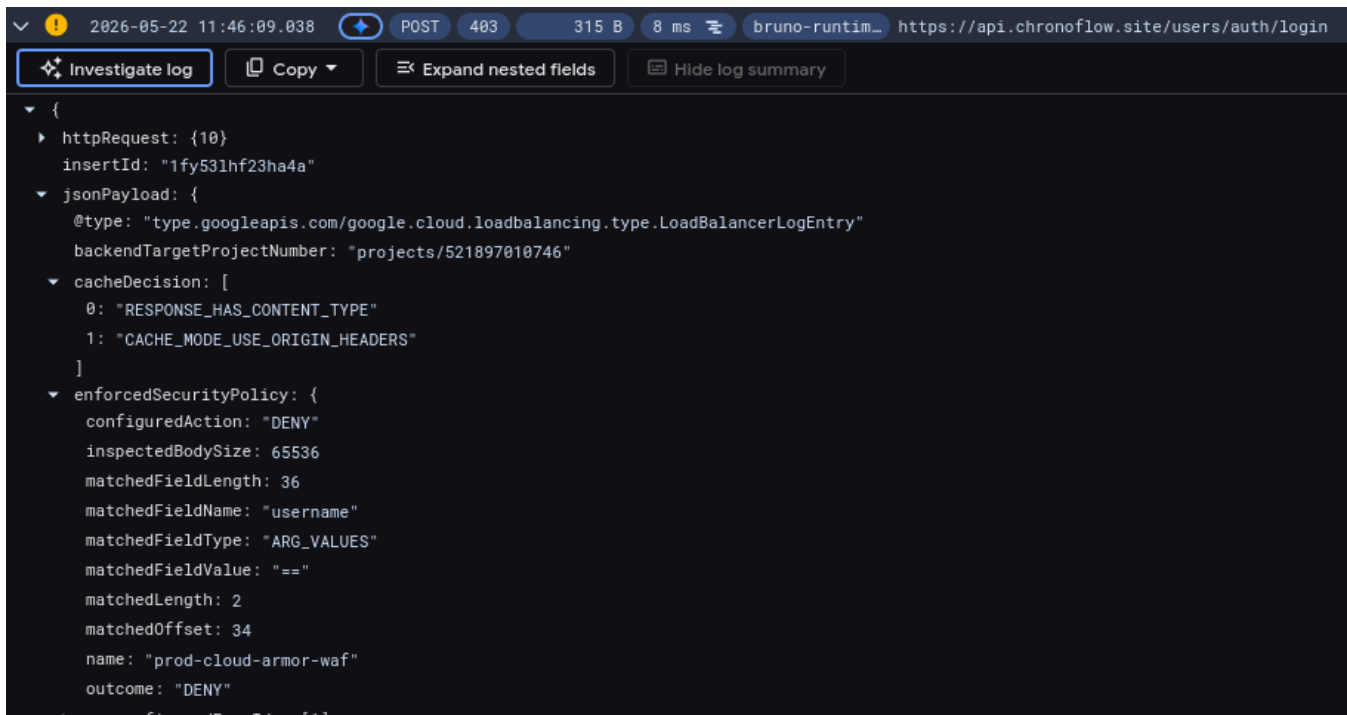


Figure 6.33.1 - Log4J JNDI Payload

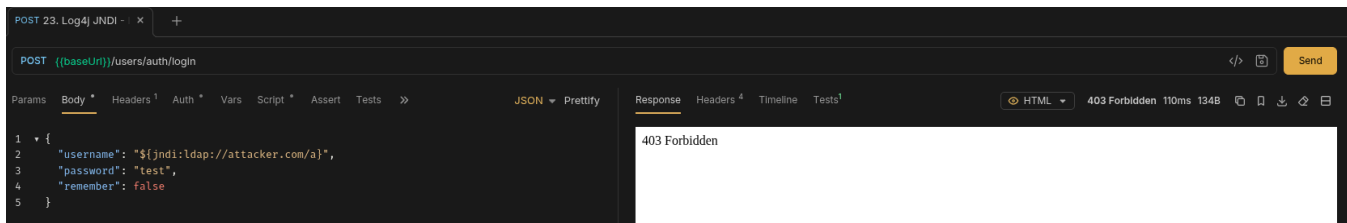


Figure 6.33.2 - Log4J JNDI Payload

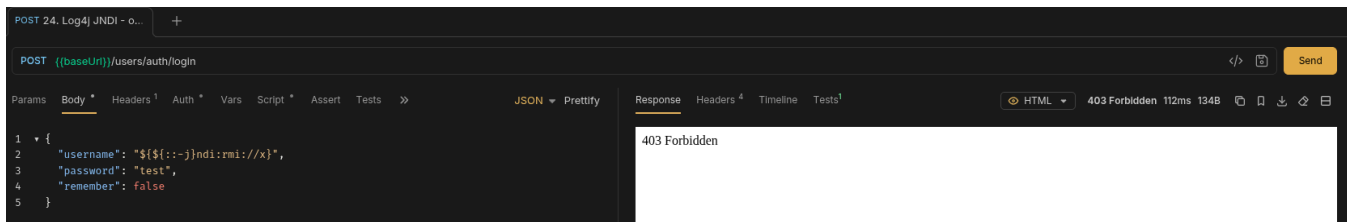


Figure 6.33.3 - Cloud Logging on Deny

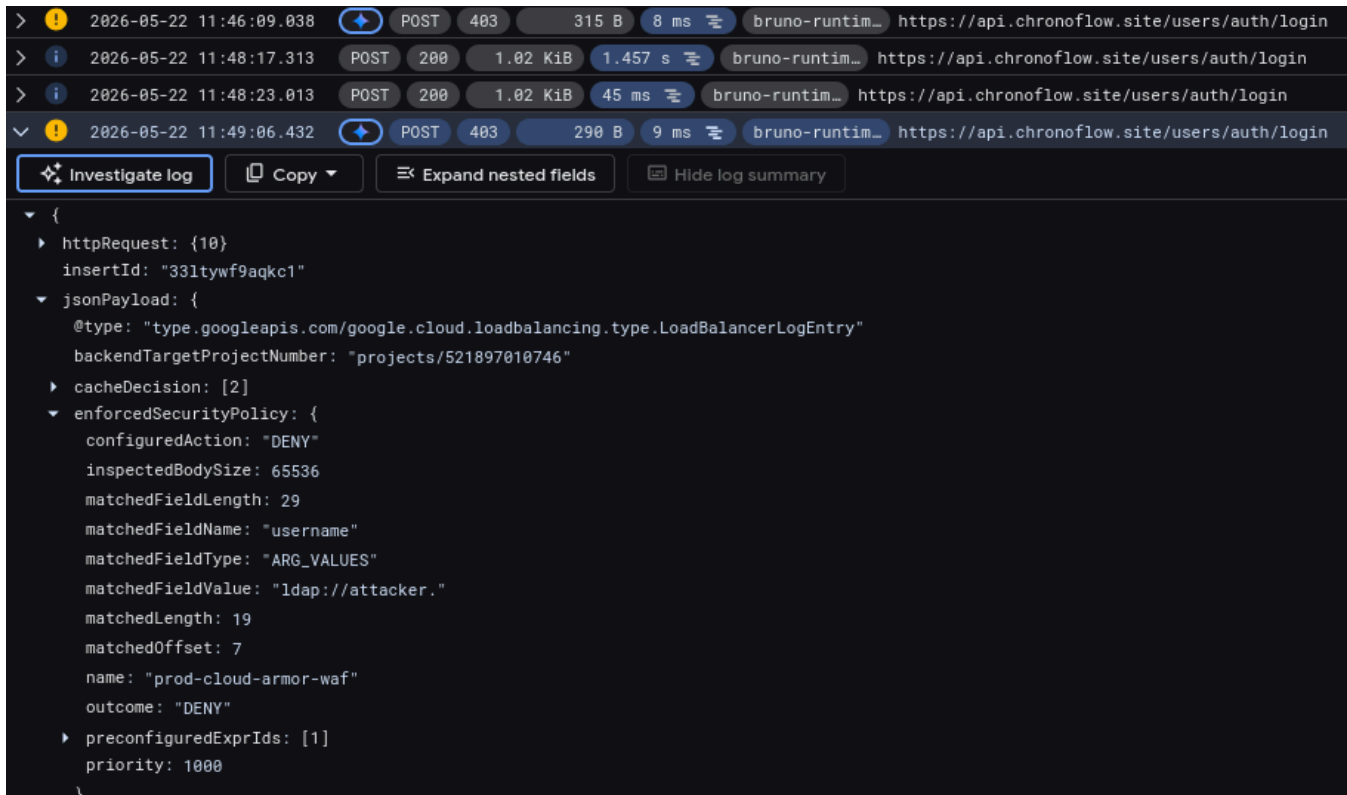


Figure 6.34.1 - Shell Command Payload

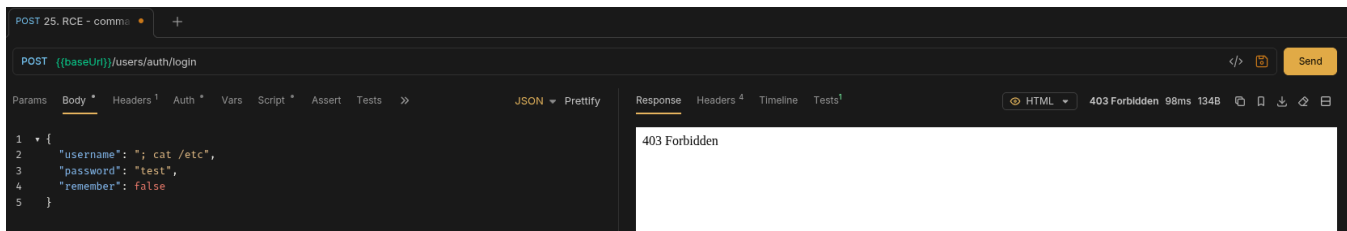
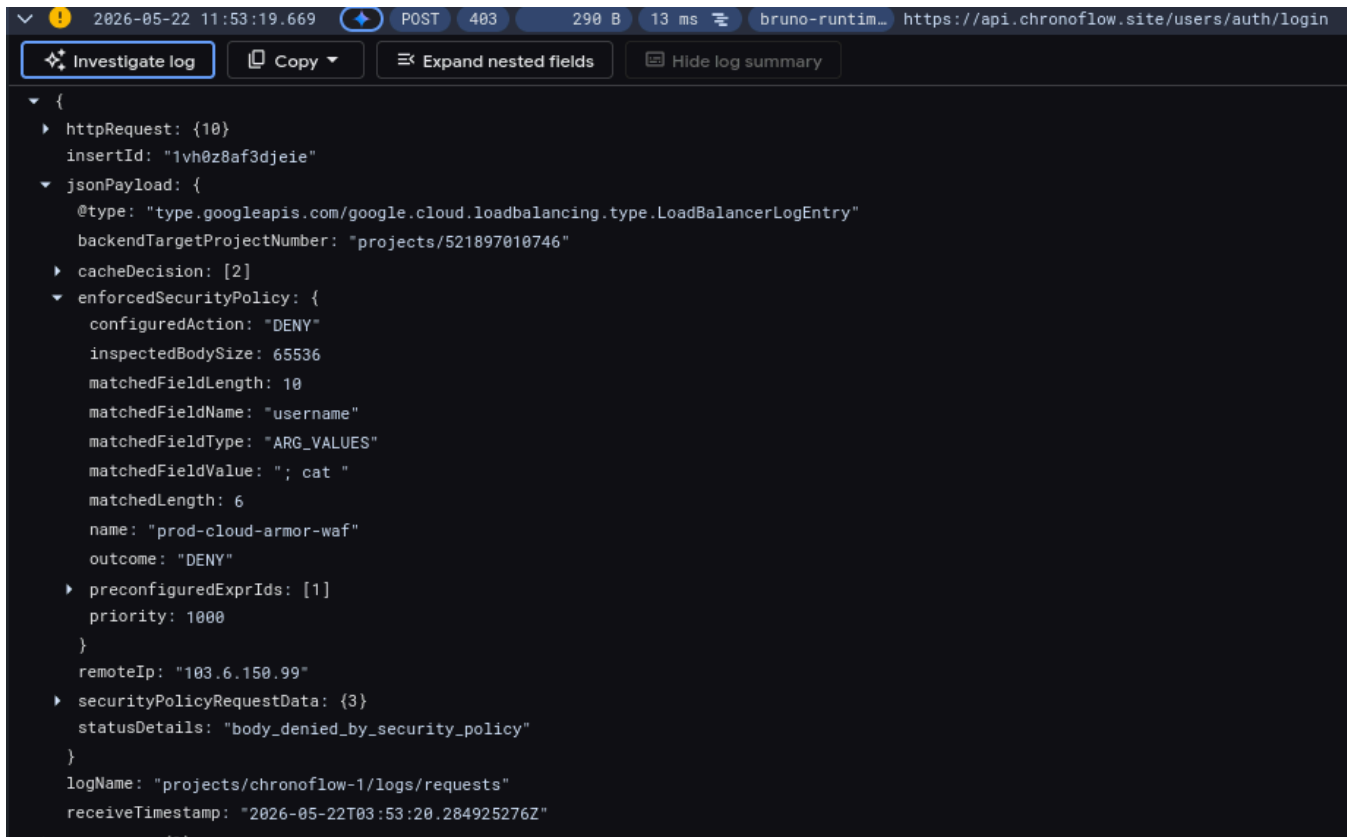


Figure 6.34.2 - Cloud Logging on Deny



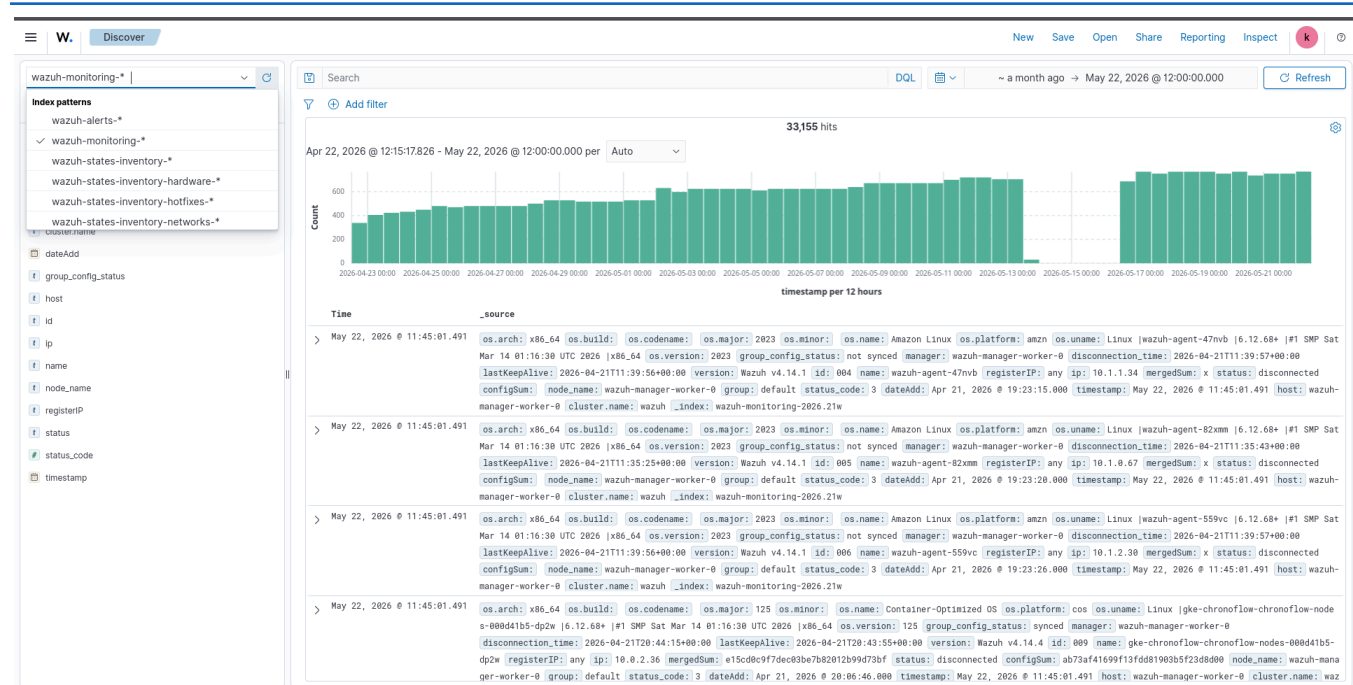
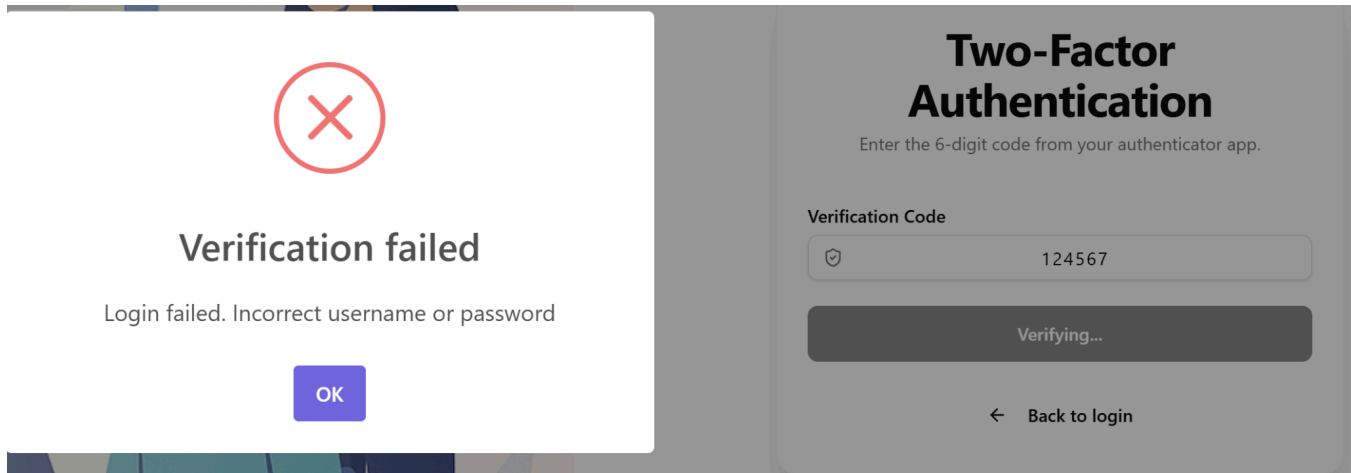


Figure 6.36.1 - MFA



V-53 / V-48 TOTP MFA – wrong code rejected, generic error returned

=====

Pre-condition (background): user has TOTP MFA enabled.

Account: secorgtest26 / Sr0ng-Tst-PW2026!

=====

STEP A: Login with username+password \MFA-enabled account\

POST http://localhost:8080/users/auth/login

RESPONSE:

{"code":0,"data":{"user":null,"roles":null,"mfaRequired":true,"mfaToken":"fb9b6e66-7874-4074-a0c3-3455765bbf2f"},"msg":""}

→ Server returns mfaRequired=true + a one-time mfaToken (no access token issued yet).

→ Captured mfaToken = fb9b6e66-7874-4074-a0c3-3455765bbf2f

=====

V-53 / V-48 test: submit WRONG TOTP code

Control: C-46 TOTP MFA / C-47 MFA Continuation Token

=====

STEP B: POST /users/auth/totp/verify with deliberately wrong 6-digit code

REQUEST body: {"mfaToken":"fb9b6e66-7874-4074-a0c3-3455765bbf2f","code":"000000"}

RESPONSE:

{"code":1001001,"data":null,"msg":"Login failed. Incorrect username or password"}

HTTP Status: 200

Figure 6.36.2 - Password Policy

Password *

.....|

👁

Strong

✓ At least 12 characters

✓ One upper-case letter

✓ One lower-case letter

✓ One digit

✗ One symbol (e.g. ! @ # \$ %)

✓ Not a commonly breached password

One symbol (e.g. ! @ # \$ %)

V-46.c Password Policy – rejected: contains username

=====

V-46 Test 3/3: Password rejected – CONTAINS USERNAME (identity check)
Control: C-40 Password Policy Enforcement (cross-field rule)

=====

REQUEST:
POST http://localhost:8080/users/reg/organizer
Body username = "identitytest01", password = "Identitytest01-Strong2026!"
(password contains username, ≥5 char substring rule trips)

RESPONSE:
{ "code":1001014,"data":null,"msg":"Password must not contain the username"}

HTTP Status: 200

V-46.a Password Policy – rejected: too short

=====

V-46 Test 1/3: Password rejected – TOO SHORT (< 12 chars)
Control: C-40 Password Policy Enforcement

=====

REQUEST:
POST http://localhost:8080/users/reg/organizer
Body password = "Pass1!" (6 chars)

RESPONSE:
{ "code":400,"data":null,"msg":"Password length must be between 12 and 128 characters"}

HTTP Status: 200

V-46.b Password Policy – rejected: missing symbol class

=====

V-46 Test 2/3: Password rejected – MISSING CHARACTER CLASS (no symbol)
Control: C-40 Password Policy Enforcement

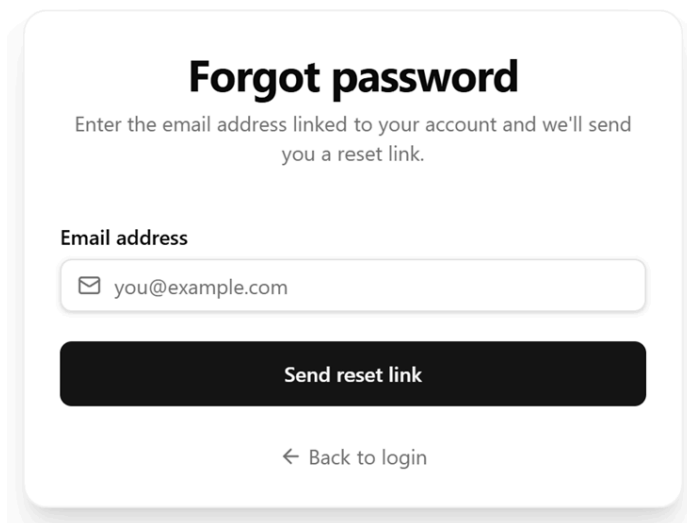
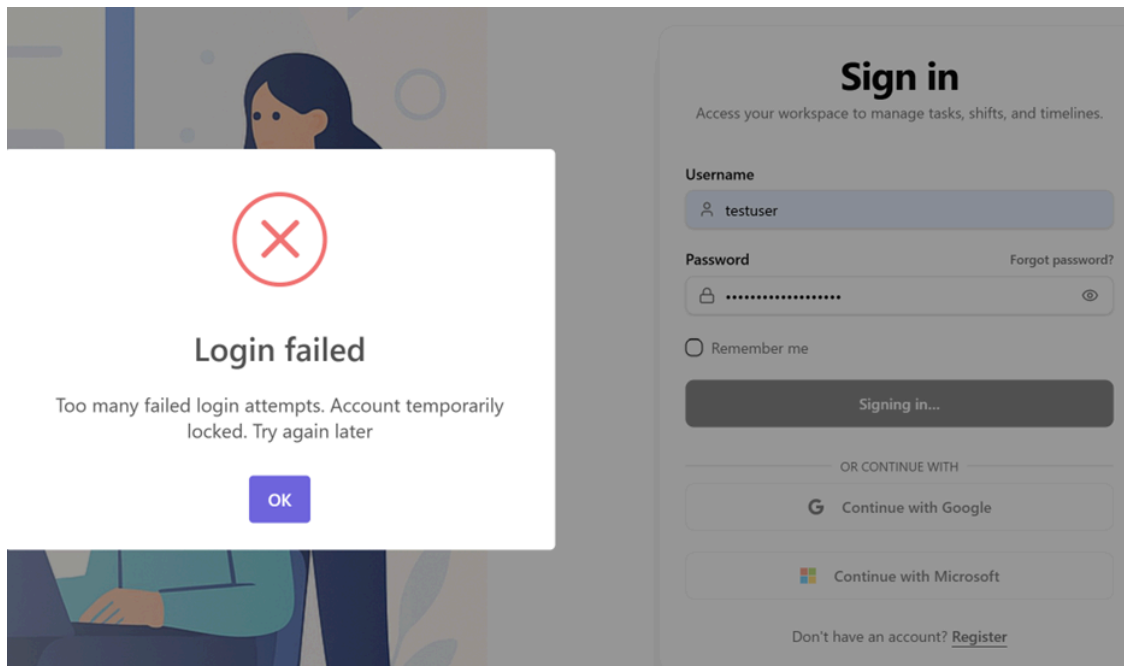
=====

REQUEST:
POST http://localhost:8080/users/reg/organizer
Body password = "PasswordTest2026" (16 chars, no symbol)

RESPONSE:
{ "code":400,"data":null,"msg":"Password must contain at least one symbol (e.g. ! @ # \$ %)"}

HTTP Status: 200

Figure 6.36.3 - Password Reset



Check your email

If an account exists for that email, a reset link has been sent. The link is valid for 30 minutes.



Didn't receive an email? Check your spam folder, then try again with the exact email on your account.

[Back to login](#)

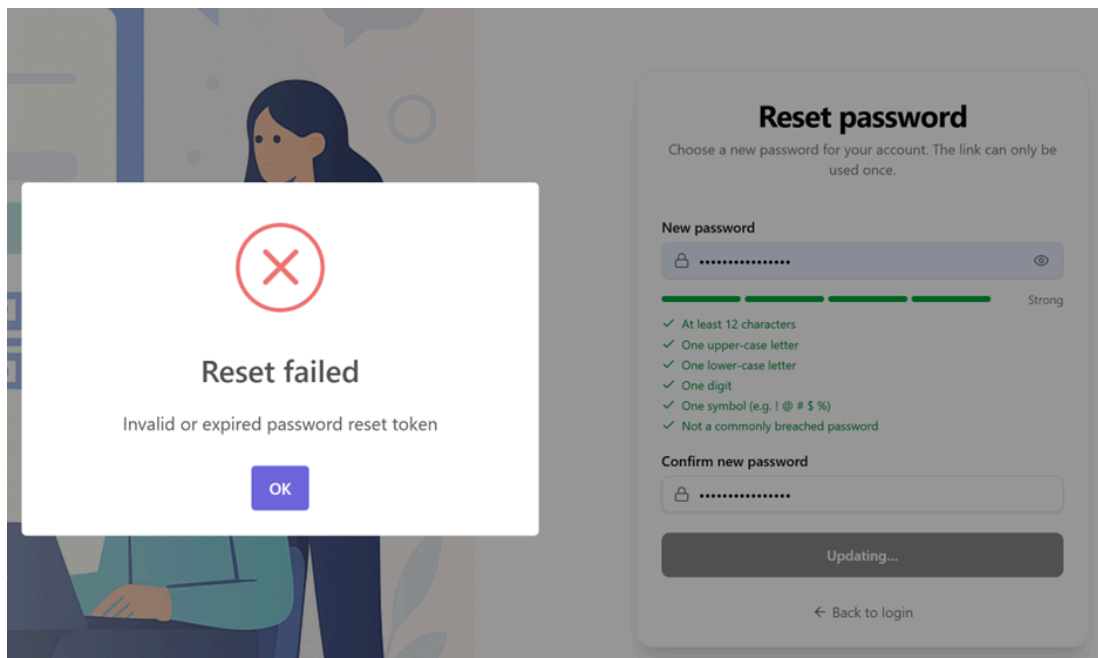


Fig 6.36.4 MFA sequence diagram

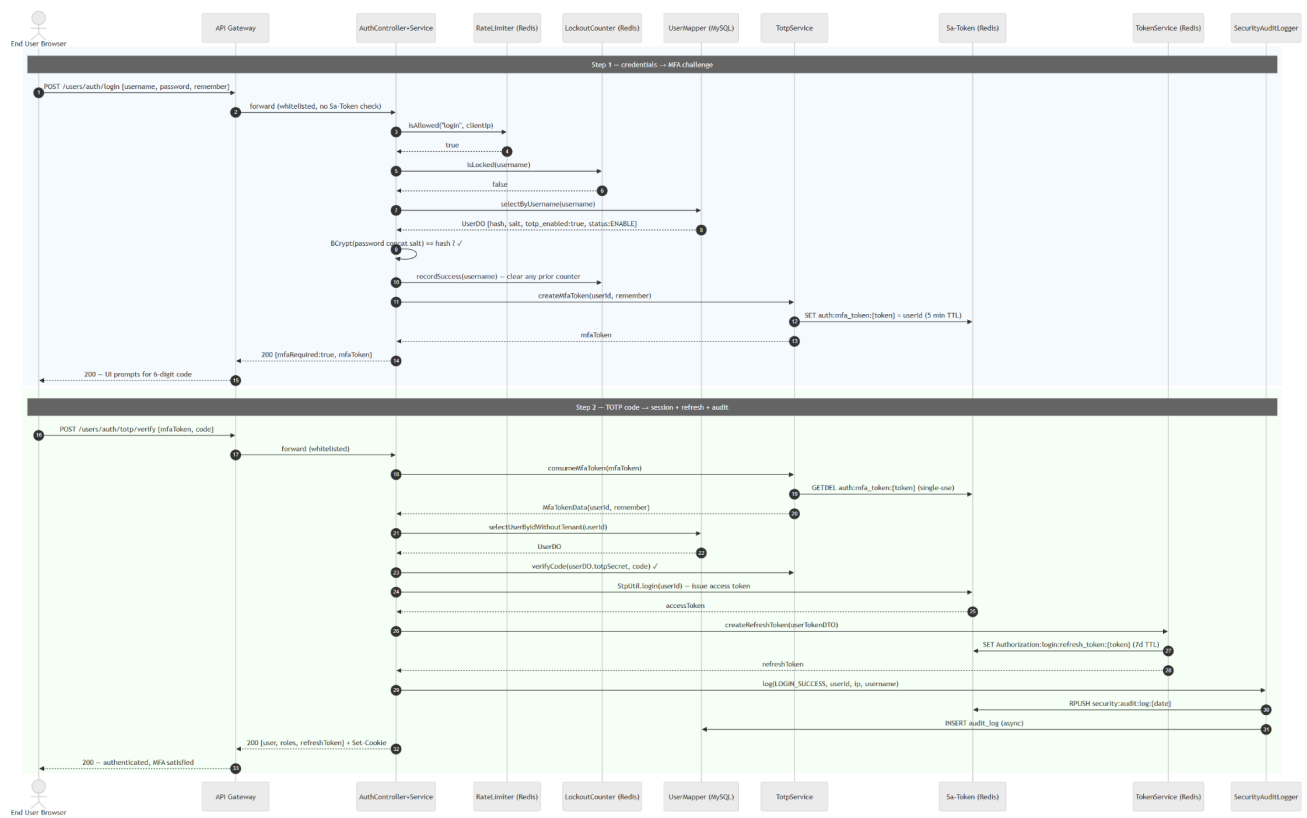


Fig 6.36.5 Password Reset sequence diagram

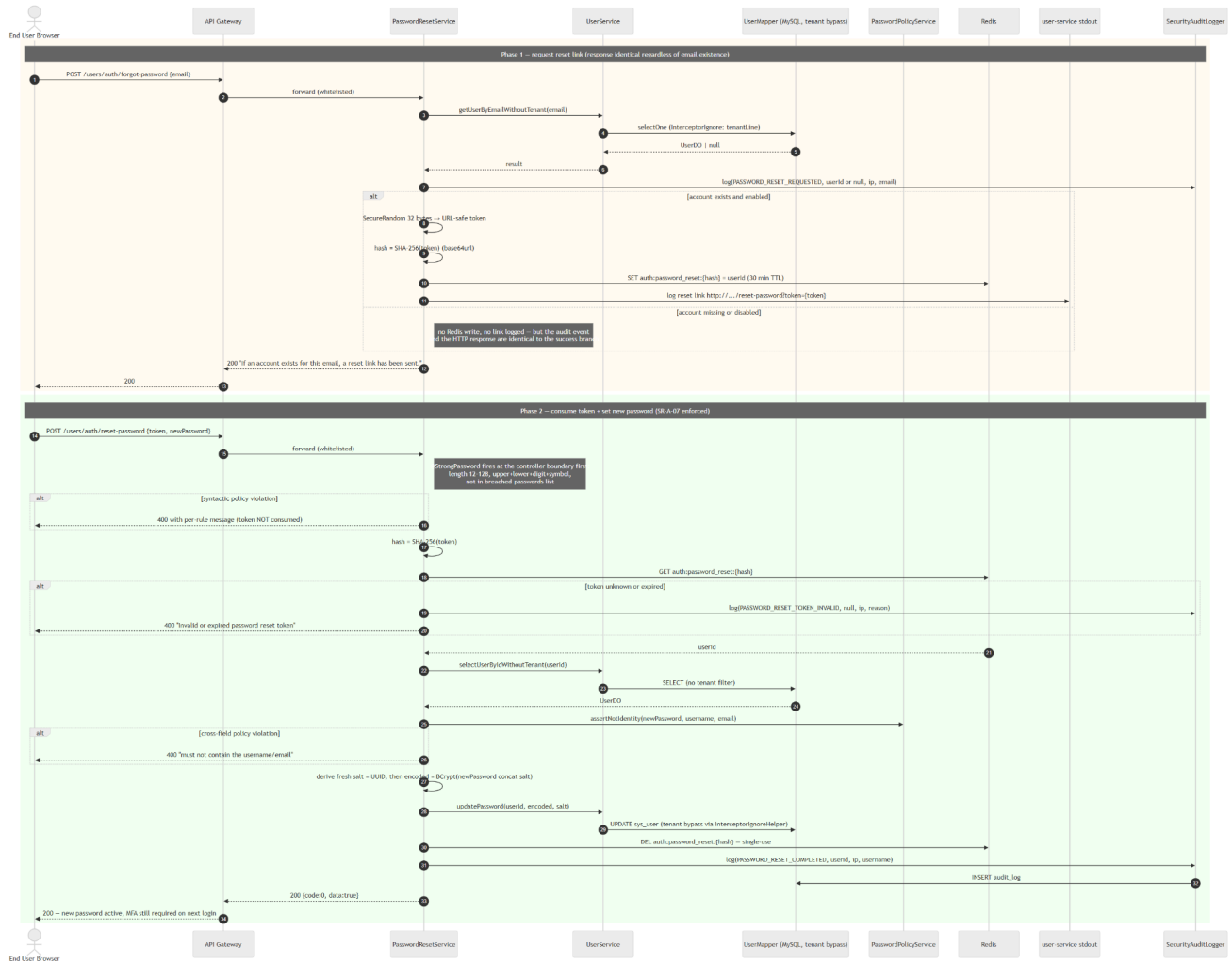


Fig 6.36.6 Too many failed logins sequence diagram

